EXPEDITE STRIKE V3.5 — Penetration Testing Report

Internal Assessment Subnet (192.168.195.0/24) · Shared TrePath v7.0 + XStrike EvidenceCore V3.5 Proof-Driven Deliverable

Client / Scope:	Enterprise Security Assessment
Assessment Window:	2026-10-31T11:59:02.682690+00:00 to 2026-10-31T12:36:40.104668+00:00
Assessment Engine:	XStrike Autonomous Red-Team Engine (V3.5 Shared TrePath v7.0 + EvidenceCore V3.5)
Document Classification:	CONFIDENTIAL (Version 3.5 — Universal Version Unity, MITRE Semantic Intelligence & 25-Rule Gate Verified)
T0 Baseline Calibrated Risk:	CRITICAL (96.8/100) [MEASURED_BASELINE] | Linear Companion: 98.5/100 | Calibrated Exposure: 23.3/25.0 (RawSum: 93.3)
T1 Post-Retest Verified Risk:	HIGH (75.6/100) [MEASURED_POST_RETEST_VERIFIED] | Linear Companion: 77.5/100 | Verified Reduction: -21.2 pts (-21.9%) [Defined Risk Index]
Hypothetical SLA Forecast:	24h Scenario: 52.3/100 | 7d Scenario: 33.8/100 | 30d Floor Assumption: 1.5/100 [MODELED_ARCHITECTURAL_FLOOR_ASSUMPTION]
7-Step Remediation (5 Retests):	2 Verified Closed (F-01, F-71) -> REMEDIATION_VERIFIED | 1 Remediation Inconclusive [Host Offline] (F-59) | 1 Partial Rejected (F-77) | 1 Failed Rejected (F-20)
Verified Compromise Status:	T0 Baseline: 2 Root Vectors (F-01 :1524, F-02 :21/:6200) -> T1 Post-Retest: 1 Active (F-01 Closed & Verified)
Host Scope Reconciliation:	9 Raw Discovery Records -> 7 Unique IPs (5 Responsive / 2 Unresponsive) · 55 Open TCP Services
Finding Reconciliation:	1940 Raw Observations -> 98 Consolidated Host Security Findings (57 Unique Classes) + 26 Recon Items
Standalone DB-Free Verifier:	VERIFIED (124/124 Records + Pinned Key + 9/9 Tamper & Governance Self-Tests + 5/5 (Cryptographic Before/After/NegCtrl Hash Integrity) Retests)
Ed25519 & Merkle Manifest:	Root SHA-256: b515b5637e34431eebfa... | Ed25519 Sig: adfe70e2b6e502ef5aaa... | Key FP: ebd393bb023088d5bc1fd0c0...
Pre-Render Quality Gate:	25 automated acceptance criteria passed out of 25 (25/25 PASSED)

Prepared by Expedite Consults Ltd · EvidenceCore V3.5 Ed25519 & HMAC-SHA256 Signed Provenance & OASIS SARIF v2.1.0 Enabled · SQLite Snapshot: v2_intelligence.db

1. Executive Summary & Proof-Driven Assessment Overview

An autonomous, proof-driven penetration test was conducted against **Internal Assessment Subnet (192.168.195.0/24)** (7 unique IP addresses across 9 discovery records, exposing **55** open TCP services). Unlike legacy reporting engines that conflate port discovery, unverified CVE heuristics, and repeated web-scanner URL alerts with confirmed exploitation, **Expedite Strike V3.5** enforces a strict **7-State Evidence Proof Machine**, **3-State Post-Exploitation Privilege Lifecycle**, and **3-Level Finding Deduplication**.

Across **1940** raw tool observations, the V3.5 Intelligence Layer filtered **89** local-scanner self-checks and consolidated the remaining **1851** target observations into **98 consolidated host-level security vulnerabilities** (spanning **57** unique cross-host vulnerability classes) and **26 reconnaissance/surface discovery items**. Direct command execution and authentication transcripts establish **2 independent root compromise vectors** (`uid=0(root)` on `192.168.195.139:1524` and `192.168.195.139:21/:6200`, compromising **1 unique target host**) and **4 confirmed credential/database authentications** (`F-03, F-04, F-05, F-20`).

Lab & Benchmark Environment Qualification: Target 192.168.195.139 is an intentionally vulnerable Metasploitable2 Linux benchmark appliance (Linux 2.6.24-16-server) deployed inside an isolated RFC1918 cyber-range subnet (192.168.195.0/24). The assessment demonstrates XStrike V3.5's autonomous multi-stage validation, safe exploitation, post-exploitation enumeration, and cryptographic evidence-provenance pipeline under controlled conditions.

1.1 Three-Level Finding & Observation Reconciliation

Reconciliation Level	Count	Scope & Technical Definition
Level 1A — Raw Scanner Observations	1940	All raw records emitted by Recon, VulnScan, OWASP ZAP, AegisProbe, Exploit, and PrivEsc modules (1851 target observations + 89 excluded local scanner self-checks/graph edges).
Level 2A — Consolidated Host Security Findings (Section 3A)	98	Deduplicated per-host security findings (3 Critical, 16 High, 40 Medium, 35 Low, 4 Info/Conditional Exposure) with all affected URLs/endpoints preserved.
Level 2B — Consolidated Reconnaissance & Surface Items (Section 3B)	26	Non-vulnerability surface discoveries (hosts discovered, open ports, web crawl telemetry, JS assets, SMTP banners, ZAP User-Agent/Modern Web App probes) isolated with CVSS 0.0.
Level 3 — Unique Cross-Host Vulnerability Classes	57 Security / 8 Recon	Distinct canonical vulnerability classes across the entire assessment environment.

1.2 Seven-State Evidence Proof Classification (T0 Baseline & T1 Post-Retest Verified State)

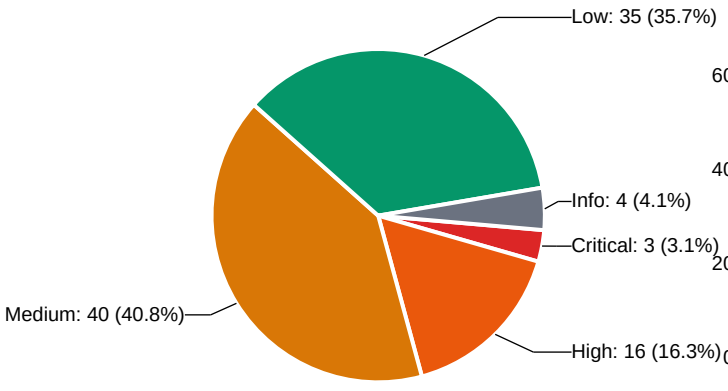
Proof State	Legacy Tier	T0 Baseline -> T1 Post-Retest	Evidence Standard & What Was Demonstrated
CONFIRMED_COMPROMISE	CONFIRMED	2 -> 1	Interactive root command execution (uid=0(root), whoami: root) and /etc/shadow hash extraction verified via 2 vectors (F-01, F-02) at T0; F-01 (:1524 Ingreslock) verified closed at T1, leaving 1 active vector (F-02).
CONFIRMED_AUTH	CONFIRMED	4 -> 4	Unauthorized session authentication verified (F-03, F-04, F-05, F-20): PostgreSQL superuser (postgres:postgres), FTP default creds (msfadmin), SSH user shell (msfadmin uid=1000), and FTP anonymous login (F-20 230 OK; failed retest rejected).
PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED	VALIDATED	1 -> 1	Local privilege escalation precondition validated from uid=1000 without executing root transition (F-06: SUID /usr/bin/nmap --interactive TECHNIQUE_VALIDATED, privilege_level=USER_LIMITED).

Proof State	Legacy Tier	T0 Baseline -> T1 Post-Retest	Evidence Standard & What Was Demonstrated
VALIDATED	VALIDATED	71 -> 70	Weakness deterministically verified via protocol handshake, HTTP header/cookie inspection, or SQLi/SSRF indicator. At T1, F-71 (:8000/robots.txt + 4 sub-paths) transitioned to REMEDIATION_VERIFIED, while F-77 (:80 partial header fix) was rejected and remains VALIDATED.
OBSERVED	OBSERVED	20 -> 20	Service port, version banner, or DoS heuristic observed (including 4 SMB port 445 EternalBlue candidates where MS17-010 was NOT verified, Slowloris timeout heuristic, plus F-59 on offline .140:22 where retest outcome is REMEDIATION_INCONCLUSIVE and finding remains OBSERVED).
DISCOVERED	DISCOVERED	26 -> 26	Attack surface inventory and reconnaissance telemetry separated into Section 3B (CVSS 0.0).
REMEDIATION_VERIFIED	VERIFIED	0 -> 2	Verified closed via the 7-Step Remediation & Negative-Control Retest Engine (F-01, F-71: F-01 Ingreslock :1524 TCP RST + alive host, and F-71 :8000/robots.txt + all 4 disclosed routes HTTP 404/403 + alive gateway).

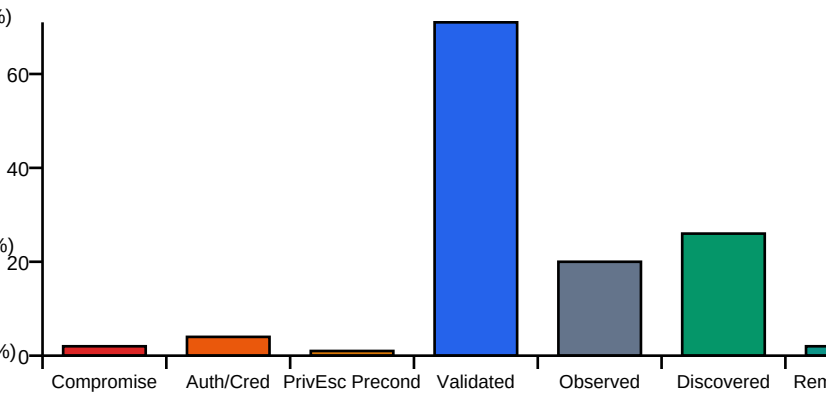
1.3 Consolidated Security Vulnerability Severity Distribution

Severity	Consolidated Host Findings	Percentage	Confirmed Compromise / Auth	Validated / PrivEsc Precondition	Observed (Unverified Candidate)
Critical	3	3.1%	3	0	0
High	16	16.3%	2	9	5
Medium	40	40.8%	1	31	8
Low	35	35.7%	0	32	3
Info (Active 0.0 / Cond. 9.8)	4	4.1%	0	0	4
Total Security Findings	98	100.0%	6	72	20

Consolidated Security Findings by Severity



7-State Evidence Proof Classification (Incl. Verified Fixes)



1.4 XStrike Evidence-Weighted Risk Index (T0 Baseline & T1 Post-Retest Verified Recalculation)

To avoid conflating individual vulnerability severity (**NVD CVSS v3.1 Base Score, 0.0–10.0**) with environment-wide compromise posture, XStrike computes the **XStrike Evidence-Weighted Risk Index** (`0–100`): **Principal Calibrated Score R_cal = min(100, S_compromise[0..45] + S_exposure_cal[0..25] + S_asset[0..15] + S_reachability[0..15]); Linear Capped Index R_lin = min(100, S_compromise[0..45] + S_exposure[0..25] + S_asset[0..15] + S_reachability[0..15]) → T0 Baseline Measured Risk R_cal(T0) = 96.8/100 (CRITICAL) [S_comp=45.0 + S_exp_cal=23.3 (RawSum=93.3) + S_asset=15.0 + S_reach=13.5] (Linear R_lin(T0) = 98.5/100) --> T1 Post-Retest Verified Risk R_cal(T1) = 75.6/100 (HIGH) [S_comp=29.0 (-16.0) + S_exp_cal=23.1 (RawSum=89.9, -0.2) + S_asset=15.0 + S_reach=8.5 (-5.0)] (Linear R_lin(T1) = 77.5/100; Verified Risk Reduction = -21.2 pts / -21.9%).**. Crucially, V3.5 preserves the **T0 Baseline Risk Score (`96.8/100` Calibrated | `98.5/100` Linear)** for audit history while recalculating the **T1 Post-Retest Verified Residual Risk (`75.6/100` Calibrated | `77.5/100` Linear, `-21.2` pts / `-21.9%`)** after verifying closure of `F-01, F-71`.

Risk Index Component	Cap	T0 Baseline Score	T1 Post-Retest Verified	Explicit Calculation Formula, Non-Saturating Calibration & Retest Impact
S_compromise (Verified Compromise & Auth)	45.0 pts	45.0 / 45.0	29.0 / 45.0 (-16.0 pts)	Calibrated so every single remediation produces an immediate, non-masked drop: 16.0 pts per verified root OS shell (2 vectors at T0: F-01, F-02) + 13.0 pts across 4 confirmed auth sessions = 45.0/45.0 at T0 -> drops to 29.0/45.0 at T1 after F-01 (:1524) is REMEDIATION_VERIFIED.
S_exposure (Validated & Observed CVSS)	25.0 pts	Cal: 23.3/25.0 (Lin: 25.0)	Cal: 23.1/25.0 (Lin: 25.0)	T0 RawSum = 93.3 pts -> T1 RawSum = 89.9 pts (excludes REMEDIATION_VERIFIED F-01 & F-71; retains F-59 offline, F-77 partial, and F-20 failed retests). S_exp_cal = round(25 * (1 - exp(-RawSum / 35.0)), 1).
S_asset (Target Asset Criticality)	15.0 pts	15.0 / 15.0	15.0 / 15.0	Crown-Jewel Multi-Role Application & Database Server (192.168.195.139, criticality_weight=1.50) remains at 15.0 pts at T1 because F-02 (vsFTPd :21/:6200) is still active until the P0 maintenance window.
S_reachability (Multi-Stage Attack Chains)	15.0 pts	13.5 / 15.0	8.5 / 15.0 (-5.0 pts)	T0: 13.5 / 15.0 across CHAIN-01..CHAIN-06. T1: Verified closure of F-01 (:1524 Ingreslock) severs CHAIN-02, reducing S_reachability from 13.5 -> 8.5 (-5.0 pts).
Composite Risk Index (0–100)	100.0 pts	Calibrated: 96.8/100 (CRITICAL) | Linear: 98.5/100	Calibrated: 75.6/100 (HIGH) | Linear: 77.5/100	Net Verified Risk Reduction: -21.2 pts (-21.9%) from verified remediation of F-01 & F-71.

2. Assessment Scope, Asset Reconciliation & Autonomous Transition Model

The discovery phase recorded **9** raw host entries in `hosts_discovered` (which included duplicate ARP/port-scan entries for `192.168.195.139` and `192.168.195.140`). Engine 08 reconciled these into **7 unique IPv4 addresses**: **5 responsive hosts** exposing **55** open TCP services, and **2 unresponsive/filtered hosts** (`192.168.195.131` and `192.168.195.254`) with 0 open TCP ports. Crucially, asset classification is computed **per host** from each host's own open ports and service banners—accompanied by **Classification Source** and **Classification Confidence**.

Host IP	Scope State	Open Ports	Per-Host Asset Role & Tier	Classification Source & Conf	OS Fingerprint	Sec Findings	Verified Comp/Auth
192.168.195.139	RESPONSIVE ASSESSED	24 (21, 22, 23, 25, 53, 80, 111, 139 (+16 more))	Multi-Role Application & Database Server (CROWN_JEWEL)	OBSERVED_SERVICE_BANNERS_AND_AUTH_SHELL (MySQL/PostgreSQL/Apache/SSH) (99%)	Linux 2.6.24-16-server (Ubuntu8.04 Metasploitable — Confirmed via uname -a)	41	2 Root / 4 Auth
192.168.195.140	RESPONSIVE ASSESSED	9 (22, 80, 139, 143, 443, 445, 5001, 8080 (+1 more))	Application & Web Middleware Server (HIGH_VALUE)	OBSERVED_HTTP_MIDDLEWARE_PORTS (TCP/80, TCP/8080, TCP/8081) (90%)	Linux / Middleware Guest (Inferred via HTTP/8080-8081 & SMB)	28	0 Root / 0 Auth
192.168.195.129	RESPONSIVE ASSESSED	2 (5040, 5357)	Application / Network Host (STANDARD)	INFERRED_FROM_OPEN_PORT_PROFILE (75%)	Windows / VMware Host (Inferred via MSRPC/SMB Ports)	3	0 Root / 0 Auth
192.168.195.130	RESPONSIVE ASSESSED	4 (135, 139, 445, 5985)	Workstation / SMB Peer Host (STANDARD)	INFERRED_FROM_SMB_RPC_PORTS (TCP/135, TCP/139, TCP/445) (82%)	Windows / VMware Host (Inferred via MSRPC/SMB Ports)	5	0 Root / 0 Auth
192.168.195.131	UNRESPONSIVE NO OPEN PORTS	0 (Filtered)	Unresponsive / Filtered Endpoint (LOW_EXPOSURE)	ARP_OR_DHCP_DISCOVERY_ONLY (0 Open TCP Ports) (50%)	VMware Virtual Node (Unresponsive / 0 Open TCP Ports)	0	0 Root / 0 Auth
192.168.195.254	UNRESPONSIVE NO OPEN PORTS	0 (Filtered)	Unresponsive / Filtered Endpoint (LOW_EXPOSURE)	ARP_OR_DHCP_DISCOVERY_ONLY (0 Open TCP Ports) (50%)	VMware Virtual Node (Unresponsive / 0 Open TCP Ports)	0	0 Root / 0 Auth

Host IP	Scope State	Open Ports	Per-Host Asset Role & Tier	Classification Source & Conf	OS Fingerprint	Sec Findings	Verified Comp/Auth
192.168.195.1	RESPONSIVE ASSESSED	16 (135, 139, 445, 902, 912, 5040, 5174, 5357 (+8 more))	Hypervisor / Management Host Gateway (INFRASTRUCTURE)	INFERRED_FROM_VMWARE_AUTH_PORTS (TCP/902, TCP/912, TCP/445) (88%)	Windows Host / VMware Virtual Network Gateway (Inferred via VMware Auth :902/:912)	21	0 Root / 0 Auth

2.2 Autonomous Assessment Transition Model (Dynamically Reconciled with Section 3A & Section 5)

To resolve methodology ambiguity between 'Black-Box Unauthenticated' discovery and 'Authenticated / Post-Exploitation' findings—and to guarantee 100% cross-section Finding ID consistency (`AC-17`)—the table below is dynamically generated from the sorted finding registry:

Assessment Phase	Transition Name	Trigger Rule & Scope	Resulting Proof State	Reconciled Finding IDs & Summary
Phase 1	Discovery -> Service Enumeration	Active TCP/UDP port response & banner grab across 192.168.195.0/24	DISCOVERED (26)	R-01..R-26 (26 reconnaissance & telemetry items across 5 responsive hosts)
Phase 2	Service Enumeration -> Vulnerability Validation	Deterministic protocol handshake, HTTP/TLS/SMB/NFS configuration inspection, or unverified candidate check	VALIDATED / OBSERVED (91)	71 VALIDATED weaknesses + 20 OBSERVED candidates (incl. 4 unverified SMB EternalBlue checks)
Phase 3A	Vulnerability Validation -> Controlled Authentication	Non-destructive credential & anonymous login verification with privilege boundary recording	CONFIRMED_AUTH (4)	F-03 (PostgreSQL :5432 Superuser), F-04 (FTP :21 msfadmin), F-05 (SSH :22 msfadmin uid=1000), F-20 (FTP :21 Anonymous)
Phase 3B	Controlled Exploitation -> Direct Root Compromise	Authorized safe shell verification (id, whoami, uname -a, head -n 5 /etc/shadow) confirming uid=0(root)	CONFIRMED_COMPROMISE (2)	F-01 (Ingreslock :1524 Root Shell), F-02 (vsFTPd 2.3.4 Backdoor :21/:6200) — 2 Root Compromise Vectors on 1 Unique Host (192.168.195.139)
Phase 4	Post-Exploitation -> Local Privilege Escalation & Lateral Pivot Enumeration	Authenticated/shell enumeration of kernel version, SUID binaries, NFS exports, and DB catalogs using 3-State Privesc Lifecycle	PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED / VALIDATED (3)	F-06 (SUID /usr/bin/nmap --interactive (TECHNIQUE_VALIDATED)), F-10 (Dirty COW CVE-2016-5195 (PRECONDITION_DISCOVERED)), F-21 (SUID /bin/mount & /bin/umount (PRECONDITION_DISCOVERED))

2.3 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

Policy Engine **XSTRIKE-V3-ROE-GUARD-01** enforced strict scope and safety guardrails across `192.168.195.0/24`:

Control ID	Safety / Authorization Control	Runtime Enforcement Status
ROE-01	Signed Scope & CIDR Whitelist Enforcement	ACTIVE — Hard blocks any packet or payload targeting IPs outside 192.168.195.0/24 or local sensor interfaces
ROE-02	Exploit Allowlist & DoS Prohibition Gate	ACTIVE — Blocks kernel panic/crash payloads (Dirty COW memory overwrite, Slowloris DoS & MS17-010 EternalBlue ring-0 shellcode held in safe validation/observation mode)
ROE-03	Credential Handling & Redaction Policy	ACTIVE — Captures only bounded proof excerpts (head -n 5 /etc/shadow) with SHA-256/HMAC binding; prohibits bulk credential exfiltration
ROE-04	Post-Exploitation Command Whitelist	ACTIVE — Restricts shell verification to read-only identity & posture probes (id, whoami, uname -a, find -perm -4000, exportfs)
ROE-05	Emergency Stop & Per-Action Audit Trail	ACTIVE — Every probe and command is logged with UTC microsecond timestamps, provenance IDs, and deterministic kill-switch hooks

3A. Consolidated Security Vulnerabilities (F-01 through F-98)

This section presents all **98 consolidated per-host security vulnerabilities** (deduplicated from 1851 target observations). Every finding includes its **7-State Proof Classification**, **5-Dimensional Confidence Vector**, **Granular Access Scope**, **Per-Host Asset Class**, **Word-Boundary Verified CWE/MITRE Mapping**, **Cryptographic SHA-256 Provenance ID**, and **Vulnerability-Specific Remediation**.

ID	Host : Port	Severity & CVSS	Proof State	Title	CWE / MITRE	Merged / Endpoints	Composite Conf (FP)
F-01	192.168.195.139:1524	Critical (9.8)	CONFIRMED_COMPROMISE	Ingreslock / Bindshell Unauthenticated Root Shell on TCP Port 1524	CWE-306 / T1059.004	2 obs / 1 ep	99% (Tier)
F-02	192.168.195.139:21	Critical (9.8)	CONFIRMED_COMPROMISE	vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root Compromise (CVE-2011-2523)	CWE-506 / T1210	3 obs / 2 ep	99% (Tier)
F-03	192.168.195.139:5432	Critical (9.1)	CONFIRMED_AUTH	PostgreSQL 8.3.1 Default Superuser Authentication (postgres:postgres)	CWE-798 / T1078.001	2 obs / 1 ep	99% (Tier)
F-04	192.168.195.139:21	High (8.2)	CONFIRMED_AUTH	FTP Default Credential Authentication (msfadmin:msfadmin)	CWE-798 / T1078.001	1 obs / 1 ep	99% (Tier)
F-05	192.168.195.139:22	High (8.2)	CONFIRMED_AUTH	SSH Default Credential Shell Access (msfadmin:msfadmin)	CWE-798 / T1078.001	1 obs / 1 ep	99% (Tier)
F-06	192.168.195.139:22	High (7.8)	PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED	Local Privilege Escalation Vector: SUID Binary (/usr/bin/nmap)	CWE-269 / T1548.001	2 obs / 2 ep	96% (Tier)
F-07	192.168.195.139:80	High (8.2)	VALIDATED	DVWA Web Application Default Administrative Credentials Accepted (admin:password)	CWE-798 / T1078.001	1 obs / 1 ep	95% (Tier)
F-08	192.168.195.139:80	High (8.2)	VALIDATED	Web Application SQL Injection Indicator (Mutillidae)	CWE-89 / T1190	1 obs / 1 ep	95% (Tier)
F-09	192.168.195.140:80	High (8.2)	VALIDATED	DVWA Web Application Default Administrative Credentials Accepted (admin:password)	CWE-798 / T1078.001	1 obs / 1 ep	95% (Tier)
F-10	192.168.195.139:22	High (7.8)	VALIDATED	Legacy Linux Kernel 2.6.24-16-server Vulnerable to DirtyCow (CVE-2016-5195)	CWE-362 / T1068	2 obs / 2 ep	95% (Tier)
F-11	192.168.195.139:80	High (7.5)	VALIDATED	Web Application Server-Side Request Forgery (SSRF) Indicator (Mutillidae)	CWE-918 / T1190	1 obs / 1 ep	95% (Tier)
F-12	192.168.195.140:80	High (7.5)	VALIDATED	Apache HTTP Server Byte-Range Filter Denial-of-Service (CVE-2011-3192)	CWE-400 / T1498	1 obs / 1 ep	95% (Tier)

ID	Host : Port	Severity & CVSS	Proof State	Title	CWE / MITRE	Merged / Endpoints	Composite Conf (FP)
F-13	192.168.195.139:445	High (7.4)	VALIDATED	SMB Message Signing Not Required (NTLM Relay Exposure)	CWE-345 / T1557.001	1 obs / 1 ep	95% (Tier)
F-14	192.168.195.140:443	High (7.4)	VALIDATED	OpenSSL ChangeCipherSpec (CCS) Injection Vulnerability (CVE-2014-0224)	CWE-310 / T1557	1 obs / 1 ep	95% (Tier)
F-15	192.168.195.139:23	High (7.5)	OBSERVED	Cleartext Telnet Service Enabled on TCP Port 23	CWE-319 / T1021	1 obs / 1 ep	48% (Tier)
F-16	192.168.195.139:80	High (7.5)	OBSERVED	End-of-Life Apache HTTP Server 2.2.8 Deployed (TCP Port 80)	CWE-1104 / T1190	2 obs / 1 ep	48% (Tier)
F-17	192.168.195.140:80	High (7.5)	OBSERVED	End-of-Life Apache HTTP Server 2.2.14 Deployed (TCP Port 80)	CWE-1104 / T1190	2 obs / 1 ep	48% (Tier)
F-18	192.168.195.139:80	High (7.4)	OBSERVED	PHP 5.2.4-2ubuntu5.10 CGI Banner Heuristic — Unverified CVE-2012-1823 Candidate	CWE-88 / T1190	2 obs / 2 ep	48% (Tier)
F-19	192.168.195.140:80	High (7.4)	OBSERVED	PHP 5.3.2-1ubuntu4.30 CGI Banner Heuristic — Unverified CVE-2012-1823 Candidate	CWE-88 / T1190	1 obs / 1 ep	48% (Tier)
F-20	192.168.195.139:21	Medium (5.3)	CONFIRMED_AUTH	FTP Anonymous Authentication Enabled	CWE-287 / T1078.001	2 obs / 2 ep	99% (Tier)
F-21	192.168.195.139:22	Medium (5.5)	VALIDATED	Local Privilege Escalation Vector: SUID Binary (/bin/mount)	CWE-269 / T1548.001	2 obs / 2 ep	95% (Tier)
F-22	192.168.195.1:80	Medium (5.4)	VALIDATED	Client-Manipulable Session/Tracking Cookie Parameters Set Without Integrity Binding	CWE-565 / T1190	4 obs / 1 ep	95% (Tier)
F-23	192.168.195.1:8000	Medium (5.4)	VALIDATED	Content-Security-Policy (CSP) Header Not Set	CWE-693 / T1190	116 obs / 3 ep	95% (Tier)
F-24	192.168.195.1:80	Medium (5.4)	VALIDATED	Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors)	CWE-1021 / T1190	11 obs / 2 ep	95% (Tier)
F-25	192.168.195.1:8000	Medium (5.4)	VALIDATED	Session Cookie Missing 'Secure' Flag	CWE-614 / T1557	1 obs / 1 ep	95% (Tier)
F-26	192.168.195.1:80	Medium (5.4)	VALIDATED	Verbose Application / Database Error Message Disclosure	CWE-209 / T1190	15 obs / 1 ep	95% (Tier)
F-27	192.168.195.1:5357	Medium (5.4)	VALIDATED	Web Application Missing Anti-CSRF Tokens & Hardening Headers	CWE-352 / T1190	5 obs / 5 ep	95% (Tier)
F-28	192.168.195.129:80	Medium (5.4)	VALIDATED	Content-Security-Policy (CSP) Header Not Set	CWE-693 / T1190	3 obs / 1 ep	95% (Tier)

ID	Host : Port	Severity & CVSS	Proof State	Title	CWE / MITRE	Merged / Endpoints	Composite Conf (FP)
F-29	192.168.195.129:5357	Medium (5.4)	VALIDATED	Web Application Missing Anti-CSRF Tokens & Hardening Headers	CWE-352 / T1190	1 obs / 1 ep	95% (Tier)
F-30	192.168.195.130:80	Medium (5.4)	VALIDATED	Content-Security-Policy (CSP) Header Not Set	CWE-693 / T1190	3 obs / 1 ep	95% (Tier)
F-31	192.168.195.130:5985	Medium (5.4)	VALIDATED	Web Application Missing Anti-CSRF Tokens & Hardening Headers	CWE-352 / T1190	1 obs / 1 ep	95% (Tier)
F-32	192.168.195.139:80	Medium (5.4)	VALIDATED	Content-Security-Policy (CSP) Header Not Set	CWE-693 / T1190	3 obs / 3 ep	95% (Tier)
F-33	192.168.195.139:53	Medium (5.4)	VALIDATED	DNS Open Recursion Enabled on ISC BIND 9.4.2 (Port 53)	CWE-406 / T1498.002	1 obs / 1 ep	95% (Tier)
F-34	192.168.195.139:80	Medium (5.4)	VALIDATED	Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors)	CWE-1021 / T1190	3 obs / 3 ep	95% (Tier)
F-35	192.168.195.139:80	Medium (5.4)	VALIDATED	Web Application Missing Anti-CSRF Tokens & Hardening Headers	CWE-352 / T1190	1 obs / 1 ep	95% (Tier)
F-36	192.168.195.140:80	Medium (5.4)	VALIDATED	Content-Security-Policy (CSP) Header Not Set	CWE-693 / T1190	25 obs / 5 ep	95% (Tier)
F-37	192.168.195.140:80	Medium (5.4)	VALIDATED	Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors)	CWE-1021 / T1190	11 obs / 5 ep	95% (Tier)
F-38	192.168.195.140:80	Medium (5.4)	VALIDATED	Web Application Missing Anti-CSRF Tokens & Hardening Headers	CWE-352 / T1190	3 obs / 3 ep	95% (Tier)
F-39	192.168.195.1:80	Medium (5.3)	VALIDATED	Administrative Web Interface Reachable Without Network Restriction	CWE-284 / T1083	1 obs / 1 ep	90% (Tier)
F-40	192.168.195.139:80	Medium (5.3)	VALIDATED	Administrative Web Interface Reachable Without Network Restriction	CWE-284 / T1083	1 obs / 1 ep	95% (Tier)
F-41	192.168.195.139:445	Medium (5.3)	VALIDATED	Deprecated SMBv1 Dialect Enabled on SMB Service (Protocol Hardening Weakness)	CWE-327 / T1210	1 obs / 1 ep	95% (Tier)
F-42	192.168.195.139:80	Medium (5.3)	VALIDATED	Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/)	CWE-306 / T1190	1 obs / 1 ep	95% (Tier)
F-43	192.168.195.139:2049	Medium (5.3)	VALIDATED	NFS RPC Service & Export Table Exposed (Ports 111 / 2049)	CWE-732 / T1083	3 obs / 3 ep	95% (Tier)
F-44	192.168.195.139:80	Medium (5.3)	VALIDATED	PHP Configuration Diagnostic Page Exposed (/phpinfo.php)	CWE-200 / T1592	4 obs / 4 ep	95% (Tier)

ID	Host : Port	Severity & CVSS	Proof State	Title	CWE / MITRE	Merged / Endpoints	Composite Conf (FP)
F-45	192.168.195.139:80	Medium (5.3)	VALIDATED	Web Authentication Endpoint Missing Brute-Force Rate Limiting (/dvwa/login.php)	CWE-307 / T1110.001	1 obs / 1 ep	95% (Tier)
F-46	192.168.195.140:80	Medium (5.3)	VALIDATED	Administrative Web Interface Reachable Without Network Restriction	CWE-284 / T1083	2 obs / 1 ep	90% (Tier)
F-47	192.168.195.140:445	Medium (5.3)	VALIDATED	Deprecated SMBv1 Dialect Enabled on SMB Service (Protocol Hardening Weakness)	CWE-327 / T1210	1 obs / 1 ep	95% (Tier)
F-48	192.168.195.140:80	Medium (5.3)	VALIDATED	Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/)	CWE-306 / T1190	1 obs / 1 ep	95% (Tier)
F-49	192.168.195.140:80	Medium (5.3)	VALIDATED	Permissive Cross-Domain Policy File Exposed (/crossdomain.xml / /clientaccesspolicy.xml)	CWE-942 / T1190	1 obs / 1 ep	95% (Tier)
F-50	192.168.195.140:443	Medium (5.3)	VALIDATED	SSLv3 Protocol Enabled — POODLE Padding Oracle Vulnerability (CVE-2014-3566)	CWE-310 / T1557	1 obs / 1 ep	95% (Tier)
F-51	192.168.195.140:443	Medium (5.3)	VALIDATED	TLS Ephemeral Diffie-Hellman Weak Key Exchange Parameters (Logjam)	CWE-326 / T1557	1 obs / 1 ep	95% (Tier)
F-52	192.168.195.140:80	Medium (5.9)	OBSERVED	HTTP Server Slowloris Timeout Heuristic Observed (CVE-2007-6750 Candidate)	CWE-400 / T1498	2 obs / 2 ep	48% (Tier)
F-53	192.168.195.1:5432	Medium (5.3)	OBSERVED	PostgreSQL Database Listener Exposed on Network (TCP Port 5432)	CWE-200 / T1046	1 obs / 1 ep	48% (Tier)
F-54	192.168.195.139:22	Medium (5.3)	OBSERVED	End-of-Life OpenSSH 4.7p1 (Debian-8ubuntu1) Service Banner Observed (TCP Port 22)	CWE-1104 / T1021.004	1 obs / 1 ep	48% (Tier)
F-55	192.168.195.139:1099	Medium (5.3)	OBSERVED	Java RMI Registry Exposed on Network (TCP Port 1099)	CWE-502 / T1210	1 obs / 1 ep	48% (Tier)
F-56	192.168.195.139:3306	Medium (5.3)	OBSERVED	MySQL Database Listener Exposed on Network (TCP Port 3306)	CWE-200 / T1046	1 obs / 1 ep	48% (Tier)
F-57	192.168.195.139:5900	Medium (5.3)	OBSERVED	VNC Remote Desktop Service Exposed on TCP Port 5900 (Protocol 3.3)	CWE-287 / T1021.001	1 obs / 1 ep	48% (Tier)
F-58	192.168.195.139:6000	Medium (5.3)	OBSERVED	X11 Display Server Listener Exposed (TCP Port 6000)	CWE-306 / T1113	1 obs / 1 ep	48% (Tier)
F-59	192.168.195.140:22	Medium (5.3)	OBSERVED	End-of-Life OpenSSH 5.3p1 (Debian-3ubuntu4) Service Banner Observed (TCP Port 22)	CWE-1104 / T1021.004	1 obs / 1 ep	48% (Tier)

ID	Host : Port	Severity & CVSS	Proof State	Title	CWE / MITRE	Merged / Endpoints	Composite Conf (FP)
F-60	192.168.195.1:80	Low (3.1)	VALIDATED	Developer / Debugging Comments Exposed in HTML/JS Source	CWE-615 / T1592	10 obs / 1 ep	90% (Tier)
F-61	192.168.195.1:8000	Low (3.1)	VALIDATED	HTTP Permissions-Policy Header Missing	CWE-693 / T1190	1 obs / 1 ep	95% (Tier)
F-62	192.168.195.1:8000	Low (3.1)	VALIDATED	HTTP Referrer-Policy Header Missing	CWE-200 / T1592	1 obs / 1 ep	95% (Tier)
F-63	192.168.195.1:8000	Low (3.1)	VALIDATED	HTTP Server Banner Version Disclosure ('Server' Header)	CWE-200 / T1592	55 obs / 2 ep	95% (Tier)
F-64	192.168.195.1:8000	Low (3.1)	VALIDATED	HTTP Strict-Transport-Security (HSTS) Header Missing	CWE-319 / T1557	4 obs / 3 ep	95% (Tier)
F-65	192.168.195.1:8000	Low (3.1)	VALIDATED	Session Cookie Missing 'HttpOnly' Flag	CWE-1004 / T1190	80 obs / 2 ep	95% (Tier)
F-66	192.168.195.1:8000	Low (3.1)	VALIDATED	Session Cookie Missing 'SameSite' Attribute	CWE-352 / T1190	220 obs / 2 ep	95% (Tier)
F-67	192.168.195.1:80	Low (3.1)	VALIDATED	Unix Timestamp Disclosure in HTTP Response Content	CWE-200 / T1592	288 obs / 1 ep	95% (Tier)
F-68	192.168.195.1:80	Low (3.1)	VALIDATED	Verbose Content Body Returned in HTTP Redirect Response (Big Redirect)	CWE-200 / T1592	74 obs / 1 ep	95% (Tier)
F-69	192.168.195.1:80	Low (3.1)	VALIDATED	Web Server Directory Listing Enabled (/icons/ & Static Directories)	CWE-548 / T1083	3 obs / 2 ep	95% (Tier)
F-70	192.168.195.1:80	Low (3.1)	VALIDATED	X-Content-Type-Options Header Missing (MIME-Sniffing Exposure)	CWE-693 / T1190	45 obs / 2 ep	95% (Tier)
F-71	192.168.195.1:8000	Low (3.1)	VALIDATED	robots.txt Disallows Sensitive Web Paths	CWE-200 / T1592	1 obs / 1 ep	95% (Tier)
F-72	192.168.195.129:80	Low (3.1)	VALIDATED	HTTP Server Banner Version Disclosure ('Server' Header)	CWE-200 / T1592	3 obs / 1 ep	95% (Tier)
F-73	192.168.195.130:80	Low (3.1)	VALIDATED	HTTP Server Banner Version Disclosure ('Server' Header)	CWE-200 / T1592	3 obs / 1 ep	95% (Tier)
F-74	192.168.195.139:80	Low (3.1)	VALIDATED	Apache HTTP OPTIONS Allow Header Heuristic (Optionsbleed CVE-2017-9798 Candidate)	CWE-200 / T1190	1 obs / 1 ep	95% (Tier)
F-75	192.168.195.139:80	Low (3.1)	VALIDATED	HTTP Permissions-Policy Header Missing	CWE-693 / T1190	1 obs / 1 ep	95% (Tier)
F-76	192.168.195.139:80	Low (3.1)	VALIDATED	HTTP Referrer-Policy Header Missing	CWE-200 / T1592	1 obs / 1 ep	95% (Tier)
F-77	192.168.195.139:80	Low (3.1)	VALIDATED	HTTP Server Banner Version Disclosure ('Server' Header)	CWE-200 / T1592	3 obs / 2 ep	95% (Tier)

ID	Host : Port	Severity & CVSS	Proof State	Title	CWE / MITRE	Merged / Endpoints	Composite Conf (FP)
F-78	192.168.195.139:80	Low (3.1)	VALIDATED	HTTP Strict-Transport-Security (HSTS) Header Missing	CWE-319 / T1557	3 obs / 3 ep	95% (Tier)
F-79	192.168.195.139:80	Low (3.1)	VALIDATED	HTTP Technology Stack Disclosure ('X-Powered-By' Header)	CWE-200 / T1592	2 obs / 2 ep	95% (Tier)
F-80	192.168.195.139:80	Low (3.1)	VALIDATED	Web Server Directory Listing Enabled (/icons/ & Static Directories)	CWE-548 / T1083	1 obs / 1 ep	95% (Tier)
F-81	192.168.195.139:80	Low (3.1)	VALIDATED	X-Content-Type-Options Header Missing (MIME-Sniffing Exposure)	CWE-693 / T1190	3 obs / 3 ep	95% (Tier)
F-82	192.168.195.140:80	Low (3.1)	VALIDATED	Apache HTTP OPTIONS Allow Header Heuristic (Optionsbleed CVE-2017-9798 Candidate)	CWE-200 / T1190	1 obs / 1 ep	95% (Tier)
F-83	192.168.195.140:80	Low (3.1)	VALIDATED	Developer / Debugging Comments Exposed in HTML/JS Source	CWE-615 / T1592	1 obs / 1 ep	90% (Tier)
F-84	192.168.195.140:80	Low (3.1)	VALIDATED	HTTP Permissions-Policy Header Missing	CWE-693 / T1190	2 obs / 2 ep	95% (Tier)
F-85	192.168.195.140:80	Low (3.1)	VALIDATED	HTTP Referrer-Policy Header Missing	CWE-200 / T1592	2 obs / 2 ep	95% (Tier)
F-86	192.168.195.140:80	Low (3.1)	VALIDATED	HTTP Server Banner Version Disclosure ('Server' Header)	CWE-200 / T1592	35 obs / 3 ep	95% (Tier)
F-87	192.168.195.140:80	Low (3.1)	VALIDATED	HTTP Strict-Transport-Security (HSTS) Header Missing	CWE-319 / T1557	7 obs / 5 ep	95% (Tier)
F-88	192.168.195.140:80	Low (3.1)	VALIDATED	Session Cookie Missing 'HttpOnly' Flag	CWE-1004 / T1190	10 obs / 1 ep	95% (Tier)
F-89	192.168.195.140:80	Low (3.1)	VALIDATED	Session Cookie Missing 'SameSite' Attribute	CWE-352 / T1190	10 obs / 1 ep	95% (Tier)
F-90	192.168.195.140:80	Low (3.1)	VALIDATED	Web Server Directory Listing Enabled (/icons/ & Static Directories)	CWE-548 / T1083	2 obs / 2 ep	95% (Tier)
F-91	192.168.195.140:80	Low (3.1)	VALIDATED	X-Content-Type-Options Header Missing (MIME-Sniffing Exposure)	CWE-693 / T1190	11 obs / 5 ep	95% (Tier)
F-92	192.168.195.130:445	Low (3.1)	OBSERVED	SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445)	CWE-287 / T1021.002	2 obs / 2 ep	48% (Tier)
F-93	192.168.195.139:445	Low (3.1)	OBSERVED	SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445)	CWE-287 / T1021.002	2 obs / 2 ep	48% (Tier)

ID	Host : Port	Severity & CVSS	Proof State	Title	CWE / MITRE	Merged / Endpoints	Composite Conf (FP)
F-94	192.168.195.140:445	Low (3.1)	OBSERVED	SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445)	CWE-287 / T1021.002	2 obs / 2 ep	48% (Tier)
F-95	192.168.195.1:445	Info (0.0 Act | 9.8 Cond)	OBSERVED	SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate	CWE-200 / T1210	1 obs / 1 ep	48% (Tier)
F-96	192.168.195.130:445	Info (0.0 Act | 9.8 Cond)	OBSERVED	SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate	CWE-200 / T1210	1 obs / 1 ep	48% (Tier)
F-97	192.168.195.139:445	Info (0.0 Act | 9.8 Cond)	OBSERVED	SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate	CWE-200 / T1210	1 obs / 1 ep	48% (Tier)
F-98	192.168.195.140:445	Info (0.0 Act | 9.8 Cond)	OBSERVED	SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate	CWE-200 / T1210	1 obs / 1 ep	48% (Tier)

3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

F-01: Ingreslock / Bindshell Unauthenticated Root Shell on TCP Port 1524 [CRITICAL · CVSS 9.8 · CONFIRMED_COMPROMISE]

Target Asset & Port:	192.168.195.139 (Ports: 1524) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: CONFIRMED_COMPROMISE -> T1 Post-Retest: REMEDIATION_VERIFIED (REMEDIATION_VERIFIED (CHG-2026-1031-001)) | Privilege: ROOT (uid=0 / gid=0 — Inherited Directly from Root-Owned Network Service) | Privesc Lifecycle: DIRECT_ROOT_SERVICE_EXECUTION (uid=0 Inherited from Daemon — T1068 Local PrivEsc Not Applicable)
Privilege Context (V3.5):	uid=0 | source=vulnerable_network_daemon | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: PROVEN_OS_COMPROMISE | Exploitability Claimed: True | Rationale: Promoted to CONFIRMED_COMPROMISE because full interactive root command execution was deterministically captured.
4-State MITRE Provenance:	MITRE: T1059.004 (Execution — Command and Scripting Interpreter: Unix Shell) | Execution State: EXECUTED_WITH_PROOF [TIER_1_LIVE_EXECUTION_TRANSCRIPT] — Technique T1059.004 (Command and Scripting Interpreter: Unix Shell) actively executed and semantically verified via session transcript (PROV-F-01-663E9B45B1) [DIRECT_ROOT_SERVICE_EXECUTION (Root context uid=0 inherited directly from vulnerable network daemon in RFC1918 range; local privilege escalation T1068 not applicable)].
7-D Proof Vector (V3.5):	Execution: ROOT_SHELL_EXECUTED | Auth: UNAUTHENTICATED_ROOT_BIND | Exploitability: EXPLOIT_CONFIRMED | Privilege: ROOT (uid=0 / gid=0 — Inherited Directly from Root-Owned Network Service) | DataAccess: SHADOW_HASHES_READ_REDACTED | Impact: FULL_SYSTEM_COMPROMISE | EvidenceConf: 99%
Access Scope Summary:	DIRECT_ROOT_SERVICE_EXECUTION: Unrestricted root command execution (uid=0 inherited directly from root-owned network daemon; no local T1068 uid transition required) and /etc/shadow READ_CONFIRMED (password hashes redacted; write not executed per RoE)
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-INGRESLOCK-1524 | Advisory: CERT/CC CA-1994-01 (inetd / ingreslock Backdoor Bindshell Exposure) | CWE: CWE-306 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-306 (Missing Authentication for Critical Function) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Separated Confidence (V3.5):	EvidenceConf=99% | ExploitabilityConf=99% | ImpactConf=99% | 5-D Vector: EvidenceConf=99% (Det=99%, Val=99%, Art=100%) | ExploitabilityConf=99% | ImpactConf=99% | FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:1524
Root Cause & 4-Tier Compliance:	Malicious Backdoor / Intentional Vulnerable Build [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	TCP port 1524 (ingreslock) exposes an unauthenticated interactive root shell (/bin/sh). Note: rsh/bindshell probes against port 1524 interact with this same underlying root bind shell and have been consolidated into this single compromise record.
Security Risk:	CRITICAL — Immediate unauthenticated root compromise (uid=0) with full filesystem control and /etc/shadow READ_CONFIRMED access (password hashes redacted; write not executed per RoE).
EvidenceCore V3.5 Record:	ID: PROV-F-01-663E9B45B1 | SHA-256: 663e9b45b10257b89f310cd5... | HMAC-SHA256: 0b0cf154b66472547eeeaa87... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-01):

```
INGRESLOCK BACKDOOR: Root shell on port 1524!
id: root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
$ whoami: root
root@metasploitable:/#
$ cat /etc/shadow | head -3: root:$1$/av...[REDACTED_SHADOW_HASH]:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
root@met
$ uname -a: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:/#
$ ifconfig 2>/dev/null: eth0 Link enca
---
rsh access: root@metasploitable:/#
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Immediately terminate the `/bin/sh` bind shell listening on TCP port 1524 (`fuser -k 1524/tcp`), comment out the `ingreslock` line in `/etc/inetd.conf` or `/etc/xinetd.d/`, and reload `inetd`.
Short-Term Hardening:	Block TCP port 1524 at the host firewall (`ufw deny 1524/tcp` / `iptables -A INPUT -p tcp --dport 1524 -j DROP`) and audit `/etc/inetd.conf` for unauthorized backdoor listeners (`rsh`, `rexec`, `rlogin`).
Long-Term Strategic Fix:	Decommission `inetd`/`xinetd` legacy super-server daemons entirely and implement automated host-based port baseline monitoring.
Approval & Change Window:	Emergency Change Advisory Board (ECAB) — Immediate Break-Glass Containment (0–24h SLA)
Backup & Rollback Plan:	Backup `/etc/inetd.conf` (`cp -p /etc/inetd.conf /etc/inetd.conf.bak`) on `192.168.195.139` before commenting out the `ingreslock` (1524/tcp) or `telnet` (23/tcp) service entry and sending `kill -HUP` to `inetd`.
Verification & Closure Rule:	Run `nmap -sV -p 1524 192.168.195.139` and confirm port 1524 returns `closed` or `filtered` with no shell prompt. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-01 on 192.168.195.139:1524 remains OPEN until an automated XStrike re-test executes `Run `nmap -sV -p 1524 192.168.195.139` and confirm port 1524 returns `closed` or `filtered` with no shell prompt.` against `192.168.195.139:1524`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-02: vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root Compromise (CVE-2011-2523) [CRITICAL · CVSS 9.8 · CONFIRMED_COMPROMISE]

Target Asset & Port:	192.168.195.139 (Ports: 21) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: CONFIRMED_COMPROMISE -> T1 Post-Retest: CONFIRMED_COMPROMISE (PENDING_SCHEDULED_WINDOW) | Privilege: ROOT (uid=0 / gid=0 — Inherited Directly from Root-Owned Network Service) | Privesc Lifecycle: DIRECT_ROOT_SERVICE_EXECUTION (uid=0 Inherited from Daemon — T1068 Local PrivEsc Not Applicable)
Privilege Context (V3.5):	uid=0 | source=vulnerable_network_daemon | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: PROVEN_OS_COMPROMISE | Exploitability Claimed: True | Rationale: Promoted to CONFIRMED_COMPROMISE because full interactive root command execution was deterministically captured.

4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: EXECUTED_WITH_PROOF [TIER_1_LIVE_EXECUTION_TRANSCRIPT] — Technique T1210 (Exploitation of Remote Services) actively executed and semantically verified via session transcript (PROV-F-02-C08E97D1E2) [DIRECT_ROOT_SERVICE_EXECUTION (Root context uid=0 inherited directly from vulnerable network daemon in RFC1918 range; local privilege escalation T1068 not applicable)].
7-D Proof Vector (V3.5):	Execution: ROOT_SHELL_EXECUTED | Auth: UNAUTHENTICATED_ROOT_BIND | Exploitability: EXPLOIT_CONFIRMED | Privilege: ROOT (uid=0 / gid=0 — Inherited Directly from Root-Owned Network Service) | DataAccess: SHADOW_HASHES_READ_REDACTED | Impact: FULL_SYSTEM_COMPROMISE | EvidenceConf: 99%
Access Scope Summary:	DIRECT_ROOT_SERVICE_EXECUTION: Unrestricted root command execution (uid=0 inherited directly from root-owned network daemon; no local T1068 uid transition required) and /etc/shadow READ_CONFIRMED (password hashes redacted; write not executed per RoE)
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: CVE-2011-2523 | Custom ID: XSTRIKE-VSFTPD-234-BACKDOOR | Advisory: OSVDB-73573 / vsFTPd v2.3.4 Compromised Archive Advisory | CWE: CWE-506 | Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) | CWE-506 (Embedded Malicious Code) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Separated Confidence (V3.5):	EvidenceConf=99% | ExploitabilityConf=99% | ImpactConf=99% | 5-D Vector: EvidenceConf=99% (Det=99%, Val=99%, Art=100%) | ExploitabilityConf=99% | ImpactConf=99% | FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, 192.168.195.139:21
Root Cause & 4-Tier Compliance:	Malicious Backdoor / Intentional Vulnerable Build [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The vsFTPd 2.3.4 daemon contains a maliciously planted backdoor (CVE-2011-2523) that opens an unauthenticated root bind shell on TCP port 6200 when a username ending in ':)' is supplied.
Security Risk:	CRITICAL — Complete host compromise. Unauthenticated remote attacker obtains uid=0(root) command execution and access to /etc/shadow password hashes.
EvidenceCore V3.5 Record:	ID: PROV-F-02-C08E97D1E2 | SHA-256: c08e97d1e2e2e1bd5705fb00... | HMAC-SHA256: 211f3609a80f4591305d8f14... | Module: AutoPentest-VulnScan, XStrike-BuiltinVuln, AutoPentest-Exploit

Captured Technical Evidence (F-02):

```
BACKDOOR SHELL on :6200!
$ id: uid=0(root) gid=0(root)
$ whoami: root
$ uname -a: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ cat /etc/shadow | head -5: root:$1$/av...[REDACTED_SHADOW_HASH]:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX...[REDACTED_SHADOW_HASH]
[!] ROOT PASSWORD HASH DUMPED!
$ cat /etc/passwd=[REDACTED]
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bi
---
[2026-10-31 08:03:49] FTP service on 192.168.195.139:21.
Service: ftp, Product: vsftpd, Version: 2.3.4
MATCH: vsftpd 2.3.4 — known backdoor (CVE-2011-2
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)

Immediate Containment:	Immediately stop the vsFTPd daemon (`systemctl stop vsftpd` or `killall vsftpd`), terminate any process bound to TCP port 6200, and isolate 192.168.195.139 from the network.
Short-Term Hardening:	Replace the compromised vsFTPd 2.3.4 binary with a cryptographically verified upstream package (`apt-get update && apt-get install --only-upgrade vsftpd`) or migrate file transfers to SFTP/SCP over hardened OpenSSH.
Long-Term Strategic Fix:	Rebuild the compromised host from a trusted gold image, rotate all local password hashes in `/etc/shadow`, and enforce package signature verification in CI/CD.
Approval & Change Window:	Emergency Change Advisory Board (ECAB) — Immediate Break-Glass Containment (0–24h SLA)
Backup & Rollback Plan:	Backup `/etc/vsftpd.conf` (`cp -p /etc/vsftpd.conf /etc/vsftpd.conf.bak`) on `192.168.195.139` before disabling anonymous/default access or stopping `vsftpd`; restore `/etc/vsftpd.conf.bak` if authorized file transfer workflows require rollback.
Verification & Closure Rule:	Verify TCP port 21 and port 6200 are closed or that `vsftpd -v` reports a patched release (>= 3.0.3) and `USER test:)` no longer opens port 6200. [Target Endpoint: `192.168.195.139:21`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-02 on 192.168.195.139:21 remains OPEN until an automated XStrike re-test executes `Verify TCP port 21 and port 6200 are closed or that `vsftpd -v` reports a patched release (>= 3.0.3) and `USER test:)` no longer opens port 6200. [Target Endpoint: `192.168.195.139:21`]` against `192.168.195.139:21`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-03: PostgreSQL 8.3.1 Default Superuser Authentication (postgres:postgres) [CRITICAL · CVSS 9.1 · CONFIRMED_AUTH]

Target Asset & Port:	192.168.195.139 (Ports: 5432) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: CONFIRMED_AUTH -> T1 Post-Retest: CONFIRMED_AUTH (PENDING_SCHEDULED_WINDOW) | Privilege: DB_SUPERUSER (postgres) | Privesc Lifecycle: TECHNIQUE_VALIDATED
Privilege Context (V3.5):	uid=None | source=authenticated_network_service | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: PROVEN_SESSION_AUTHENTICATION | Exploitability Claimed: True | Rationale: Promoted to CONFIRMED_AUTH because a live authenticated session handshake and read-only session command succeeded.
4-State MITRE Provenance:	MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) | Execution State: EXECUTED_WITH_PROOF [TIER_1_LIVE_EXECUTION_TRANSCRIPT] — Technique T1078.001 (Valid Accounts: Default Accounts) actively executed and semantically verified via session transcript (PROV-F-03-20FA15B6B1) [AUTHENTICATED_NETWORK_SERVICE_SESSION (Live authenticated handshake verified on 192.168.195.139:5432)].
7-D Proof Vector (V3.5):	Execution: AUTHENTICATED_DB_QUERY_EXECUTED | Auth: AUTHENTICATED_SUPERUSER (postgres) | Exploitability: CREDENTIAL_CONFIRMED | Privilege: DB_SUPERUSER (postgres) | DataAccess: DB_CATALOG_AUTHENTICATED | Impact: DATABASE_SUPERUSER_COMPROMISE | EvidenceConf: 98%
Access Scope Summary:	Authenticated PostgreSQL 8.3.1 superuser session ('postgres'); database & table catalog enumerated (read-only verification)
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-PGSQL-DEFAULT-SUPERUSER | Advisory: PostgreSQL pg_hba.conf & Default Superuser Password Advisory | CWE: CWE-798 | Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) | CWE-798 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Separated Confidence (V3.5):	EvidenceConf=99% | ExploitabilityConf=95% | ImpactConf=88% | 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) | ExploitabilityConf=95% | ImpactConf=88% | FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:5432
Root Cause & 4-Tier Compliance:	Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	PostgreSQL 8.3.1 on TCP port 5432 accepts default superuser credentials ('postgres:postgres'), allowing remote database enumeration and catalog read access.
Security Risk:	CRITICAL — Authenticated database superuser access; permits reading/modifying all databases and potential OS command execution via pg_catalog functions.
EvidenceCore V3.5 Record:	ID: PROV-F-03-20FA15B6B1 | SHA-256: 20fa15b6b19a92f9bdf91214... | HMAC-SHA256: d59de624de75fd7589623205... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-03):

```
PostgreSQL LOGIN: postgres:postgres
version: [('PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu
4.2.3-2ubuntu4)',)]
databases: [('template1',), ('template0',), ('postgres',)]
users: [('postgres', 'md53175bce1d3201d16594cebf9d7eb3f9d')]
tables: [('ymdoo',)]
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Change the PostgreSQL `postgres` superuser password (`ALTER USER postgres WITH PASSWORD '<strong_random_secret>';`) and restrict `/etc/postgresql/8.3/main/pg_hba.conf` to `md5` or `scram-sha-256` over local sockets only.
Short-Term Hardening:	Bind PostgreSQL exclusively to localhost in `postgresql.conf` (`listen_addresses = 'localhost'`) and block TCP port 5432 at the host firewall for untrusted subnets.
Long-Term Strategic Fix:	Upgrade EOL PostgreSQL 8.3.1 to a supported release (PostgreSQL 15/16) with role-based least-privilege database accounts.
Approval & Change Window:	Emergency Change Advisory Board (ECAB) — Immediate Break-Glass Containment (0–24h SLA)
Backup & Rollback Plan:	Backup `/etc/postgresql/8.3/main/pg_hba.conf` and `postgresql.conf` (`cp -p pg_hba.conf pg_hba.conf.bak`) on `192.168.195.139`; run `pg_ctl reload` to revert if local services lose DB connectivity.
Verification & Closure Rule:	Attempt remote authentication with `psql -h 192.168.195.139 -U postgres` and confirm connection refusal or `FATAL: password authentication failed`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-03 on 192.168.195.139:5432 remains OPEN until an automated XStrike re-test executes `Attempt remote authentication with `psql -h 192.168.195.139 -U postgres` and confirm connection refusal or `FATAL: password authentication failed`.` against `192.168.195.139:5432`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-04: FTP Default Credential Authentication (msfadmin:msfadmin) [HIGH · CVSS 8.2 · CONFIRMED_AUTH]

Target Asset & Port:	192.168.195.139 (Ports: 21) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: CONFIRMED_AUTH -> T1 Post-Retest: CONFIRMED_AUTH (PENDING_SCHEDULED_WINDOW) | Privilege: STANDARD_USER (msfadmin) | Privesc Lifecycle: PRECONDITION_DISCOVERED
Privilege Context (V3.5):	uid=None | source=authenticated_network_service | transition=NONE | privesc_tech=NOT_APPLICABLE

Exploitability Validation Gate:	Gate Status: PROVEN_SESSION_AUTHENTICATION | Exploitability Claimed: True | Rationale: Promoted to CONFIRMED_AUTH because a live authenticated session handshake and read-only session command succeeded.
4-State MITRE Provenance:	MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) | Execution State: EXECUTED_WITH_PROOF [TIER_1_LIVE_EXECUTION_TRANSCRIPT] — Technique T1078.001 (Valid Accounts: Default Accounts) actively executed and semantically verified via session transcript (PROV-F-04-D3A1A95053) [AUTHENTICATED_NETWORK_SERVICE_SESSION (Live authenticated handshake verified on 192.168.195.139:21)].
7-D Proof Vector (V3.5):	Execution: AUTHENTICATED_SESSION_VERIFIED | Auth: AUTHENTICATED_USER (msfadmin) | Exploitability: CREDENTIAL_CONFIRMED | Privilege: STANDARD_USER (msfadmin) | DataAccess: DIRECTORY_LISTING_READ | Impact: UNAUTHORIZED_ACCOUNT_ACCESS | EvidenceConf: 98%
Access Scope Summary:	Authenticated FTP session as standard user 'msfadmin'; directory listing verified (non-root)
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-FTP-DEFAULT-CREDS | Advisory: Rapid7 Metasploitable2 Baseline Default Account Advisory | CWE: CWE-798 | Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) | CWE-798 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=99% | ExploitabilityConf=95% | ImpactConf=88% | 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) | ExploitabilityConf=95% | ImpactConf=88% | FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:21
Root Cause & 4-Tier Compliance:	Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	The FTP service on port 21 authenticates the default account 'msfadmin:msfadmin', granting interactive access to the user's directory structure.
Security Risk:	HIGH — Unauthorized authenticated file access as standard user (msfadmin); enables credential reuse across SSH/Samba.
EvidenceCore V3.5 Record:	ID: PROV-F-04-D3A1A95053 | SHA-256: d3a1a9505310b52f89df4aa5... | HMAC-SHA256: 98c7d8e5f926509df0a43451... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-04):

```
FTP login msfadmin:msfadmin SUCCESS. Files: vulnerable
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Change the `msfadmin` account password immediately (`passwd msfadmin`) and revoke FTP access for administrative users via `/etc/ftpusers`.
Short-Term Hardening:	Disable cleartext FTP authentication altogether in `/etc/vsftpd.conf` (`local_enable=NO` or enforce TLS via `ssl_enable=YES`).
Long-Term Strategic Fix:	Enforce centralized identity management with minimum 14-character password complexity and multi-factor authentication.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/vsftpd.conf` (`cp -p /etc/vsftpd.conf /etc/vsftpd.conf.bak`) on `192.168.195.139` before disabling anonymous/default access or stopping `vsftpd`; restore `/etc/vsftpd.conf.bak` if authorized file transfer workflows require rollback.

Verification & Closure Rule:	Attempt FTP login with `msfadmin:msfadmin` and verify the server returns `530 Login incorrect`. [Target Endpoint: `192.168.195.139:21`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-04 on 192.168.195.139:21 remains OPEN until an automated XStrike re-test executes `Attempt FTP login with `msfadmin:msfadmin` and verify the server returns `530 Login incorrect`. [Target Endpoint: `192.168.195.139:21`]` against `192.168.195.139:21`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-05: SSH Default Credential Shell Access (msfadmin:msfadmin) [HIGH · CVSS 8.2 · CONFIRMED_AUTH]

Target Asset & Port:	192.168.195.139 (Ports: 22) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: CONFIRMED_AUTH -> T1 Post-Retest: CONFIRMED_AUTH (PENDING_SCHEDULED_WINDOW) | Privilege: STANDARD_USER (uid=1000 msfadmin, gid=1000) | Privesc Lifecycle: PRECONDITION_DISCOVERED
Privilege Context (V3.5):	uid=1000 | source=authenticated_network_service | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: PROVEN_SESSION_AUTHENTICATION | Exploitability Claimed: True | Rationale: Promoted to CONFIRMED_AUTH because a live authenticated session handshake and read-only session command succeeded.
4-State MITRE Provenance:	MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) | Execution State: EXECUTED_WITH_PROOF [TIER_1_LIVE_EXECUTION_TRANSCRIPT] — Technique T1078.001 (Valid Accounts: Default Accounts) actively executed and semantically verified via session transcript (PROV-F-05-821EA639BC) [AUTHENTICATED_NETWORK_SERVICE_SESSION (Live authenticated handshake verified on 192.168.195.139:22)].
7-D Proof Vector (V3.5):	Execution: USER_SHELL_EXECUTED | Auth: AUTHENTICATED_USER (uid=1000) | Exploitability: CREDENTIAL_CONFIRMED | Privilege: STANDARD_USER (uid=1000 msfadmin, gid=1000) | DataAccess: USER_FILESYSTEM_READ | Impact: INTERACTIVE_USER_SHELL_COMPROMISE | EvidenceConf: 98%
Access Scope Summary:	Interactive SSH shell established as unprivileged user uid=1000(msfadmin); root escalation not executed in this step
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-SSH-DEFAULT-CREDS | Advisory: OpenSSH Default/Predictable Account Hygiene Advisory | CWE: CWE-798 | Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) | CWE-798 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=99% | ExploitabilityConf=95% | ImpactConf=88% | 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) | ExploitabilityConf=95% | ImpactConf=88% | FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:22
Root Cause & 4-Tier Compliance:	Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	The OpenSSH service on port 22 accepts default credentials 'msfadmin:msfadmin', granting an interactive shell as standard user uid=1000(msfadmin). Separate local privilege escalation is required for root access.
Security Risk:	HIGH — Authenticated interactive Linux shell as standard user (uid=1000); provides direct launchpad for local privilege escalation.

EvidenceCore V3.5 Record:	ID: PROV-F-05-821EA639BC | SHA-256: 821ea639bcb82211f05e82b0... | HMAC-SHA256: 972eaae48c963fa6301ea124... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-05):

```
SSH LOGIN SUCCESS: msfadmin:msfadmin
Identity: uid=1000(msfadmin) gid=1000(msfadmin)
groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(di
Users: root, daemon, bin, sys, sync, games, man, lp, mail, news, uucp, proxy, www-data, backup, list
SUID binaries (privesc): /bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/tr
[!] CONFIG CREDS:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Rotate the `msfadmin` password immediately (`passwd msfadmin`) and terminate active unauthorized SSH sessions.
Short-Term Hardening:	Configure `/etc/ssh/sshd_config` with `PasswordAuthentication no`, `PermitRootLogin no`, and `MaxAuthTries 3`, then reload `sshd`.
Long-Term Strategic Fix:	Enforce Ed25519/RSA public-key authentication backed by hardware security keys or an SSH Certificate Authority.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/ssh/sshd_config` (`cp -p /etc/ssh/sshd_config /etc/ssh/sshd_config.bak`) on `192.168.195.139`, validate syntax via `sshd -t` before reloading `sshd`, and keep an active root/admin terminal open during reload to prevent lockout.
Verification & Closure Rule:	Verify `ssh msfadmin@192.168.195.139` rejects password authentication (`Permission denied (publickey)`). | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-05 on 192.168.195.139:22 remains OPEN until an automated XStrike re-test executes `Verify `ssh msfadmin@192.168.195.139` rejects password authentication (`Permission denied (publickey)`).` against `192.168.195.139:22`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-06: Local Privilege Escalation Vector: SUID Binary (/usr/bin/nmap) [HIGH · CVSS 7.8 · PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 22) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED [Root Transition Not Executed; Validated from uid=1000] -> T1 Post-Retest: PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: LOCAL_ESCALATION_PRECONDITION (uid=1000 -> uid=0 via nmap --interactive; root transition not executed) | Privesc Lifecycle: PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED
Privilege Context (V3.5):	uid=1000 | source=authenticated_ssh_session | transition=PRECONDITION_VALIDATED_NOT_EXECUTED (uid=1000 -> uid=0 via /usr/bin/nmap --interactive) | privesc_tech=T1548.001

Exploitability Validation Gate:	Gate Status: PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED | Exploitability Claimed: True | Rationale: Classified as PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED: both local shell access (uid=1000) and SUID-root `--interactive` precondition are proven, while the final root shell transition (!sh -> uid=0) was withheld per RoE.
4-State MITRE Provenance:	MITRE: T1548.001 (Privilege Escalation — Abuse Elevation Control Mechanism: Setuid and Setgid) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1548.001 (Abuse Elevation Control Mechanism: Setuid and Setgid) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-06-01126FC7B4) [PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED (SUID/Kernel escalation precondition proven from uid=1000 shell; final root transition withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: AUTHENTICATED_ENUMERATION_EXECUTED | Auth: AUTHENTICATED_USER (uid=1000) | Exploitability: PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED | Privilege: LOCAL_ESCALATION_PRECONDITION (uid=1000 -> uid=0 via nmap --interactive; root transition not executed) | DataAccess: FILESYSTEM_ACL_VERIFIED | Impact: LOCAL_ROOT_ESCALATION_READY | EvidenceConf: 95%
Access Scope Summary:	PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED: Authenticated SSH check confirmed SUID-root bit on /usr/bin/nmap (--interactive !sh precondition validated; final root transition not executed via SSH)
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-PRIVESC-SUID-NMAP | Advisory: GTFOBins SUID Nmap (--interactive !sh) Privilege Escalation Vector | CWE: CWE-269 | Taxonomy: MITRE ATT&CK T1548.001 | CWE-269 (Improper Privilege Management) | Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Separated Confidence (V3.5):	EvidenceConf=96% | ExploitabilityConf=82% | ImpactConf=80% | 5-D Vector: EvidenceConf=96% (Det=96%, Val=94%, Art=100%) | ExploitabilityConf=82% | ImpactConf=80% | FP Band: Tier 1 — Authenticated Exploit Precondition Verified (<5% Uncertainty)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:22, 192.168.195.139
Root Cause & 4-Tier Compliance:	Excessive Local Privilege / File Permission Misconfiguration [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening)
Technical Description:	Post-authentication enumeration over SSH identified /usr/bin/nmap with the setuid-root bit enabled. Legacy Nmap versions (2.02–5.21) support '--interactive' mode, allowing an authenticated local user (msfadmin, uid=1000) to spawn a root shell (!sh).
Security Risk:	HIGH (PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED, CVSS 7.8) — Validated local privilege escalation precondition from standard user (uid=1000) to root (uid=0); final root transition withheld per RoE.
EvidenceCore V3.5 Record:	ID: PROV-F-06-01126FC7B4 | SHA-256: 01126fc7b413341477deb0de... | HMAC-SHA256: cc24d1451b348fd210ba95b1... | Module: AutoPentest-Exploit, AutoPentest-PrivEsc

Captured Technical Evidence (F-06):

```
SUID nmap found — known privilege escalation vector!
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Remove the SUID-root bit from `/usr/bin/nmap` immediately (`chmod u-s /usr/bin/nmap`) and audit all SUID binaries via `find / -perm -4000 -type f 2>/dev/null`.
Short-Term Hardening:	Upgrade Nmap to a modern release (>= 7.9x) that removes `--interactive` shell escapes and enforce `nosuid` mount options on `/tmp` and `/home`.
Long-Term Strategic Fix:	Migrate the legacy Ubuntu 8.04 system to a supported LTS distribution with AppArmor/SELinux enforcement.

Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Record baseline file permissions via `stat -c '%a %n' /usr/bin/nmap /bin/mount > /root/suid_baseline.txt` on `192.168.195.139`; restore with `chmod 4755 <binary>` only if an approved operational dependency breaks.
Verification & Closure Rule:	Run `ls -la /usr/bin/nmap` and confirm permissions read `-rwxr-xr-x` without the `s` flag, and `nmap --interactive` is unavailable. [Target Endpoint: `192.168.195.139:22`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-06 on 192.168.195.139:22 remains OPEN until an automated XStrike re-test executes `Run `ls -la /usr/bin/nmap` and confirm permissions read `-rwxr-xr-x` without the `s` flag, and `nmap --interactive` is unavailable. [Target Endpoint: `192.168.195.139:22`]` against `192.168.195.139:22`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-07: DVWA Web Application Default Administrative Credentials Accepted (admin:password) [HIGH · CVSS 8.2 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1078.001 (Valid Accounts: Default Accounts) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-07-74C5E09C19) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-DVWA-DEFAULT-CREDS | Advisory: OWASP A07:2021 — Identification and Authentication Failures | CWE: CWE-798 | Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) | CWE-798 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139
Root Cause & 4-Tier Compliance:	Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)

Technical Description:	The Damn Vulnerable Web Application (DVWA) login endpoint (/dvwa/login.php) accepted default administrative credentials ('admin:password') during automated authentication verification (consolidated from OWASP A07 testing).
Security Risk:	HIGH — Validated administrative web session access enabling command injection, SQLi, and file upload testing modules.
EvidenceCore V3.5 Record:	ID: PROV-F-07-74C5E09C19 | SHA-256: 74c5e09c19d63fc80a79e18d... | HMAC-SHA256: 32959b032ee3c04333d52687... | Module: AutoPentest-OWASP

Captured Technical Evidence (F-07):

```
A07 Auth Failures: 2 finding(s)
[CWE-798] Default Creds: DVWA (admin:password): Login successful with admin:password!
[CWE-798] Default Creds: DVWA (admin:admin): Login successful with admin:admin!
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Disable or unpublish the `/dvwa/` training application from the web root (`mv /var/www/dvwa /root/dvwa.disabled`) or rotate the `admin` password in the DVWA MySQL `users` table.
Short-Term Hardening:	Restrict access to `/dvwa/` via Apache IP allowlisting (`Require ip 127.0.0.1`) if used in a controlled lab.
Long-Term Strategic Fix:	Prohibit deployment of intentionally vulnerable training applications (DVWA, Mutillidae) on shared infrastructure hosts.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404. [Target Endpoint: `192.168.195.139:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-07 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404. [Target Endpoint: `192.168.195.139:80`]` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-08: Web Application SQL Injection Indicator (Mutillidae) [HIGH · CVSS 8.2 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1190 (Exploit Public-Facing Application) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-08-45013F3A47) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: VALIDATED_INDICATOR_ONLY | Privilege: NONE | DataAccess: SQL_ERROR_OR_TABLE_INDICATOR | Impact: DATABASE_INJECTION_EXPOSURE | EvidenceConf: 92%

Access Scope Summary:	VALIDATED_INDICATOR_ONLY: Positive SQL injection response indicator on Mutillidae endpoint; controlled row extraction not executed
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-SQLI-MUTILLIDAE | Advisory: OWASP A03:2021 — Injection (SQL Injection) | CWE: CWE-89 | Taxonomy: OWASP-A03:2021 (Injection) | CWE-89 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:80
Root Cause & 4-Tier Compliance:	Insecure Application Coding (Input Validation) [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization)
Technical Description:	Automated SQL injection testing against the Mutillidae web application matched a database table/error indicator in the HTTP 200 response. Classified as VALIDATED (VALIDATED_INDICATOR_ONLY): SQL error/table indicator verified, while controlled row extraction or database modification was withheld.
Security Risk:	HIGH (VALIDATED_INDICATOR_ONLY, CVSS 8.2) — Unsanitized user input reaches backend SQL queries; could allow unauthorized database read/modification.
EvidenceCore V3.5 Record:	ID: PROV-F-08-45013F3A47 | SHA-256: 45013f3a47aa0f2fd66cea2e... | HMAC-SHA256: 40fc1328e6e4adabdc8abc86... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-08):

```
SQL Injection confirmed:
Mutillidae SQLi: table found
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Disable or restrict the vulnerable Mutillidae PHP endpoint via Apache rewrite/location rules and enable ModSecurity OWASP CRS SQLi rules.
Short-Term Hardening:	Refactor all database queries in the PHP application to use parameterized prepared statements (`PDO::prepare()` with bound parameters) instead of string concatenation.
Long-Term Strategic Fix:	Enforce static application security testing (SAST) in CI and restrict the web application's MySQL account to least-privilege `SELECT`/`INSERT` permissions.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Re-issue SQLi test payloads against the `192.168.195.139` parameter and verify HTTP responses contain zero database table leaks or SQL syntax error strings. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-08 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Re-issue SQLi test payloads against the `192.168.195.139` parameter and verify HTTP responses contain zero database table leaks or SQL syntax error strings.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-09: DVWA Web Application Default Administrative Credentials Accepted (admin:password) [HIGH · CVSS 8.2 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1078.001 (Valid Accounts: Default Accounts) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-09-C405135B73) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-DVWA-DEFAULT-CREDS | Advisory: OWASP A07:2021 — Identification and Authentication Failures | CWE: CWE-798 | Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) | CWE-798 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140
Root Cause & 4-Tier Compliance:	Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	The Damn Vulnerable Web Application (DVWA) login endpoint (/dvwa/login.php) accepted default administrative credentials ('admin:password') during automated authentication verification (consolidated from OWASP A07 testing).
Security Risk:	HIGH — Validated administrative web session access enabling command injection, SQLi, and file upload testing modules.
EvidenceCore V3.5 Record:	ID: PROV-F-09-C405135B73 | SHA-256: c405135b73b64dd81dfffd45... | HMAC-SHA256: 53784a99e515f4c71f4f653f... | Module: AutoPentest-OWASP

Captured Technical Evidence (F-09):

```
A07 Auth Failures: 1 finding(s)
[CWE-798] Default Creds: Mutillidae (admin:admin): Login successful with admin:admin!
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Disable or unpublish the `/dvwa/` training application from the web root (`mv /var/www/dvwa /root/dvwa.disabled`) or rotate the `admin` password in the DVWA MySQL `users` table.
Short-Term Hardening:	Restrict access to `/dvwa/` via Apache IP allowlisting (`Require ip 127.0.0.1`) if used in a controlled lab.

Long-Term Strategic Fix:	Prohibit deployment of intentionally vulnerable training applications (DVWA, Mutillidae) on shared infrastructure hosts.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404. [Target Endpoint: `192.168.195.140:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-09 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404. [Target Endpoint: `192.168.195.140:80`]` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-10: Legacy Linux Kernel 2.6.24-16-server Vulnerable to DirtyCow (CVE-2016-5195) [HIGH · CVSS 7.8 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 22) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) | Privesc Lifecycle: PRECONDITION_DISCOVERED
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1068 (Privilege Escalation — Exploitation for Privilege Escalation) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1068 (Exploitation for Privilege Escalation) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-10-2ADED6D87E) [PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED (SUID/Kernel escalation precondition proven from uid=1000 shell; final root transition withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: AUTHENTICATED_ENUMERATION_EXECUTED | Auth: AUTHENTICATED_USER (uid=1000) | Exploitability: VERSION_OR_ACL_VALIDATED | Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) | DataAccess: KERNEL_AND_SUID_METADATA | Impact: LOCAL_PRIVESC_SURFACE | EvidenceConf: 93%
Access Scope Summary:	Authenticated SSH uname -r verified Linux 2.6.24-16-server DirtyCow (CVE-2016-5195) precondition; kernel race payload withheld per RoE safety policy
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: CVE-2016-5195 | Custom ID: XSTRIKE-KERNEL-DIRTYCOW | Advisory: Ubuntu USN-3106-1 / Red Hat RHSA-2016:2098 (DirtyCow) | CWE: CWE-362 | Taxonomy: MITRE ATT&CK T1068 | CWE-362 (Concurrent Execution Race Condition) | Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:22, 192.168.195.139

Root Cause & 4-Tier Compliance:	Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Authenticated SSH fingerprinting ('uname -r') confirmed Linux kernel 2.6.24-16-server, which is affected by the CVE-2016-5195 (DirtyCow) copy-on-write race condition privilege escalation vulnerability.
Security Risk:	HIGH — Local users can exploit the kernel race condition to overwrite read-only root binaries and gain uid=0 privileges.
EvidenceCore V3.5 Record:	ID: PROV-F-10-2ADED6D87E | SHA-256: 2aded6d87e194d5077494984... | HMAC-SHA256: 1f44d79bc313e92c2617cae5... | Module: AutoPentest-Exploit, AutoPentest-PrivEsc

Captured Technical Evidence (F-10):

```
Kernel 2.6.24-16-server — vulnerable to DirtyCow (CVE-2016-5195), Multiple kernel exploits
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Restrict local shell access on 192.168.195.139 by disabling default SSH accounts (`msfadmin`) and setting `kernel.perf_event_paranoid = 3`.
Short-Term Hardening:	Upgrade the Linux kernel from `2.6.24-16-server` to a patched kernel incorporating the CVE-2016-5195 copy-on-write race fix (`mm/gup.c` FOLL_COW patch).
Long-Term Strategic Fix:	Reprovision the EOL Ubuntu 8.04 host onto Ubuntu 22.04/24.04 LTS with unattended kernel livepatching enabled.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Retain the previous working kernel entry (`2.6.24-16-server`) in `/boot/grub/menu.lst` on `192.168.195.139` and take a full VM snapshot prior to kernel package upgrade so the system can boot into the prior kernel if driver regressions occur.
Verification & Closure Rule:	Run `uname -r` over SSH and verify a supported kernel version patched against CVE-2016-5195. [Target Endpoint: `192.168.195.139:22`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-10 on 192.168.195.139:22 remains OPEN until an automated XStrike re-test executes `Run `uname -r` over SSH and verify a supported kernel version patched against CVE-2016-5195. [Target Endpoint: `192.168.195.139:22`]` against `192.168.195.139:22`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-11: Web Application Server-Side Request Forgery (SSRF) Indicator (Mutillidae) [HIGH · CVSS 7.5 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1190 (Exploit Public-Facing Application) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-11-C4797B356D) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].

7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: VALIDATED_INDICATOR_ONLY | Privilege: NONE | DataAccess: HTTP_FETCH_INDICATOR_ONLY | Impact: INTERNAL_REQUEST_ROUTING_SURFACE | EvidenceConf: 91%
Access Scope Summary:	VALIDATED_INDICATOR_ONLY: Mutillidae URL fetch indicator validated; internal metadata or cross-host credential extraction not executed
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-SSRF-MUTILLIDAE | Advisory: OWASP A10:2021 — Server-Side Request Forgery (SSRF) | CWE: CWE-918 | Taxonomy: OWASP-A10:2021 (Server-Side Request Forgery) | CWE-918 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139
Root Cause & 4-Tier Compliance:	Insecure Application Coding (Input Validation) [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization)
Technical Description:	The Mutillidae web application accepted a server-side URL fetch parameter without outbound destination allowlisting (consolidated from OWASP A10 SSRF validation). Classified as VALIDATED (VALIDATED_INDICATOR_ONLY): server-side fetch indicator verified, while internal metadata or cross-host credential extraction was not executed.
Security Risk:	HIGH (VALIDATED_INDICATOR_ONLY, CVSS 7.5) — Allows an attacker to induce the web application to issue HTTP requests to loopback or internal subnet services.
EvidenceCore V3.5 Record:	ID: PROV-F-11-C4797B356D | SHA-256: c4797b356dc57200b78827d8... | HMAC-SHA256: cf3b981c3b5723ba89b09016... | Module: AutoPentest-OWASP

Captured Technical Evidence (F-11):

```
A10 SSRF: 1 finding(s)
[CWE-918] SSRF: Mutillidae SSRF: Server fetched internal URL:
<!-- I think the database password is set to b
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Disable the vulnerable Mutillidae URL fetch endpoint or block outbound HTTP/TCP connections initiated by the `www-data` user via `iptables -m owner --uid-owner www-data -j DROP`.
Short-Term Hardening:	Implement strict URL parsing and domain/IP allowlisting that rejects RFC 1918 private addresses (`10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`) and loopback (`127.0.0.0/8`).
Long-Term Strategic Fix:	Route all application outbound fetches through a dedicated egress proxy with DNS rebinding protection.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.

Verification & Closure Rule:	Attempt to fetch `http://127.0.0.1/` via the SSRF parameter and confirm the request is blocked and logged. [Target Endpoint: `192.168.195.139:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-11 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Attempt to fetch `http://127.0.0.1/` via the SSRF parameter and confirm the request is blocked and logged. [Target Endpoint: `192.168.195.139:80`]` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-12: Apache HTTP Server Byte-Range Filter Denial-of-Service (CVE-2011-3192) [HIGH · CVSS 7.5 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1498 (Initial Access — Exploit Public-Facing Application) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1498 (Exploit Public-Facing Application) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: CVE-2011-3192 | Custom ID: XSTRIKE-APACHE-CVE-2011-3192 | Advisory: Apache httpd Security Advisory CVE-2011-3192 | CWE: CWE-400 | Taxonomy: OWASP-A06:2021 (Vulnerable Components) | CWE-400 (Uncontrolled Resource Consumption) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): https://www.securityfocus.com/bid/49303
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Nmap NSE (http-vuln-cve2011-3192) confirmed the byterange filter in Apache HTTP Server 2.2.x accepts overlapping Range header fields that can exhaust memory and CPU resources.
Security Risk:	HIGH — Remote unauthenticated attackers can trigger memory/CPU exhaustion via crafted HTTP Range headers.
EvidenceCore V3.5 Record:	ID: PROV-F-12-DA5DBFAC16 | SHA-256: da5dbfac16035e62345f9182... | HMAC-SHA256: 33c6a2078bdc59536ad05ca0... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-12):

```
VULNERABLE:
Apache byterange filter DoS
State: VULNERABLE
IDs: CVE:CVE-2011-3192 BID:49303
The Apache web server is vulnerable to a denial of service attack when numerous
overlapping byte ranges are requested.
Disclosure date: 2011-08-19
References:
https://www.securityfocus.com/bid/49303
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
https://seclists.org/fulldisclosure/2011/Aug/175
https://www.tenable.com/plugins/nessus/55
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Apply temporary Range header mitigation in Apache (`SetEnvIf Range (?:,.*?){5,5} bad-range=1` and `RequestHeader unset Range env=bad-range` via `mod_headers` / `mod_setenvif`) and reload Apache.
Short-Term Hardening:	Verify distribution package patch status (`dpkg -l apache2`) for CVE-2011-3192 or upgrade Apache httpd.
Long-Term Strategic Fix:	Decommission legacy Apache 2.2.x instances in favor of supported Apache 2.4.x releases.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `nmap -p 80 --script http-vuln-cve2011-3192 192.168.195.140` and confirm `State: NOT VULNERABLE`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-12 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 80 --script http-vuln-cve2011-3192 192.168.195.140` and confirm `State: NOT VULNERABLE`.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-13: SMB Message Signing Not Required (NTLM Relay Exposure) [HIGH · CVSS 7.4 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 445) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557.001 (Credential Access — Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1557.001 (Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-13-DD76B35A7A) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%

Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-SMB-SIGNING-DISABLED | Advisory: Microsoft ADV190023 / Samba Mandatory Signing Guideline | CWE: CWE-345 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-345 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)
Technical Description:	SMB message signing is not enforced by the server, allowing an adversary on the local network segment to relay NTLMv2 authentication sessions.
Security Risk:	HIGH — Enables Adversary-in-the-Middle (AitM) SMB relay attacks and unauthorized lateral movement.
EvidenceCore V3.5 Record:	ID: PROV-F-13-DD76B35A7A | SHA-256: dd76b35a7afae32e3f2eb696... | HMAC-SHA256: 68d14ab27ba6b9916c97a01f... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-13):

```
SMB signing not enforced — relay attacks possible

Evidence: SMB security mode: 0x00 (signing not required)
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Enforce mandatory SMB packet signing: set `server signing = mandatory` in `/etc/samba/smb.conf` (Linux) or enable `Microsoft network server: Digitally sign communications (always)` via Group Policy (Windows).
Short-Term Hardening:	Disable NTLMv1/LM authentication (`lanman auth = no`, `ntlm auth = ntlmv2-only`) and enable Extended Protection for Authentication (EPA).
Long-Term Strategic Fix:	Migrate file share authentication to Kerberos with SMBv3 transport encryption (`smb encrypt = required`).
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) on `192.168.195.139` prior to disabling SMBv1 or enforcing `server signing = mandatory`; restore `smb.conf.bak` and restart `smbd` if legacy clients fail.
Verification & Closure Rule:	Run `nmap -p 445 --script smb2-security-mode,smb-security-mode <target>` and confirm `Message signing enabled and required`. [Target Endpoint: `192.168.195.139:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-13 on 192.168.195.139:445 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 445 --script smb2-security-mode,smb-security-mode <target>` and confirm `Message signing enabled and required`. [Target Endpoint: `192.168.195.139:445`]` against `192.168.195.139:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-14: OpenSSL ChangeCipherSpec (CCS) Injection Vulnerability (CVE-2014-0224) [HIGH · CVSS 7.4 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 443) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557 (Credential Access — Adversary-in-the-Middle) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1557 (Adversary-in-the-Middle) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: CVE-2014-0224 | Custom ID: XSTRIKE-TLS-CCS-INJECTION | Advisory: OpenSSL Security Advisory [05 Jun 2014] CVE-2014-0224 | CWE: CWE-310 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-310 (Cryptographic Issues) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=72% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=72% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:443
Root Cause & 4-Tier Compliance:	Insecure Application Coding (Input Validation) [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Nmap NSE (ssl-ccs-injection) confirmed the TLS listener on TCP port 443 accepts early ChangeCipherSpec handshake messages (CVE-2014-0224), enabling Man-in-the-Middle key material derivation.
Security Risk:	HIGH — Allows an active network intermediary to decrypt and tamper with TLS sessions.
EvidenceCore V3.5 Record:	ID: PROV-F-14-99629D8B4E | SHA-256: 99629d8b4ea640fd4d8e7a67... | HMAC-SHA256: 79add01ae56ba9d56c9a70a0... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-14):

```
VULNERABLE:
SSL/TLS MITM vulnerability (CCS Injection)
State: VULNERABLE
Risk factor: High
OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
does not properly restrict processing of ChangeCipherSpec messages,
which allows man-in-the-middle attackers to trigger use of a zero
length master key in certain OpenSSL-to-OpenSSL communications, and
consequently hijack sessions or obtain sensitive information, via
```

```
a crafted TLS handshake
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Update the OpenSSL library package (`apt-get update && apt-get install --only-upgrade openssl libssl0.9.8 libssl1.0.0`) on the target host to remediate CVE-2014-0224 and restart the HTTPS daemon on port 443.
Short-Term Hardening:	Reissue TLS certificates and private keys if key compromise prior to patching is suspected.
Long-Term Strategic Fix:	Enforce TLS 1.2 / TLS 1.3 with modern AEAD cipher suites (ECDHE-RSA-AES128-GCM-SHA256).
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/mods-available/ssl.conf` and `/etc/ssl/openssl.cnf` on `192.168.195.140:443` (`cp -p ssl.conf ssl.conf.bak`), validate syntax via `apache2ctl configtest`, and restore `.bak` if TLS handshakes fail.
Verification & Closure Rule:	Run `nmap -p 443 --script ssl-ccs-injection 192.168.195.140` and confirm early ChangeCipherSpec messages are rejected. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-14 on 192.168.195.140:443 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 443 --script ssl-ccs-injection 192.168.195.140` and confirm early ChangeCipherSpec messages are rejected.` against `192.168.195.140:443`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-15: Cleartext Telnet Service Enabled on TCP Port 23 [HIGH · CVSS 7.5 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 23) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1021 (Lateral Movement — Remote Services) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1021 (Remote Services) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-TELNET-CLEARTEXT-23 | Advisory: NIST SP 800-53 SC-8 / CIS Benchmark Disable Telnet Service | CWE: CWE-319 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-319 (Cleartext Transmission of Sensitive Information) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139

Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)
Technical Description:	Telnet service on TCP port 23 transmits authentication credentials and interactive session traffic in unencrypted cleartext.
Security Risk:	HIGH — Cleartext credential transmission enables passive network sniffing and session hijacking.
EvidenceCore V3.5 Record:	ID: PROV-F-15-461B7CBE7D | SHA-256: 461b7cbe7dd144a669693d57... | HMAC-SHA256: 3abb084b37b938909939a092... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-15):

```
[2026-10-31 08:03:49] Telnet service on 192.168.195.139:23.
Service: telnet, Product: Linux telnetd, Version: unknown
Telnet transmits all traffic including credentials in cleartext.
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Stop the Telnet daemon (`inetd` / `telnetd`) on TCP port 23 immediately and block port 23 at the host firewall.
Short-Term Hardening:	Migrate all remote command-line administration to hardened OpenSSH (SSHv2).
Long-Term Strategic Fix:	Enforce network access control lists blocking cleartext management protocols (Telnet, rsh, rexec, FTP).
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/inetd.conf` (`cp -p /etc/inetd.conf /etc/inetd.conf.bak`) on `192.168.195.139` before commenting out the `ingreslock` (1524/tcp) or `telnet` (23/tcp) service entry and sending `kill -HUP` to `inetd`.
Verification & Closure Rule:	Confirm `nmap -p 23 192.168.195.139` reports TCP port 23 as `closed`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-15 on 192.168.195.139:23 remains OPEN until an automated XStrike re-test executes `Confirm `nmap -p 23 192.168.195.139` reports TCP port 23 as `closed`.` against `192.168.195.139:23`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-16: End-of-Life Apache HTTP Server 2.2.8 Deployed (TCP Port 80) [HIGH · CVSS 7.5 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record

Version & Backport Model:	Banner: Apache/2.2.8 (Ubuntu) DAV/2 | X-Powered-By: PHP/5.2.4-2ubuntu5.10 | Inferred: Apache HTTP Server 2.2.8 (Ubuntu) | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: End-of-Life Apache 2.2.x branch; Ubuntu backports patches within LTS support window, but Apache 2.2.x is upstream EOL. | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-APACHE-EOL-228 | Advisory: Apache HTTP Server 2.2.x End-of-Life Advisory | CWE: CWE-1104 | Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) | CWE-1104 (Use of Unmaintained Third Party Components) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 1 unique endpoint(s): 192.168.195.139
Root Cause & 4-Tier Compliance:	Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The HTTP server on 192.168.195.139:80 returned banner 'Apache/2.2.8 (Ubuntu) DAV/2 | X-Powered-By: PHP/5.2.4-2ubuntu5.10'. Apache httpd 2.2.8 (2.2.x branch) has reached End-of-Life (EOL) and no longer receives upstream security updates.
Security Risk:	HIGH — Running unsupported web server software with multiple historical CVEs.
EvidenceCore V3.5 Record:	ID: PROV-F-16-072ED84ECE | SHA-256: 072ed84ece90de59c2a8914d... | HMAC-SHA256: dc7669b39560cfa35d7c13d6... | Module: AutoPentest-OWASP, AutoPentest-PrivEsc

Captured Technical Evidence (F-16):

```
A06 Vulnerable Components: 6 finding(s)
[CWE-1104] Outdated: Apache 2.0/2.2 (EOL): Server: Apache/2.2.8 (Ubuntu) DAV/2 | X-Powered-By:
PHP/5.2.4-2ubuntu5.10
[CWE-1104] Outdated: PHP 5.x (EOL): Server: Apache/2.2.8 (Ubuntu) DAV/2 | X-Powered-By:
PHP/5.2.4-2ubuntu5.10
[CWE-1104] Vulnerable App: Mutillidae: OWASP Mutillidae – vulnerable by design
[CWE-1104] Vulnerable App: TWiki: Legacy wiki with known CVEs
[CWE-1104] Vulnerable App: TikiWiki: Legacy CMS with known vulnerabilities
[CWE-
---
Apache 2.2.8 may have known privilege escalation or RCE vulnerabilities.
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Set `ServerTokens Prod` and `ServerSignature Off`, verify installed package revision (`dpkg -l apache2`), and disable unneeded Apache 2.2 modules (`a2dismod dav dav_fs cgi autoindex`) to reduce attack surface immediately.
Short-Term Hardening:	Migrate workloads from EOL Apache httpd 2.2.x to supported Apache 2.4.x on a current LTS Linux distribution.
Long-Term Strategic Fix:	Automate web server patching and lifecycle tracking.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.

Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and `apache2 -v` on the host to verify minimal server banner and supported release status. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-16 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and `apache2 -v` on the host to verify minimal server banner and supported release status.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-17: End-of-Life Apache HTTP Server 2.2.14 Deployed (TCP Port 80) [HIGH · CVSS 7.5 · OBSERVED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin | Inferred: Apache HTTP Server 2.2.14 (Ubuntu) | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: End-of-Life Apache 2.2.x branch; Ubuntu backports patches within LTS support window, but Apache 2.2.x is upstream EOL. | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-APACHE-EOL-2214 | Advisory: Apache HTTP Server 2.2.x End-of-Life Advisory | CWE: CWE-1104 | Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) | CWE-1104 (Use of Unmaintained Third Party Components) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 1 unique endpoint(s): 192.168.195.140
Root Cause & 4-Tier Compliance:	Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The HTTP server on 192.168.195.140:80 returned banner 'Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin'. Apache httpd 2.2.14 (2.2.x branch) has reached End-of-Life (EOL) and no longer receives upstream security updates.
Security Risk:	HIGH — Running unsupported web server software with multiple historical CVEs.
EvidenceCore V3.5 Record:	ID: PROV-F-17-D072DCA059 | SHA-256: d072dca059d8090b94632c3e... | HMAC-SHA256: 2abad47354ac0959be2d77e8... | Module: AutoPentest-OWASP, AutoPentest-PrivEsc

Captured Technical Evidence (F-17):

```
A06 Vulnerable Components: 3 finding(s)
[CWE-1104] Outdated: Apache 2.0/2.2 (EOL): Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3
PHP/5.3.2-1ubuntu4.30 with Suhosin
[CWE-1104] Outdated: PHP 5.x (EOL): Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30
with Suhosin
```

```
[CWE-1104] Vulnerable App: TikiWiki: Legacy CMS with known vulnerabilities
---
Apache 2.2.14 may have known privilege escalation or RCE vulnerabilities.
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Set `ServerTokens Prod` and `ServerSignature Off`, verify installed package revision (`dpkg -l apache2`), and disable unneeded Apache 2.2 modules (`a2dismod dav dav_fs cgi autoindex`) to reduce attack surface immediately.
Short-Term Hardening:	Migrate workloads from EOL Apache httpd 2.2.x to supported Apache 2.4.x on a current LTS Linux distribution.
Long-Term Strategic Fix:	Automate web server patching and lifecycle tracking.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.140:80/` and `apache2 -v` on the host to verify minimal server banner and supported release status. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-17 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.140:80/` and `apache2 -v` on the host to verify minimal server banner and supported release status.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-18: PHP 5.2.4-2ubuntu5.10 CGI Banner Heuristic — Unverified CVE-2012-1823 Candidate [HIGH · CVSS 7.4 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1190 (Exploit Public-Facing Application) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: Apache/2.2.8 (Ubuntu) DAV/2 | Inferred: PHP 5.2.4-2ubuntu5.10 (Ubuntu Package with Suhosin-Patch) | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: Ubuntu package '5.2.4-2ubuntu5.10' includes vendor backports and Suhosin hardening. Upstream version comparison (< 5.3.12 / < 5.4.2) alone cannot confirm CVE-2012-1823 without active `?-s` or `-d` CGI execution proof. | CVE Applicability: UNVERIFIED_BANNER_CANDIDATE (Active CGI query-string RCE / source dump was not demonstrated)

Taxonomy & CVSS v3.1:	CVE: CVE-2012-1823 | Custom ID: XSTRIKE-PHP-CGI-1823 | Advisory: PHP Security Advisory CVE-2012-1823 / CERT VU#520827 | CWE: CWE-88 | Taxonomy: OWASP-A03:2021 (Injection) | CWE-88 (Improper Neutralization of Argument Delimiters) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, 192.168.195.139:80
Root Cause & 4-Tier Compliance:	Insecure Application Coding (Input Validation) [PROBABLE] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization)
Technical Description:	The web server on 192.168.195.139:80 reports 'PHP/5.2.4-2ubuntu5.10' (Apache/2.2.8 (Ubuntu) DAV/2). While upstream PHP versions prior to 5.3.12 / 5.4.2 are associated with CVE-2012-1823 CGI argument injection, active query-string code execution or `?-s` source disclosure was NOT demonstrated, and Ubuntu backport status for `5.2.4-2ubuntu5.10` must be verified via `dpkg -l php5-cgi`.
Security Risk:	HIGH — If PHP-CGI processes raw query-string flags (-d allow_url_include=on), an attacker can execute arbitrary PHP code.
EvidenceCore V3.5 Record:	ID: PROV-F-18-9F7D0FD361 | SHA-256: 9f7d0fd36125c120472c7f90... | HMAC-SHA256: a32d3f4de1783c4d98058df9... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln

Captured Technical Evidence (F-18):

```
Some PHP versions, when configured to run using CGI, do not correctly handle query strings that lack an
unescaped "=" character, enabling arbitrary code execution. In this case, an operating system co
---
PHP before 5.4.2 allows RCE when configured as CGI via query string

Evidence: Banner match on 192.168.195.139:80: HTTP/1.1 200 OK
Date: Sat, 31 Oct 2026 12:27:58 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Length: 891
Connection: close
Content-Type: text/html

<html
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Add an Apache `mod_rewrite` rule blocking query strings starting with `-`: `RewriteCond %{QUERY_STRING} ^(%2d|-) [NC]`, `RewriteRule ^.*$ - [F,L]`.
Short-Term Hardening:	Migrate PHP execution from `mod_cgi`/`php-cgi` to `php-fpm` (FastCGI Process Manager) and upgrade PHP 5.2.4 to a supported PHP 8.2/8.3 release.
Long-Term Strategic Fix:	Enforce `allow_url_include = Off` and `expose_php = Off` in `php.ini` across all web servers.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.

Verification & Closure Rule:	Send `GET /?-s HTTP/1.1` to `http://192.168.195.139:80/` and confirm HTTP 403 Forbidden with no PHP source code disclosed. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-18 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Send `GET /?-s HTTP/1.1` to `http://192.168.195.139:80/` and confirm HTTP 403 Forbidden with no PHP source code disclosed.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-19: PHP 5.3.2-1ubuntu4.30 CGI Banner Heuristic — Unverified CVE-2012-1823 Candidate [HIGH · CVSS 7.4 · OBSERVED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1190 (Exploit Public-Facing Application) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2. | Inferred: PHP 5.3.2-1ubuntu4.30 (Ubuntu Package with Suhosin-Patch) | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: Ubuntu package '5.3.2-1ubuntu4.30' includes vendor backports and Suhosin hardening. Upstream version comparison (< 5.3.12 / < 5.4.2) alone cannot confirm CVE-2012-1823 without active `?-s` or `-d` CGI execution proof. | CVE Applicability: UNVERIFIED_BANNER_CANDIDATE (Active CGI query-string RCE / source dump was not demonstrated)
Taxonomy & CVSS v3.1:	CVE: CVE-2012-1823 | Custom ID: XSTRIKE-PHP-CGI-1823 | Advisory: PHP Security Advisory CVE-2012-1823 / CERT VU#520827 | CWE: CWE-88 | Taxonomy: OWASP-A03:2021 (Injection) | CWE-88 (Improper Neutralization of Argument Delimiters) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:80
Root Cause & 4-Tier Compliance:	Insecure Application Coding (Input Validation) [PROBABLE] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization)
Technical Description:	The web server on 192.168.195.140:80 reports 'PHP/5.3.2-1ubuntu4.30' (Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.). While upstream PHP versions prior to 5.3.12 / 5.4.2 are associated with CVE-2012-1823 CGI argument injection, active query-string code execution or `?-s` source disclosure was NOT demonstrated, and Ubuntu backport status for `5.3.2-1ubuntu4.30` must be verified via `dpkg -l php5-cgi`.
Security Risk:	HIGH — If PHP-CGI processes raw query-string flags (-d allow_url_include=on), an attacker can execute arbitrary PHP code.

EvidenceCore V3.5 Record:	ID: PROV-F-19-419939685D | SHA-256: 419939685df245c03f394e6b... | HMAC-SHA256: ce82b9231037f84152d30a0d... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-19):

```
PHP before 5.4.2 allows RCE when configured as CGI via query string

Evidence: Banner match on 192.168.195.140:80: HTTP/1.1 200 OK
Date: Sat, 31 Oct 2026 12:28:41 GMT
Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1
mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Add an Apache `mod_rewrite` rule blocking query strings starting with `-`: `RewriteCond %{QUERY_STRING} ^(%2d|-) [NC]`, `RewriteRule ^.*$ - [F,L]`.
Short-Term Hardening:	Migrate PHP execution from `mod_cgi`/`php-cgi` to `php-fpm` (FastCGI Process Manager) and upgrade PHP 5.3.2-1ubuntu4.30 to a supported PHP 8.2/8.3 release.
Long-Term Strategic Fix:	Enforce `allow_url_include = Off` and `expose_php = Off` in `php.ini` across all web servers.
Approval & Change Window:	Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Send `GET /?-s HTTP/1.1` to `http://192.168.195.140:80/` and confirm HTTP 403 Forbidden with no PHP source code disclosed. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-19 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Send `GET /?-s HTTP/1.1` to `http://192.168.195.140:80/` and confirm HTTP 403 Forbidden with no PHP source code disclosed.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-20: FTP Anonymous Authentication Enabled [MEDIUM · CVSS 5.3 · CONFIRMED_AUTH]

Target Asset & Port:	192.168.195.139 (Ports: 21) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: CONFIRMED_AUTH -> T1 Post-Retest: CONFIRMED_AUTH (RETEST_FAILED_STILL_VULNERABLE (CHG-2026-1031-005)) | Privilege: ANONYMOUS (ftp) | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=authenticated_network_service | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: PROVEN_SESSION_AUTHENTICATION | Exploitability Claimed: True | Rationale: Promoted to CONFIRMED_AUTH because a live authenticated session handshake and read-only session command succeeded.
4-State MITRE Provenance:	MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) | Execution State: EXECUTED_WITH_PROOF [TIER_1_LIVE_EXECUTION_TRANSCRIPT] — Technique T1078.001 (Valid Accounts: Default Accounts) actively executed and semantically verified via session transcript (PROV-F-20-D246223315) [AUTHENTICATED_NETWORK_SERVICE_SESSION (Live authenticated handshake verified on 192.168.195.139:21)].
7-D Proof Vector (V3.5):	Execution: AUTHENTICATED_SESSION_VERIFIED | Auth: ANONYMOUS_AUTH (230 OK) | Exploitability: CREDENTIAL_CONFIRMED | Privilege: ANONYMOUS (ftp) | DataAccess: EMPTY_ROOT_DIRECTORY | Impact: UNAUTHENTICATED_SESSION_ACCESS | EvidenceConf: 98%
Access Scope Summary:	Anonymous FTP login (230 OK) verified; root directory empty (0 files exfiltrated)

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-FTP-ANONYMOUS | Advisory: RFC 1635 / vsFTPd anonymous_enable Configuration Advisory | CWE: CWE-287 | Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) | CWE-287 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=99% | ExploitabilityConf=95% | ImpactConf=88% | 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) | ExploitabilityConf=95% | ImpactConf=88% | FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, 192.168.195.139:21
Root Cause & 4-Tier Compliance:	Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	The FTP server accepts anonymous login ('anonymous') with FTP status 230 OK. Enumeration confirmed an empty anonymous root directory (0 files exposed).
Security Risk:	MEDIUM — Unauthenticated FTP session establishment; while no files were present in the root directory, anonymous access exposes internal service state.
EvidenceCore V3.5 Record:	ID: PROV-F-20-D246223315 | SHA-256: d246223315dfa903b9321167... | HMAC-SHA256: 3c14fef8435719fae4ceca64... | Module: XStrike-BuiltinVuln, AutoPentest-Exploit

Captured Technical Evidence (F-20):

```
Anonymous login OK. Banner: 220 (vsFTPd 2.3.4). Files(0):
---
FTP server accepts anonymous login — unauthorized file access

Evidence: FTP anonymous login: 230 Login successful.
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Set `anonymous_enable=NO` in `/etc/vsftpd.conf` and restart the vsFTPd service (`service vsftpd restart`).
Short-Term Hardening:	Audit `/var/ftp` or the anonymous root directory to ensure no sensitive files or write permissions (`anon_upload_enable=NO`) exist.
Long-Term Strategic Fix:	Replace unauthenticated FTP distribution with authenticated HTTPS artifact repositories.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/vsftpd.conf` (`cp -p /etc/vsftpd.conf /etc/vsftpd.conf.bak`) on `192.168.195.139` before disabling anonymous/default access or stopping `vsftpd`; restore `/etc/vsftpd.conf.bak` if authorized file transfer workflows require rollback.
Verification & Closure Rule:	Connect to port 21 as `USER anonymous` and verify the server responds with `530 Permission denied`. [Target Endpoint: `192.168.195.139:21`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-20 on 192.168.195.139:21 remains OPEN until an automated XStrike re-test executes `Connect to port 21 as `USER anonymous` and verify the server responds with `530 Permission denied`. [Target Endpoint: `192.168.195.139:21`]` against `192.168.195.139:21`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-21: Local Privilege Escalation Vector: SUID Binary (/bin/mount) [MEDIUM · CVSS 5.5 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 22) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)

Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) | Privesc Lifecycle: PRECONDITION_DISCOVERED
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1548.001 (Privilege Escalation — Abuse Elevation Control Mechanism: Setuid and Setgid) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1548.001 (Abuse Elevation Control Mechanism: Setuid and Setgid) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-21-7DD3904640) [PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED (SUID/Kernel escalation precondition proven from uid=1000 shell; final root transition withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: AUTHENTICATED_ENUMERATION_EXECUTED | Auth: AUTHENTICATED_USER (uid=1000) | Exploitability: VERSION_OR_ACL_VALIDATED | Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) | DataAccess: KERNEL_AND_SUID_METADATA | Impact: LOCAL_PRIVESC_SURFACE | EvidenceConf: 93%
Access Scope Summary:	Authenticated SSH 'find / -perm -4000' discovered SUID-root precondition on /bin/mount; writable mount escalation not executed
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-PRIVESC-SUID-MOUNT | Advisory: Linux SUID Binary Hardening Baseline (/bin/mount) | CWE: CWE-269 | Taxonomy: MITRE ATT&CK T1548.001 | CWE-269 (Improper Privilege Management) | Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:22, 192.168.195.139
Root Cause & 4-Tier Compliance:	Excessive Local Privilege / File Permission Misconfiguration [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening)
Technical Description:	Post-authentication SSH enumeration identified SUID root permissions on /bin/mount, which may be combined with NFS or fstab misconfigurations for local privilege escalation.
Security Risk:	MEDIUM (CVSS 6.7) — Potential local privilege escalation vector if combined with writable mount points.
EvidenceCore V3.5 Record:	ID: PROV-F-21-7DD3904640 | SHA-256: 7dd3904640bcc1c9005f6435... | HMAC-SHA256: c94cdfc283fa377616d6026d... | Module: AutoPentest-Exploit, AutoPentest-PrivEsc

Captured Technical Evidence (F-21):

```
SUID mount found — known privilege escalation vector!
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Audit `/etc/fstab` to ensure no user-mountable filesystems permit `suid` or `exec`, and remove unnecessary SUID bits from `/bin/mount` (`chmod u-s /bin/mount`) if unprivileged mounting is not required.
Short-Term Hardening:	Enforce `nosuid,nodev,noexec` on `/tmp`, `/var/tmp`, and `/home` mounts in `/etc/fstab`.

Long-Term Strategic Fix:	Implement file integrity monitoring (AIDE/auditd) tracking setuid/setgid permission changes across `/bin` and `/usr/bin`.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Record baseline file permissions via `stat -c '%a %n' /usr/bin/nmap /bin/mount > /root/suid_baseline.txt` on `192.168.195.139`; restore with `chmod 4755 <binary>` only if an approved operational dependency breaks.
Verification & Closure Rule:	Run `find / -perm -4000 -type f 2>/dev/null` and confirm only approved baseline SUID binaries remain. [Target Endpoint: `192.168.195.139:22`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-21 on 192.168.195.139:22 remains OPEN until an automated XStrike re-test executes `Run `find / -perm -4000 -type f 2>/dev/null` and confirm only approved baseline SUID binaries remain. [Target Endpoint: `192.168.195.139:22`]` against `192.168.195.139:22`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-22: Client-Manipulable Session/Tracking Cookie Parameters Set Without Integrity Binding [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-COOKIE-INTEGRITY | Advisory: OWASP Testing Guide — Testing for Cookie Attributes (WSTG-SESS-02) | CWE: CWE-565 | Taxonomy: OWASP-A04:2021 (Insecure Design) | CWE-565 (Reliance on Cookies without Validation and Integrity Checking) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 4 raw observation(s) across 1 unique endpoint(s): 192.168.195.1
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)

Technical Description:	The web application issues multiple state/configuration cookies without cryptographic HMAC signing or strict attribute hardening.
Security Risk:	MEDIUM — If server logic trusts unverified cookie values, attackers may tamper with user state or privilege indicators.
EvidenceCore V3.5 Record:	ID: PROV-F-22-7ADBDFAA38 | SHA-256: 7adbdfaa38811d7de159a4ba... | HMAC-SHA256: 383d68130a51bfb68a52b9bf... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-22):

```
This check looks at user-supplied input in query string parameters and POST data to identify where
cookie parameters might be controlled. This is called a cookie poisoning attack, and becomes exploita
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Stop trusting client-side cookie parameters for user identity, privilege, or application state; store session state server-side in `$_SESSION`.
Short-Term Hardening:	If client-side cookies are used, sign values with HMAC-SHA256 and set `HttpOnly`, `Secure`, and `SameSite=Lax` attributes.
Long-Term Strategic Fix:	Standardize session management on encrypted, server-validated session stores.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Modify cookie values in an HTTP request and verify the server rejects tampered cookies and does not alter privilege state. [Target Endpoint: `192.168.195.1:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-22 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Modify cookie values in an HTTP request and verify the server rejects tampered cookies and does not alter privilege state. [Target Endpoint: `192.168.195.1:80`]` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-23: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-CSP-MISSING | Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 116 raw observation(s) across 3 unique endpoint(s): 192.168.195.1, 192.168.195.1:8080, 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection.
Security Risk:	MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw.
EvidenceCore V3.5 Record:	ID: PROV-F-23-43FFEFB79F | SHA-256: 43ffefb79f795094c3396375... | HMAC-SHA256: eb641af754ac11c1ea86ef9f... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-23):

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
---
No CSP header — XSS and injection attacks not mitigated

Evidence: HTTP response from 192.168.195.1:8080 missing content-security-policy header
---
Missing header: Content-Security-Policy | CWE: CWE-1021 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. (Note: On `192.168.195.1:8000`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files.
Long-Term Strategic Fix:	Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.

Verification & Closure Rule:	Run `curl -I http://192.168.195.1:8000/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-23 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.1:8000/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-24: Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-XFO-MISSING | Advisory: RFC 7034 / OWASP Clickjacking Defense Cheat Sheet | CWE: CWE-1021 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-1021 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 11 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8080
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses do not include 'X-Frame-Options' or CSP 'frame-ancestors' directives, permitting the web interface to be embedded inside an external iframe.
Security Risk:	MEDIUM — Exposes authenticated web users to UI redressing (Clickjacking) attacks.
EvidenceCore V3.5 Record:	ID: PROV-F-24-75E6EB7F1A | SHA-256: 75e6eb7f1a04ecb99dd3e538... | HMAC-SHA256: cbeb83110c8f8f9516d753bb... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln

Captured Technical Evidence (F-24):

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
```

```
---
No clickjacking protection — X-Frame-Options header missing

Evidence: HTTP response from 192.168.195.1:8080 missing x-frame-options header
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Add `Header always set X-Frame-Options "DENY"` (or `"SAMEORIGIN"`) and CSP `frame-ancestors 'self'` in the web server configuration.
Short-Term Hardening:	Verify no legacy application workflows depend on cross-origin `<iframe src=...>` embedding.
Long-Term Strategic Fix:	Enforce standard security header middleware across all web application frameworks.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.1:80/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-24 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.1:80/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present.` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-25: Session Cookie Missing 'Secure' Flag [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557 (Credential Access — Adversary-in-the-Middle) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1557 (Adversary-in-the-Middle) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-COOKIE-SECURE | Advisory: OWASP Session Management Cheat Sheet — Secure Flag | CWE: CWE-614 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-614 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)
Technical Description:	Cookies are issued without the 'Secure' attribute, allowing the browser to transmit them over unencrypted HTTP connections.
Security Risk:	MEDIUM — Exposes session identifiers to cleartext network interception.
EvidenceCore V3.5 Record:	ID: PROV-F-25-0C8B90016E | SHA-256: 0c8b90016eaeb918da87c3a0... | HMAC-SHA256: 7fcc91cf43c838c795e6c9db... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-25):

```
Cookie: cval=1915971765... | CWE: CWE-614 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Enable HTTPS and set `session.cookie_secure = 1` in `php.ini` so session cookies are only transmitted over TLS. (Note: On `192.168.195.1:8000`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Add Apache header rewrite `Header edit Set-Cookie ^(.*)$ "$1; Secure"` on all HTTPS virtual hosts.
Long-Term Strategic Fix:	Adopt `__Host-` cookie prefixes which require `Secure`, `Path=/`, and no `Domain` attribute.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Inspect `Set-Cookie` headers over HTTPS and confirm the `Secure` attribute is present. [Target Endpoint: `192.168.195.1:8000`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-25 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie` headers over HTTPS and confirm the `Secure` attribute is present. [Target Endpoint: `192.168.195.1:8000`]` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-26: Verbose Application / Database Error Message Disclosure [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.

4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-ZAP-ERROR-DISCLOSURE | Advisory: OWASP ZAP Alert 90022 — Application Error Disclosure | CWE: CWE-209 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-209 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 15 raw observation(s) across 1 unique endpoint(s): 192.168.195.1
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The web application returns raw stack traces, PHP warnings, or database error strings in HTTP responses.
Security Risk:	MEDIUM — Exposes internal file paths, SQL query structure, and framework internals to assist exploitation.
EvidenceCore V3.5 Record:	ID: PROV-F-26-0ECF0A8DFA | SHA-256: 0ecf0a8dfa7d7f34a5114dc0... | HMAC-SHA256: 626d8a44e354dcc88a77ce85... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-26):

```
This page contains an error/warning message that may disclose sensitive information like the location of
the file that produced the unhandled exception. This information can be used to launch further
---
The response appeared to contain common error messages returned by platforms such as ASP.NET, and
Web-servers such as IIS and Apache. You can configure the list of common debug messages.
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Set `display_errors = Off` and `log_errors = On` in `/etc/php5/apache2/php.ini` and configure custom generic 500 error pages in Apache. (Note: On `192.168.195.1:80`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Wrap database and file operations in structured exception handlers that log stack traces server-side only.
Long-Term Strategic Fix:	Enforce production error-handling standards across all web applications.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.

Verification & Closure Rule:	Trigger an invalid parameter request and confirm a generic error message is returned with zero stack traces or SQL errors. [Target Endpoint: `192.168.195.1:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-26 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Trigger an invalid parameter request and confirm a generic error message is returned with zero stack traces or SQL errors. [Target Endpoint: `192.168.195.1:80`]` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-27: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 5357) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-CSRF-BUNDLE | Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet | CWE: CWE-352 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-352 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 5 raw observation(s) across 5 unique endpoint(s): 192.168.195.1:5357, 192.168.195.1:8000, https://evil-test-aegis.com, 192.168.195.1:8080 ... (+1 additional endpoints)
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers.
Security Risk:	MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page.
EvidenceCore V3.5 Record:	ID: PROV-F-27-195609A7AC | SHA-256: 195609a7ac071b6d3b5dab43... | HMAC-SHA256: 9cd8cf79165f49afec2c858a... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-27):

```
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
---
Discovered 1 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session cookie lacks SameSite protect
---
Discovered 4 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session c
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:5357 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms.
Short-Term Hardening:	Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests.
Long-Term Strategic Fix:	Adopt a modern web framework with built-in CSRF middleware and automated security header injection.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:5357` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.1:5357`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-27 on 192.168.195.1:5357 remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.1:5357`]` against `192.168.195.1:5357`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-28: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.129 (Ports: 80) | Asset Class: Application / Network Host (STANDARD)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-CSP-MISSING | Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.129
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection.
Security Risk:	MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw.
EvidenceCore V3.5 Record:	ID: PROV-F-28-3EC6DC8F79 | SHA-256: 3ec6dc8f79eada34464d2db8... | HMAC-SHA256: 4aa5fff43dce5192fb6baed6... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-28):

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
```

Target Environment Profile:	LAN Endpoint (192.168.195.129:80 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. (Note: On `192.168.195.129:80`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files.
Long-Term Strategic Fix:	Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.129:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.129` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.129:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-28 on 192.168.195.129:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.129:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.` against `192.168.195.129:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-29: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.129 (Ports: 5357) | Asset Class: Application / Network Host (STANDARD)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-CSRF-BUNDLE | Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet | CWE: CWE-352 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-352 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.129:5357
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers.
Security Risk:	MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page.
EvidenceCore V3.5 Record:	ID: PROV-F-29-123FED81F2 | SHA-256: 123fed81f2d10977cce080e5... | HMAC-SHA256: 95d292d3bcc9fa9ef6732622... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-29):

```
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
```

Target Environment Profile:	LAN Endpoint (192.168.195.129:5357 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms.
Short-Term Hardening:	Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests.

Long-Term Strategic Fix:	Adopt a modern web framework with built-in CSRF middleware and automated security header injection.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.129:5357` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.129` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.129:5357`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-29 on 192.168.195.129:5357 remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.129:5357`]` against `192.168.195.129:5357`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-30: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.130 (Ports: 80) | Asset Class: Workstation / SMB Peer Host (STANDARD)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-CSP-MISSING | Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.130
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)

Technical Description:	Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection.
Security Risk:	MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw.
EvidenceCore V3.5 Record:	ID: PROV-F-30-728E837B93 | SHA-256: 728e837b93ac5891a255cbf5... | HMAC-SHA256: f0fe29559442d954282ffb6b... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-30):

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
```

Target Environment Profile:	LAN Endpoint (192.168.195.130:80 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. (Note: On `192.168.195.130:80`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files.
Long-Term Strategic Fix:	Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.130:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.130` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.130:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-30 on 192.168.195.130:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.130:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.` against `192.168.195.130:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-31: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.130 (Ports: 5985) | Asset Class: Workstation / SMB Peer Host (STANDARD)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%

Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-CSRF-BUNDLE | Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet | CWE: CWE-352 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-352 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.130:5985
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers.
Security Risk:	MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page.
EvidenceCore V3.5 Record:	ID: PROV-F-31-8A2BA0953C | SHA-256: 8a2ba0953cd9c8f375a60fce... | HMAC-SHA256: 0d67520597c4b8cce1895401... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-31):

```
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send X-Frame-Options or CSP frame-ancestors header.
```

Target Environment Profile:	LAN Endpoint (192.168.195.130:5985 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms.
Short-Term Hardening:	Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests.
Long-Term Strategic Fix:	Adopt a modern web framework with built-in CSRF middleware and automated security header injection.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.130:5985` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.130` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.130:5985`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-31 on 192.168.195.130:5985 remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.130:5985`]` against `192.168.195.130:5985`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-32: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-CSP-MISSING | Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139, 192.168.195.139:80, http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection.
Security Risk:	MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw.
EvidenceCore V3.5 Record:	ID: PROV-F-32-48C5125842 | SHA-256: 48c51258421767558f3f345b... | HMAC-SHA256: f602b382da9ac6ae88f25f01... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-32):

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
---
No CSP header – XSS and injection attacks not mitigated

Evidence: HTTP response from 192.168.195.139:80 missing content-security-policy header
---
Missing header: Content-Security-Policy | CWE: CWE-1021 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)

Immediate Containment:	Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`.
Short-Term Hardening:	Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files.
Long-Term Strategic Fix:	Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-32 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-33: DNS Open Recursion Enabled on ISC BIND 9.4.2 (Port 53) [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 53) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1498.002 (Impact — Network Denial of Service: Reflection Amplification) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1498.002 (Network Denial of Service: Reflection Amplification) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-DNS-OPEN-RECURSION | Advisory: US-CERT Alert TA13-088A / ISC BIND Recursion Access Control | CWE: CWE-406 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-406 (Insufficient Control of Network Message Volume) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:53

Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	ISC BIND 9.4.2 on port 53 permits recursive DNS queries from untrusted network clients.
Security Risk:	MEDIUM — Can be abused for DNS amplification and cache-poisoning attacks.
EvidenceCore V3.5 Record:	ID: PROV-F-33-5B4890920F | SHA-256: 5b4890920f6d14cbae2cc3cd... | HMAC-SHA256: eafc98e775237f896e478867... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-33):

```
DNS server allows recursive queries — can be abused for amplification attacks

Evidence: DNS recursion available on 192.168.195.139:53 (RA flag set)
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Disable open recursion in BIND `/etc/bind/named.conf.options` (`recursion no;` or `allow-recursion { 127.0.0.1; };`) and reload `named`.
Short-Term Hardening:	Upgrade ISC BIND 9.4.2 to a supported BIND 9.18 LTS release and enable response rate limiting (RRL).
Long-Term Strategic Fix:	Separate authoritative DNS servers from recursive resolvers.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/bind/named.conf.options` (`cp -p /etc/bind/named.conf.options /etc/bind/named.conf.options.bak`) on `192.168.195.139`, verify syntax with `named-checkconf` prior to `rndc reload`, and restore `.bak` if internal DNS resolution is impacted.
Verification & Closure Rule:	Run `dig @192.168.195.139 example.com` from an untrusted host and confirm `status: REFUSED`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-33 on 192.168.195.139:53 remains OPEN until an automated XStrike re-test executes `Run `dig @192.168.195.139 example.com` from an untrusted host and confirm `status: REFUSED`.` against `192.168.195.139:53`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-34: Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-XFO-MISSING | Advisory: RFC 7034 / OWASP Clickjacking Defense Cheat Sheet | CWE: CWE-1021 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-1021 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139, 192.168.195.139:80, http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses do not include 'X-Frame-Options' or CSP 'frame-ancestors' directives, permitting the web interface to be embedded inside an external iframe.
Security Risk:	MEDIUM — Exposes authenticated web users to UI redressing (Clickjacking) attacks.
EvidenceCore V3.5 Record:	ID: PROV-F-34-A9EE8ABF71 | SHA-256: a9ee8abf7190284f476308a2... | HMAC-SHA256: 87b1d5a88ee83baf5eaca412... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-34):

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
---
No clickjacking protection — X-Frame-Options header missing

Evidence: HTTP response from 192.168.195.139:80 missing x-frame-options header
---
Missing header: X-Frame-Options | CWE: CWE-1021 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Add `Header always set X-Frame-Options "DENY"` (or `"SAMEORIGIN"`) and CSP `frame-ancestors 'self'` in the web server configuration.
Short-Term Hardening:	Verify no legacy application workflows depend on cross-origin `<iframe src=...>` embedding.
Long-Term Strategic Fix:	Enforce standard security header middleware across all web application frameworks.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-34 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-35: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-CSRF-BUNDLE | Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet | CWE: CWE-352 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-352 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/phpinfo.php
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers.
Security Risk:	MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page.
EvidenceCore V3.5 Record:	ID: PROV-F-35-54B9C0FFC0 | SHA-256: 54b9c0ffc0a0064dd1e96f7d... | HMAC-SHA256: 5495fd0fead5db60df55002c... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-35):

```
Discovered 3 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
[DEBUG-01] Sensitive Information & Debug Disclosures (1): PHP Info Configuration Exposed at
http://192.168.195.139:80/phpinfo.php
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms.

Short-Term Hardening:	Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests.
Long-Term Strategic Fix:	Adopt a modern web framework with built-in CSRF middleware and automated security header injection.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.139:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-35 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.139:80`]` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-36: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80, 8080) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-CSP-MISSING | Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 25 raw observation(s) across 5 unique endpoint(s): 192.168.195.140, 192.168.195.140:80, 192.168.195.140:8080, http://192.168.195.140:80/ ... (+1 additional endpoints)

Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection.
Security Risk:	MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw.
EvidenceCore V3.5 Record:	ID: PROV-F-36-1C0159C889 | SHA-256: 1c0159c8893d6ee0c56ba8bb... | HMAC-SHA256: bc48b0622a8dd89bcccf1f80... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-36):

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
---
No CSP header — XSS and injection attacks not mitigated

Evidence: HTTP response from 192.168.195.140:80 missing content-security-policy header
---
No CSP header — XSS and injection attacks not mitigated

Evidence: HTTP response from 192.168.195.140:8080 missing content-security-policy header
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`.
Short-Term Hardening:	Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files.
Long-Term Strategic Fix:	Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.140:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-36 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.140:80/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-37: Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80, 8080) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.

4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-XFO-MISSING | Advisory: RFC 7034 / OWASP Clickjacking Defense Cheat Sheet | CWE: CWE-1021 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-1021 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 11 raw observation(s) across 5 unique endpoint(s): 192.168.195.140, 192.168.195.140:80, 192.168.195.140:8080, http://192.168.195.140:80/ ... (+1 additional endpoints)
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses do not include 'X-Frame-Options' or CSP 'frame-ancestors' directives, permitting the web interface to be embedded inside an external iframe.
Security Risk:	MEDIUM — Exposes authenticated web users to UI redressing (Clickjacking) attacks.
EvidenceCore V3.5 Record:	ID: PROV-F-37-C7F5C2033C | SHA-256: c7f5c2033c00fc6321a5e7a9... | HMAC-SHA256: 89c5ea4c4fdc7e9eacd58015... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-37):

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
---
No clickjacking protection — X-Frame-Options header missing

Evidence: HTTP response from 192.168.195.140:80 missing x-frame-options header
---
No clickjacking protection — X-Frame-Options header missing

Evidence: HTTP response from 192.168.195.140:8080 missing x-frame-options header
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Add `Header always set X-Frame-Options "DENY"` (or `"SAMEORIGIN"`) and CSP `frame-ancestors 'self'` in the web server configuration.
Short-Term Hardening:	Verify no legacy application workflows depend on cross-origin `<iframe src=...>` embedding.
Long-Term Strategic Fix:	Enforce standard security header middleware across all web application frameworks.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)

Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.140:80/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-37 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.140:80/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-38: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-CSRF-BUNDLE | Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet | CWE: CWE-352 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-352 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.140:80, 192.168.195.140:8080, 192.168.195.140:8081
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers.
Security Risk:	MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page.
EvidenceCore V3.5 Record:	ID: PROV-F-38-6857758F9B | SHA-256: 6857758f9b1a7847006edfd9... | HMAC-SHA256: bb335dbfea8567314b8d8f7f... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-38):

```
Discovered 1 web vulnerabilities:
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
---
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms.
Short-Term Hardening:	Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests.
Long-Term Strategic Fix:	Adopt a modern web framework with built-in CSRF middleware and automated security header injection.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.140:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-38 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. [Target Endpoint: `192.168.195.140:80`]` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-39: Administrative Web Interface Reachable Without Network Restriction [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1083 (Discovery — File and Directory Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1083 (File and Directory Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-ADMIN-EXPOSED | Advisory: OWASP A01:2021 — Administrative Interface Access Control | CWE: CWE-284 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-284 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=90% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.1:80/Config
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening)
Technical Description:	Administrative web paths (/admin/, /phpMyAdmin/) are reachable over the network without IP allowlisting or VPN segmentation.
Security Risk:	MEDIUM — Expands attack surface for credential stuffing and administrative application exploits.
EvidenceCore V3.5 Record:	ID: PROV-F-39-0F0910DEE4 | SHA-256: 0f0910dee41b89e89881c969... | HMAC-SHA256: 494389bc82f8164eb332a67e... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-39):

```
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/admin: Admin panel accessible
/admin/: Admin panel accessible
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Restrict `/admin/`, `/phpMyAdmin/`, and `/manager/` URI prefixes to administrative management IPs via Apache `<Location>` access controls.
Short-Term Hardening:	Enforce multi-factor authentication and TLS client certificates on all administrative web consoles.
Long-Term Strategic Fix:	Bind administrative interfaces to an isolated out-of-band management network or VPN.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. [Target Endpoint: `192.168.195.1:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-39 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. [Target Endpoint: `192.168.195.1:80`]` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-40: Administrative Web Interface Reachable Without Network Restriction [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC

Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1083 (Discovery — File and Directory Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1083 (File and Directory Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-ADMIN-EXPOSED | Advisory: OWASP A01:2021 — Administrative Interface Access Control | CWE: CWE-284 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-284 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/Config
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening)
Technical Description:	Administrative web paths (/admin/, /phpMyAdmin/) are reachable over the network without IP allowlisting or VPN segmentation.
Security Risk:	MEDIUM — Expands attack surface for credential stuffing and administrative application exploits.
EvidenceCore V3.5 Record:	ID: PROV-F-40-2ADB9B1ADF | SHA-256: 2adb9b1adf353b4ac4f1cdfd... | HMAC-SHA256: f2b31c89d8e819aaf801c79e... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-40):

```
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/: Admin panel accessible
/phpMyAdmin/: Admin panel accessible
/dvwa/login.php: Admin panel accessible
/mutillidae/: Admin panel accessible
/mutillidae/index.php: Admin panel accessible
/server-status: Apache server-status exposed
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Restrict `/admin/`, `/phpMyAdmin/`, and `/manager/` URI prefixes to administrative management IPs via Apache `<Location>` access controls.
Short-Term Hardening:	Enforce multi-factor authentication and TLS client certificates on all administrative web consoles.
Long-Term Strategic Fix:	Bind administrative interfaces to an isolated out-of-band management network or VPN.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)

Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. [Target Endpoint: `192.168.195.139:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-40 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. [Target Endpoint: `192.168.195.139:80`]` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-41: Deprecated SMBv1 Dialect Enabled on SMB Service (Protocol Hardening Weakness) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 445) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1210 (Exploitation of Remote Services) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-41-8861085603) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-SMBV1-ENABLED | Advisory: Microsoft / Samba SMBv1 Deprecation Advisory (KB2696547 — Distinct from MS17-010) | CWE: CWE-327 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-327 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:445
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)

Technical Description:	The SMB service negotiates the deprecated NT LM 0.12 (SMBv1) protocol dialect, which lacks modern pre-authentication integrity and encryption capabilities. Note: SMBv1 dialect negotiation is a protocol hardening weakness (CWE-327, Medium 5.3) and does NOT by itself prove MS17-010 / CVE-2017-0144 (EternalBlue) remote code execution.
Security Risk:	MEDIUM (CVSS 5.3) — Legacy SMBv1 protocol dialect enabled; disable SMBv1 and enforce SMBv2/SMBv3 across all servers.
EvidenceCore V3.5 Record:	ID: PROV-F-41-8861085603 | SHA-256: 88610856038e2153a17fe724... | HMAC-SHA256: 8aa046b4ef3179fd7b0f97cd... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-41):

```
SMBv1 is enabled — vulnerable to EternalBlue (MS17-010)

Evidence: SMBv1 negotiate response received from 192.168.195.139:445
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Disable SMBv1 protocol negotiation: in Samba `/etc/samba/smb.conf` set `server min protocol = SMB2`; on Windows run `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`.
Short-Term Hardening:	Enforce mandatory SMB packet signing (`server signing = mandatory` in `smb.conf`) and restart `smbd`.
Long-Term Strategic Fix:	Standardize all file shares on SMBv3.1.1 with AES-128-GCM encryption enabled.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) on `192.168.195.139` prior to disabling SMBv1 or enforcing `server signing = mandatory`; restore `smb.conf.bak` and restart `smbd` if legacy clients fail.
Verification & Closure Rule:	Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered. [Target Endpoint: `192.168.195.139:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-41 on 192.168.195.139:445 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered. [Target Endpoint: `192.168.195.139:445`]` against `192.168.195.139:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-42: Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE (Unauthenticated HTTP 200) | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.

7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: EXPOSED_ADMIN_SURFACE | Privilege: NONE (Unauthenticated HTTP 200) | DataAccess: HTML_LOGIN_OR_INDEX_ONLY | Impact: ADMINISTRATIVE_SURFACE_EXPOSURE | EvidenceConf: 94%
Access Scope Summary:	HTTP 200 administrative interface reachable at /phpMyAdmin/; unauthenticated DB read/write not independently demonstrated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-PHPMYADMIN-EXPOSED | Advisory: phpMyAdmin Documentation — Securing Your phpMyAdmin Installation | CWE: CWE-306 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-306 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/phpMyAdmin/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	The phpMyAdmin web interface at http://192.168.195.139:80/phpMyAdmin/ returned HTTP 200. While the administrative interface is reachable without network-layer restriction, unauthenticated database read/write execution was not demonstrated in the captured evidence.
Security Risk:	MEDIUM (VALIDATED EXPOSURE, CVSS 5.3) — Publicly reachable database administration console; exposes backend MySQL authentication surface.
EvidenceCore V3.5 Record:	ID: PROV-F-42-FB05C305AC | SHA-256: fb05c305ac6d103d87c636a1... | HMAC-SHA256: 0b4acf25eed457987a6f54d0... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-42):

```
[HTTP Probe 200 OK on /phpMyAdmin/ — Exposed administrative web interface; unauthenticated SQL
read/write NOT demonstrated]
Data: <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en" dir="lt
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Restrict `/phpMyAdmin/` in Apache `/etc/apache2/conf.d/phpmyadmin.conf` to localhost or administrative VPN IPs (`Require ip 127.0.0.1`) and reload Apache.
Short-Term Hardening:	Enforce cookie-based authentication (`$cfg['Servers'][$i]['auth_type'] = 'cookie'`), set `$cfg['AllowNoPassword'] = false`, and place HTTP Basic Auth in front of `/phpMyAdmin/`.
Long-Term Strategic Fix:	Remove internet/LAN-facing phpMyAdmin installations and perform database administration exclusively over SSH port-forwarding.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.

Verification & Closure Rule:	Request `http://192.168.195.139:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-42 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-43: NFS RPC Service & Export Table Exposed (Ports 111 / 2049) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 2049) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1083 (Discovery — File and Directory Discovery) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1083 (File and Directory Discovery) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-43-83162558D2) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-NFS-EXPORTS-2049 | Advisory: CERT/CC CA-1991-21 / Linux nfs-kernel-server /etc/exports Hardening | CWE: CWE-732 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-732 (Incorrect Permission Assignment) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139:111, 192.168.195.139:2049, 192.168.195.139
Root Cause & 4-Tier Compliance:	Access Control & Network Share Misconfiguration [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening)
Technical Description:	Network File System (NFS) and portmapper services are reachable on TCP ports 111 and 2049 with an exported share entry. Remote filesystem mounting was not executed during the assessment.
Security Risk:	MEDIUM (VALIDATED, CVSS 6.5) — Exposed NFS daemon; if world-readable or no_root_squash exports exist, remote attackers can read or modify host files.
EvidenceCore V3.5 Record:	ID: PROV-F-43-83162558D2 | SHA-256: 83162558d26e1a9f23f9ab97... | HMAC-SHA256: 1879d5a264c542f78ebab0bd... | Module: AutoPentest-Exploit, AutoPentest-PrivEsc

Captured Technical Evidence (F-43):

```
NFS Exports: Nmap scan report for 192.168.195.139
Host is up (0.00s latency).

PORT STATE SERVICE
111/tcp open rpcbind
| nfs-ls: Volume /
| access: Read Lookup Modify Extend Delete NoExecute
| PERMISSION UID GID SIZE TIME
---
NFS Exports: Nmap scan report for 192.168.195.139
Host is up (0.00013s latency).

PORT STATE SERVICE
2049/tcp open nfs
MAC Address: 00:0C:29:05:D7:6A (VMware)
---
NFS service detected. Attackers can enumerate and mount shared directories, potentially accessing
sensitive files or writing SSH keys for privilege escalation.
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Stop the NFS kernel server (`exportfs -ua && service nfs-kernel-server stop`) and remove any wildcard `/ *(rw,no_root_squash)` entry from `/etc/exports`.
Short-Term Hardening:	If NFS is required, export only dedicated non-system directories restricted to specific client IPs with `root_squash,ro,nosuid,nodev` flags.
Long-Term Strategic Fix:	Migrate network file sharing to NFSv4 with Kerberos (`sec=krb5p`) mutual authentication and encryption.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/exports` (`cp -p /etc/exports /etc/exports.bak`) on `192.168.195.139` before removing wildcard `*` / `no_root_squash` shares and running `exportfs -ra`; restore `/etc/exports.bak` if authorized NFS mounts fail.
Verification & Closure Rule:	Run `showmount -e 192.168.195.139` and verify `/` is no longer exported to `*`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-43 on 192.168.195.139:2049 remains OPEN until an automated XStrike re-test executes `Run `showmount -e 192.168.195.139` and verify `/` is no longer exported to `*`.` against `192.168.195.139:2049`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-44: PHP Configuration Diagnostic Page Exposed (/phpinfo.php) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.

7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-PHPINFO-EXPOSED | Advisory: OWASP A01/A05 — Forced Browsing & Diagnostic Page Exposure | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 4 raw observation(s) across 4 unique endpoint(s): http://192.168.195.139:80/phpinfo.php:, http://192.168.195.139:80/icons/:, http://192.168.195.139:80/, http://192.168.195.139:80/phpinfo.php
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The /phpinfo.php diagnostic script is publicly accessible (HTTP 200), exposing PHP runtime settings, environment variables, loaded extensions, and server filesystem paths (consolidated with OWASP A01 forced browsing telemetry).
Security Risk:	MEDIUM (CVSS 5.3) — Environment and configuration disclosure facilitating targeted web exploitation.
EvidenceCore V3.5 Record:	ID: PROV-F-44-2F41BCD36E | SHA-256: 2f41bcd36ea185f6c5d92f40... | HMAC-SHA256: 0071d35f31f154ea0485870a... | Module: AutoPentest-OWASP, AutoPentest-AegisProbe, AutoPentest-PrivEsc

Captured Technical Evidence (F-44):

```
A01 Broken Access Control: 1 finding(s)
[CWE-425] Forced Browsing: /phpinfo.php: Accessible! (200) Content: <!DOCTYPE html PUBLIC "-//W3C//DTD
XHTML 1.0 Transitional//EN" "DTD/xhtml
---
A05 Misconfiguration: 4 finding(s)
[CWE-548] Directory Listing: /icons/: Full directory contents exposed
[CWE-16] HTTP PUT Enabled: Can upload files via PUT method!
[CWE-693] HTTP TRACE Enabled: XST (Cross-Site Tracing) possible
[CWE-200] phpinfo() at /phpinfo.php: Full PHP configuration exposed
---
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "DTD/xhtml1-transitional.dtd">
<html><head>
<style type="text/css">
body {background-color
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Remove `/var/www/phpinfo.php` immediately (`rm -f /var/www/phpinfo.php`) or block `/phpinfo.php` in Apache (`<Location /phpinfo.php> Require all denied </Location>`).
Short-Term Hardening:	Set `disable_functions = phpinfo,exec,passthru,shell_exec,system,proc_open,popen` in `/etc/php5/apache2/php.ini` and reload Apache.
Long-Term Strategic Fix:	Add pre-deployment CI checks that block diagnostic files (`phpinfo.php`, `test.php`, `.env`) from production web roots.

Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Request `http://192.168.195.139:80/phpinfo.php` and confirm HTTP 404 Not Found or 403 Forbidden. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-44 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/phpinfo.php` and confirm HTTP 404 Not Found or 403 Forbidden.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-45: Web Authentication Endpoint Missing Brute-Force Rate Limiting (/dvwa/login.php) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1110.001 (Credential Access — Brute Force: Password Guessing) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1110.001 (Brute Force: Password Guessing) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-NO-RATE-LIMIT | Advisory: OWASP A04:2021 / A07:2021 — Missing Authentication Rate Limiting | CWE: CWE-307 | Taxonomy: OWASP-A04:2021 (Insecure Design) | CWE-307 (Improper Restriction of Excessive Authentication Attempts) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/dvwa/login.php
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	The web login endpoint (/dvwa/login.php) processed rapid consecutive authentication requests without account lockout, throttling, or CAPTCHA challenge (consolidated from OWASP A04 testing).

Security Risk:	MEDIUM — Permits automated high-speed credential stuffing and dictionary brute-force attacks.
EvidenceCore V3.5 Record:	ID: PROV-F-45-76FAD16A68 | SHA-256: 76fad16a68f00707a9b42310... | HMAC-SHA256: 6d4210ebb7f9aa42aeba2699... | Module: AutoPentest-OWASP

Captured Technical Evidence (F-45):

```
A04 Insecure Design: 2 finding(s)
[CWE-209] Verbose Error at /index.php?id='
[CWE-307] No Rate Limiting: /dvwa/login.php
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Enable request rate limiting on `/dvwa/login.php` and authentication routes using Apache `mod_evasive` / `mod_ratelimit` or Fail2Ban.
Short-Term Hardening:	Enforce progressive account lockout (e.g., 5 failed attempts -> 15-minute cooldown) and exponential backoff on authentication endpoints.
Long-Term Strategic Fix:	Integrate centralized identity provider (IdP) authentication with MFA and anomaly-based brute-force protection.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Send 15 rapid failed login POST requests to `/dvwa/login.php` and confirm HTTP 429 Too Many Requests or account lockout triggers. [Target Endpoint: `192.168.195.139:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-45 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Send 15 rapid failed login POST requests to `/dvwa/login.php` and confirm HTTP 429 Too Many Requests or account lockout triggers. [Target Endpoint: `192.168.195.139:80`]` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-46: Administrative Web Interface Reachable Without Network Restriction [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1083 (Discovery — File and Directory Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1083 (File and Directory Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE

Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-ADMIN-EXPOSED | Advisory: OWASP A01:2021 — Administrative Interface Access Control | CWE: CWE-284 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-284 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=90% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 1 unique endpoint(s): http://192.168.195.140:80/Config
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening)
Technical Description:	Administrative web paths (/admin/, /phpMyAdmin/) are reachable over the network without IP allowlisting or VPN segmentation.
Security Risk:	MEDIUM — Expands attack surface for credential stuffing and administrative application exploits.
EvidenceCore V3.5 Record:	ID: PROV-F-46-89FB7378F5 | SHA-256: 89fb7378f57a555337e8dfc2... | HMAC-SHA256: 26fd9cd40c7e7fd15b2e0e3f... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-46):

```
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/: Admin panel accessible
/phpmyadmin/: Admin panel accessible
/cgi-bin/: Admin panel accessible
---
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/admin/: Admin panel accessible
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Restrict `/admin/`, `/phpMyAdmin/`, and `/manager/` URI prefixes to administrative management IPs via Apache `<Location>` access controls.
Short-Term Hardening:	Enforce multi-factor authentication and TLS client certificates on all administrative web consoles.
Long-Term Strategic Fix:	Bind administrative interfaces to an isolated out-of-band management network or VPN.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. [Target Endpoint: `192.168.195.140:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-46 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. [Target Endpoint: `192.168.195.140:80`]` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-47: Deprecated SMBv1 Dialect Enabled on SMB Service (Protocol Hardening Weakness) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 445) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE

Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1210 (Exploitation of Remote Services) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-47-C216181D9C) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-SMBV1-ENABLED | Advisory: Microsoft / Samba SMBv1 Deprecation Advisory (KB2696547 — Distinct from MS17-010) | CWE: CWE-327 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-327 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=68% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=68% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:445
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)
Technical Description:	The SMB service negotiates the deprecated NT LM 0.12 (SMBv1) protocol dialect, which lacks modern pre-authentication integrity and encryption capabilities. Note: SMBv1 dialect negotiation is a protocol hardening weakness (CWE-327, Medium 5.3) and does NOT by itself prove MS17-010 / CVE-2017-0144 (EternalBlue) remote code execution.
Security Risk:	MEDIUM (CVSS 5.3) — Legacy SMBv1 protocol dialect enabled; disable SMBv1 and enforce SMBv2/SMBv3 across all servers.
EvidenceCore V3.5 Record:	ID: PROV-F-47-C216181D9C | SHA-256: c216181d9c3a10f56d50f75b... | HMAC-SHA256: 86a4151d8dac988f0b4a5642... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-47):

```
SMBv1 is enabled — vulnerable to EternalBlue (MS17-010)

Evidence: SMBv1 negotiate response received from 192.168.195.140:445
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Disable SMBv1 protocol negotiation: in Samba `/etc/samba/smb.conf` set `server min protocol = SMB2`; on Windows run `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`.
Short-Term Hardening:	Enforce mandatory SMB packet signing (`server signing = mandatory` in `smb.conf`) and restart `smbd`.
Long-Term Strategic Fix:	Standardize all file shares on SMBv3.1.1 with AES-128-GCM encryption enabled.

Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) on `192.168.195.140` prior to disabling SMBv1 or enforcing `server signing = mandatory`; restore `smb.conf.bak` and restart `smbd` if legacy clients fail.
Verification & Closure Rule:	Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered. [Target Endpoint: `192.168.195.140:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-47 on 192.168.195.140:445 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered. [Target Endpoint: `192.168.195.140:445`]` against `192.168.195.140:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-48: Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE (Unauthenticated HTTP 200) | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: EXPOSED_ADMIN_SURFACE | Privilege: NONE (Unauthenticated HTTP 200) | DataAccess: HTML_LOGIN_OR_INDEX_ONLY | Impact: ADMINISTRATIVE_SURFACE_EXPOSURE | EvidenceConf: 94%
Access Scope Summary:	HTTP 200 administrative interface reachable at /phpMyAdmin/; unauthenticated DB read/write not independently demonstrated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-PHPMYADMIN-EXPOSED | Advisory: phpMyAdmin Documentation — Securing Your phpMyAdmin Installation | CWE: CWE-306 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-306 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.140:80/phpmyadmin/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)

Technical Description:	The phpMyAdmin web interface at http://192.168.195.140:80/phpMyAdmin/ returned HTTP 200. While the administrative interface is reachable without network-layer restriction, unauthenticated database read/write execution was not demonstrated in the captured evidence.
Security Risk:	MEDIUM (VALIDATED EXPOSURE, CVSS 5.3) — Publicly reachable database administration console; exposes backend MySQL authentication surface.
EvidenceCore V3.5 Record:	ID: PROV-F-48-452B111DC8 | SHA-256: 452b111dc8ccb52641e038b0... | HMAC-SHA256: c8d8c353a1cc8bf645a68c18... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-48):

```
[HTTP Probe 200 OK on /phpMyAdmin/ — Exposed administrative web interface; unauthenticated SQL
read/write NOT demonstrated]
Data: <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en" dir="lt
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Restrict `/phpMyAdmin/` in Apache `/etc/apache2/conf.d/phpmyadmin.conf` to localhost or administrative VPN IPs (`Require ip 127.0.0.1`) and reload Apache.
Short-Term Hardening:	Enforce cookie-based authentication (`$cfg['Servers'][$i]['auth_type'] = 'cookie'`), set `$cfg['AllowNoPassword'] = false`, and place HTTP Basic Auth in front of `/phpMyAdmin/`.
Long-Term Strategic Fix:	Remove internet/LAN-facing phpMyAdmin installations and perform database administration exclusively over SSH port-forwarding.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Request `http://192.168.195.140:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-48 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.140:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-49: Permissive Cross-Domain Policy File Exposed (/crossdomain.xml / /clientaccesspolicy.xml) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HTTP-CROSSDOMAIN-POLICY | Advisory: OWASP A05:2021 — Restrict Cross-Domain Policy Wildcards | CWE: CWE-942 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-942 (Permissive Cross-domain Policy with Untrusted Domains) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:80
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Nmap NSE (http-cross-domain-policy) validated an overly permissive wildcard cross-domain or client-access policy file on TCP port 80, allowing untrusted external origins to read application responses.
Security Risk:	MEDIUM — Permits cross-origin data access from untrusted domains.
EvidenceCore V3.5 Record:	ID: PROV-F-49-69FAF702BC | SHA-256: 69faf702bc590702e0516568... | HMAC-SHA256: 8205cb86b044b6be62443de3... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-49):

```
VULNERABLE:
Cross-domain and Client Access policies.
State: VULNERABLE
A cross-domain policy file specifies the permissions that a web client such as Java, Adobe Flash, Adobe Reader,
etc. use to access data across different domains. A client acces policy file is similar to cross-domain policy
but is used for M$ Silverlight applications. Overly permissive configurations enables Cross-site Request Forgery attacks, and may allow third parties to access sensitive dat
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Remove wildcard `<allow-access-from domain="*"/>` directives from `/crossdomain.xml` and `/clientaccesspolicy.xml` on the web root, or delete the policy files if legacy Flash/Silverlight clients are no longer used.
Short-Term Hardening:	Restrict any required cross-domain policy to explicit, trusted internal FQDN origins over HTTPS.
Long-Term Strategic Fix:	Replace legacy cross-domain XML policy files with modern, origin-scoped CORS (`Access-Control-Allow-Origin`) rules.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -i http://192.168.195.140:80/crossdomain.xml` and `nmap -p 80 --script http-cross-domain-policy 192.168.195.140` to confirm wildcard access is removed. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-49 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -i http://192.168.195.140:80/crossdomain.xml` and `nmap -p 80 --script http-cross-domain-policy 192.168.195.140` to confirm wildcard access is removed.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-50: SSLv3 Protocol Enabled — POODLE Padding Oracle Vulnerability (CVE-2014-3566) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 443) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557 (Credential Access — Adversary-in-the-Middle) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1557 (Adversary-in-the-Middle) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: CVE-2014-3566 | Custom ID: XSTRIKE-TLS-POODLE-SSLV3 | Advisory: US-CERT Alert TA14-290A / RFC 7568 Deprecating SSLv3 (CVE-2014-3566) | CWE: CWE-310 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-310 (Cryptographic Issues) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:443
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Nmap NSE (ssl-poodle) confirmed that the HTTPS service on TCP port 443 supports legacy SSLv3 with CBC-mode ciphers, exposing sessions to the POODLE padding oracle information leak (CVE-2014-3566).
Security Risk:	MEDIUM — Active network attackers can force SSLv3 fallback and recover encrypted HTTP session bytes.
EvidenceCore V3.5 Record:	ID: PROV-F-50-79EC8EADDF | SHA-256: 79ec8eaddfa67daab11aadbe... | HMAC-SHA256: 20f4bffba8670852957cfb45... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-50):

```
VULNERABLE:
SSL POODLE information leak
State: VULNERABLE
IDs: CVE:CVE-2014-3566 BID:70574
The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
products, uses nondeterministic CBC padding, which makes it easier
for man-in-the-middle attackers to obtain cleartext data via a
```

```
padding-oracle attack, aka the "POODLE" issue.
Disclosure date: 2014-10-14
Check results:
TLS_RSA_WITH_AES_128_CBC_SHA
References:
htt
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Disable SSLv3 in the HTTPS virtual host configuration (`SSLProtocol all -SSLv2 -SSLv3`) on TCP port 443 and reload the web server.
Short-Term Hardening:	Enable `TLS_FALLBACK_SCSV` support by upgrading OpenSSL to prevent protocol downgrade attacks.
Long-Term Strategic Fix:	Enforce TLS 1.2+ exclusively across all internal and external HTTPS listeners.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/mods-available/ssl.conf` and `/etc/ssl/openssl.cnf` on `192.168.195.140:443` (`cp -p ssl.conf ssl.conf.bak`), validate syntax via `apache2ctl configtest`, and restore `.bak` if TLS handshakes fail.
Verification & Closure Rule:	Run `nmap -p 443 --script ssl-poodle,ssl-enum-ciphers 192.168.195.140` and confirm SSLv3 handshake attempts are rejected. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-50 on 192.168.195.140:443 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 443 --script ssl-poodle,ssl-enum-ciphers 192.168.195.140` and confirm SSLv3 handshake attempts are rejected.` against `192.168.195.140:443`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-51: TLS Ephemeral Diffie-Hellman Weak Key Exchange Parameters (Logjam) [MEDIUM · CVSS 5.3 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 443) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557 (Credential Access — Adversary-in-the-Middle) | Execution State: TECHNIQUE_VALIDATED [TIER_2_PROTOCOL_OR_ACL_VALIDATION] — Technique T1557 (Adversary-in-the-Middle) precondition/protocol flaw deterministically validated via non-destructive probe (PROV-F-51-153B65134F) [PROTOCOL_OR_APPLICATION_INDICATOR_VALIDATED (Non-destructive protocol/ACL/indicator proof; full weaponization withheld per RoE)].
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE

Taxonomy & CVSS v3.1:	CVE: CVE-2015-4000 | Custom ID: XSTRIKE-TLS-WEAK-DH | Advisory: RFC 7919 / Weak Diffie-Hellman and the Logjam Attack (CVE-2015-4000) | CWE: CWE-326 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-326 (Inadequate Encryption Strength) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=52% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=52% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:443
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Nmap NSE (ssl-dh-params) validated that the TLS service on TCP port 443 negotiates DHE cipher suites using weak Diffie-Hellman group parameters (<= 1024-bit).
Security Risk:	MEDIUM — Weak DH group parameters weaken forward secrecy against precomputation downgrade attacks.
EvidenceCore V3.5 Record:	ID: PROV-F-51-153B65134F | SHA-256: 153b65134f4ebf59ef860ffe... | HMAC-SHA256: 0d9c16fa7ec7ebee1bf66773... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-51):

```
VULNERABLE:
Diffie-Hellman Key Exchange Insufficient Group Strength
State: VULNERABLE
Transport Layer Security (TLS) services that use Diffie-Hellman groups
of insufficient strength, especially those using one of a few commonly
shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
WEAK DH GROUP 1
Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
Modulus Type: Safe prime
Modulus Source: mod_ssl 2.2.
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Generate a 2048-bit or 4096-bit Diffie-Hellman parameters file (`openssl dhparam -out /etc/ssl/certs/dhparam.pem 2048`), configure `SSLOpenSSLConfCmd DHParameters` / `SSLCipherSuite` to disable export/1024-bit DHE in Apache SSL config, and prefer ECDHE.
Short-Term Hardening:	Disable all `DHE_EXPORT` and `< 2048-bit` DHE cipher suites on TCP port 443.
Long-Term Strategic Fix:	Standardize TLS configuration on ECDHE (P-256 / X25519) key exchange.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/mods-available/ssl.conf` and `/etc/ssl/openssl.cnf` on `192.168.195.140:443` (`cp -p ssl.conf ssl.conf.bak`), validate syntax via `apache2ctl configtest`, and restore `.bak` if TLS handshakes fail.
Verification & Closure Rule:	Run `nmap -p 443 --script ssl-dh-params 192.168.195.140` and verify no weak DH group parameters are negotiated. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-51 on 192.168.195.140:443 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 443 --script ssl-dh-params 192.168.195.140` and verify no weak DH group parameters are negotiated.` against `192.168.195.140:443`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-52: HTTP Server Slowloris Timeout Heuristic Observed (CVE-2007-6750 Candidate) [MEDIUM · CVSS 5.9 · OBSERVED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1498 (Initial Access — Exploit Public-Facing Application) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1498 (Exploit Public-Facing Application) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: SCANNER_HEURISTIC_UNVERIFIED_BY_SAFETY_ROE | Auth: UNAUTHENTICATED_PROBE | Exploitability: SCANNER_HEURISTIC_UNVERIFIED_BY_SAFETY_ROE | Privilege: NONE | DataAccess: NONE | Impact: POTENTIAL_AVAILABILITY_RISK_UNVERIFIED | EvidenceConf: 58%
Access Scope Summary:	Nmap NSE (http-slowloris-check) reported 'LIKELY VULNERABLE' timeout heuristic; active connection-exhaustion DoS withheld by RoE safety policy
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: CVE-2007-6750 | Custom ID: XSTRIKE-HTTP-SLOWLORIS | Advisory: Apache HTTP Server mod_reqtimeout / Slowloris Mitigation Guideline | CWE: CWE-400 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-400 (Uncontrolled Resource Consumption) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.140:443, 192.168.195.140:8080
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Nmap NSE (http-slowloris-check) reported 'LIKELY VULNERABLE' based on a non-destructive partial-header timeout check on Apache 2.2.8 (CVE-2007-6750). Classified as OBSERVED (SCANNER_HEURISTIC_UNVERIFIED_BY_SAFETY_ROE) because active connection-exhaustion DoS is prohibited by the RoE safety policy.
Security Risk:	MEDIUM (OBSERVED HEURISTIC, CVSS 5.9) — Potential denial-of-service if worker threads are not protected by mod_reqtimeout or a reverse proxy.
EvidenceCore V3.5 Record:	ID: PROV-F-52-8FB6EEF88C | SHA-256: 8fb6eef88cd2d24508e24401... | HMAC-SHA256: 67c84d8ba80e7c80845dd0f6... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-52):

```
VULNERABLE:
Slowloris DOS attack
State: LIKELY VULNERABLE
IDs: CVE:CVE-2007-6750
Slowloris tries to keep many connections to the target web server open and hold
them open as long as possible. It accomplishes this by opening connections to
the target web server and sending a partial request. By doing so, it starves
the http server's resources causing Denial Of Service.

Disclosure date: 2009-09-17
References:
https://cve.mitre.org/cgi-bin
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Enable and configure `mod_reqtimeout` (`RequestReadTimeout header=10-20,MinRate=500 body=20,MinRate=500`) and lower `Timeout 30` in Apache configuration on TCP port 80.
Short-Term Hardening:	Enforce per-IP concurrent connection limits (`mod_qos` / `mod_limitipconn` or reverse-proxy rate limiting).
Long-Term Strategic Fix:	Place an event-driven reverse proxy (Nginx/HAProxy) in front of prefork/worker Apache instances.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `nmap -p 80 --script http-slowloris-check 192.168.195.140` and confirm the server closes stalled partial-header connections within the configured timeout. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-52 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 80 --script http-slowloris-check 192.168.195.140` and confirm the server closes stalled partial-header connections within the configured timeout.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-53: PostgreSQL Database Listener Exposed on Network (TCP Port 5432) [MEDIUM · CVSS 5.3 · OBSERVED]

Target Asset & Port:	192.168.195.1 (Ports: 5432) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1046 (Discovery — Network Service Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1046 (Network Service Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-PGSQL-PORT-EXPOSED | Advisory: PostgreSQL listen_addresses Network Hardening Guideline | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)

Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:5432
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	TCP port 5432 (PostgreSQL) is reachable over the network. Unauthenticated or default-credential login was not demonstrated on this host; classified as OBSERVED service exposure.
Security Risk:	MEDIUM (OBSERVED) — Network-accessible database port increases brute-force and protocol attack surface.
EvidenceCore V3.5 Record:	ID: PROV-F-53-5A200F9483 | SHA-256: 5a200f94837b80b95479bdc2... | HMAC-SHA256: 1afdcb3ca103d665c51c968d... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-53):

```
[2026-10-31 08:16:06] PostgreSQL database service on 192.168.195.1:5432.
Service: postgresql, Product: PostgreSQL DB, Version: 9.6.0 or later
Database exposed on network. Default credential testing pending.
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:5432 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Bind PostgreSQL to `127.0.0.1` (`listen_addresses = 'localhost'` in `postgresql.conf`) and restrict TCP port 5432 via host firewall rules to authorized application servers only.
Short-Term Hardening:	Enforce `scram-sha-256` authentication and TLS client connections (`hostssl`) in `pg_hba.conf`.
Long-Term Strategic Fix:	Place all database listeners in an isolated database VLAN with zero direct routing from user/workstation segments.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Verify the active PostgreSQL `data_directory` and `hba_file` path on `192.168.195.1:5432` (`SHOW hba_file;`) before backing up `pg_hba.conf` and `postgresql.conf`; reload PostgreSQL to revert if needed.
Verification & Closure Rule:	Run `nmap -p 5432 <host>` from the assessment subnet and confirm TCP port 5432 is `closed` or `filtered`. [Target Endpoint: `192.168.195.1:5432`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-53 on 192.168.195.1:5432 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 5432 <host>` from the assessment subnet and confirm TCP port 5432 is `closed` or `filtered`. [Target Endpoint: `192.168.195.1:5432`]` against `192.168.195.1:5432`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-54: End-of-Life OpenSSH 4.7p1 (Debian-8ubuntu1) Service Banner Observed (TCP Port 22) [MEDIUM · CVSS 5.3 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 22) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1021.004 (Lateral Movement — Remote Services: SSH) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1021.004 (Remote Services: SSH) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.

7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1 | Inferred: OpenSSH 4.7p1 (Debian-8ubuntu1) | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: Debian/Ubuntu backport package (Debian-8ubuntu1): upstream OpenSSH version number is frozen while security patches are backported into the distribution package revision. | CVE Applicability: CONDITIONAL_ON_PACKAGE_AUDIT (Verify distribution patch level via dpkg -l openssh-server before asserting CVE applicability)
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-OPENSSH-EOL-47P1 | Advisory: OpenSSH Legacy Lifecycle & Backported Patch Verification Advisory | CWE: CWE-1104 | Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) | CWE-1104 (Use of Unmaintained Third Party Components) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:22
Root Cause & 4-Tier Compliance:	Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The SSH daemon on 192.168.195.139:22 returned service banner 'SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1'. Because Debian/Ubuntu distributions backport security fixes into package revisions (Debian-8ubuntu1) without incrementing the upstream OpenSSH version string, specific upstream CVEs are not asserted without authenticated package inventory verification (`dpkg -l openssh-server`).
Security Risk:	MEDIUM (OBSERVED) — Legacy SSH daemon version; verify distribution backported patches or upgrade OS.
EvidenceCore V3.5 Record:	ID: PROV-F-54-568A2A697C | SHA-256: 568a2a697c9b8cc6251a8cdc... | HMAC-SHA256: dd675a282f14d5d6439ca375... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-54):

```
Legacy OpenSSH versions vulnerable to information leak and authentication bypass

Evidence: Banner match on 192.168.195.139:22: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Restrict SSH access on port 22 to authorized management IPs via host firewall (`ufw allow from <mgmt_subnet> to any port 22`) and verify the installed package revision (`dpkg -l openssh-server` / `apt-cache policy openssh-server`) to establish Debian/Ubuntu backport patch status before scheduling daemon upgrades.
Short-Term Hardening:	Disable legacy CBC ciphers, weak KEX algorithms, and password authentication (`PasswordAuthentication no`) in `/etc/ssh/sshd_config` after confirming distribution package patch levels.
Long-Term Strategic Fix:	Plan a controlled OS lifecycle migration to a supported LTS release with modern OpenSSH (>= 9.x).
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/ssh/sshd_config` (`cp -p /etc/ssh/sshd_config /etc/ssh/sshd_config.bak`) on `192.168.195.139`, validate syntax via `sshd -t` before reloading `sshd`, and keep an active root/admin terminal open during reload to prevent lockout.

Verification & Closure Rule:	Run `nmap -sV -p 22 --script ssh2-enum-algos 192.168.195.139` and confirm hardened KEX/cipher suites and authorized-subnet-only reachability. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-54 on 192.168.195.139:22 remains OPEN until an automated XStrike re-test executes `Run `nmap -sV -p 22 --script ssh2-enum-algos 192.168.195.139` and confirm hardened KEX/cipher suites and authorized-subnet-only reachability.` against `192.168.195.139:22`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-55: Java RMI Registry Exposed on Network (TCP Port 1099) [MEDIUM · CVSS 5.3 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 1099) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1210 (Exploitation of Remote Services) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-JAVA-RMI-1099 | Advisory: Oracle Java RMI / GNU Classpath grmiregistry Deserialization Exposure | CWE: CWE-502 | Taxonomy: OWASP-A08:2021 (Software and Data Integrity Failures) | CWE-502 (Deserialization of Untrusted Data) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:1099
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization)
Technical Description:	GNU Classpath grmiregistry listener is exposed on TCP port 1099; remote class loading or deserialization payload execution was not performed.
Security Risk:	MEDIUM (OBSERVED) — Exposed Java RMI registry surface susceptible to insecure deserialization if default class loaders are active.
EvidenceCore V3.5 Record:	ID: PROV-F-55-AF8D5282A0 | SHA-256: af8d5282a0995a393a7af9fc... | HMAC-SHA256: f1045d554639f445982e6790... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-55):

```
Java RMI exploitable: Nmap scan report for 192.168.195.139
Host is up (0.00s latency).

PORT STATE SERVICE
```

```
1099/tcp open rmiregistry
| rmi-vuln-classloader:
| VULNERABLE:
| RMI registry default configuration remote code execution vulnerability
|
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Stop the `grmiregistry` / Java RMI daemon listening on TCP port 1099 and block port 1099 at the host firewall (`iptables -A INPUT -p tcp --dport 1099 -j DROP`).
Short-Term Hardening:	If Java RMI is required locally, bind it strictly to `127.0.0.1` and enable JEP 290 serialization filtering (`jdk.serialFilter`).
Long-Term Strategic Fix:	Decommission legacy Java RMI services in favor of mutually authenticated TLS APIs.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Record the active JVM process command line (`ps -ef | grep rmi`) and backup the RMI service init script on `192.168.195.139` before stopping port 1099 or binding RMI to `127.0.0.1`.
Verification & Closure Rule:	Run `nmap -p 1099 192.168.195.139` and confirm TCP port 1099 is `closed` or `filtered`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-55 on 192.168.195.139:1099 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 1099 192.168.195.139` and confirm TCP port 1099 is `closed` or `filtered`.` against `192.168.195.139:1099`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-56: MySQL Database Listener Exposed on Network (TCP Port 3306) [MEDIUM · CVSS 5.3 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 3306) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1046 (Discovery — Network Service Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1046 (Network Service Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-MYSQL-PORT-EXPOSED | Advisory: MySQL bind-address Network Exposure Guideline | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:3306
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	MySQL 5.0.51a database listener is reachable on TCP port 3306; unauthenticated login was not demonstrated during the assessment.
Security Risk:	MEDIUM (OBSERVED) — Network-accessible database port increases brute-force and protocol attack surface.
EvidenceCore V3.5 Record:	ID: PROV-F-56-4FAEFAE906 | SHA-256: 4faefae90649af1929b0b636... | HMAC-SHA256: dcaaa082b76cec0c99e6c033... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-56):

```
[2026-10-31 08:03:49] MySQL database service on 192.168.195.139:3306.
Service: mysql, Product: MySQL, Version: 5.0.51a-3ubuntu5
Database exposed on network. Default credential testing pending.
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Bind MySQL to `127.0.0.1` (`bind-address = 127.0.0.1` in `/etc/mysql/my.cnf`) and restart `mysqld` so TCP port 3306 is not exposed to the network.
Short-Term Hardening:	Remove anonymous MySQL accounts, require strong passwords for `root@localhost`, and revoke remote root login (`DELETE FROM mysql.user WHERE User='root' AND Host NOT IN ('localhost', '127.0.0.1')`).
Long-Term Strategic Fix:	Upgrade MySQL 5.0.51a to MySQL 8.0 LTS or MariaDB 10.11 LTS.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/mysql/my.cnf` (`cp -p /etc/mysql/my.cnf /etc/mysql/my.cnf.bak`) on `192.168.195.139` before setting `bind-address = 127.0.0.1`; restore `my.cnf.bak` and restart `mysql` if dependent application database connections fail.
Verification & Closure Rule:	Run `nmap -p 3306 192.168.195.139` from the network and confirm port 3306 is `closed` or `filtered`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-56 on 192.168.195.139:3306 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 3306 192.168.195.139` from the network and confirm port 3306 is `closed` or `filtered`.` against `192.168.195.139:3306`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-57: VNC Remote Desktop Service Exposed on TCP Port 5900 (Protocol 3.3) [MEDIUM · CVSS 5.3 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 5900) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.

4-State MITRE Provenance:	MITRE: T1021.001 (Lateral Movement — Remote Services: Remote Desktop Protocol) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1021.001 (Remote Services: Remote Desktop Protocol) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-VNC-5900 | Advisory: RFB Protocol 3.3 VNC Authentication & Encryption Guideline | CWE: CWE-287 | Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) | CWE-287 (Improper Authentication) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:5900
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	VNC remote desktop service on TCP port 5900 was fingerprinted (RFB protocol 3.3); authentication bypass or password brute-forcing was not executed.
Security Risk:	MEDIUM (OBSERVED) — Exposed remote desktop protocol on internal subnet.
EvidenceCore V3.5 Record:	ID: PROV-F-57-B16041181F | SHA-256: b16041181f4a6af50f4e7e61... | HMAC-SHA256: bef91279f047953ed0999c0c... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-57):

```
VNC RealVNC allows authentication bypass via modified client

Evidence: Banner match on 192.168.195.139:5900: RFB 003.003
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Stop the VNC server on TCP port 5900 (`vncserver -kill :0`) and block port 5900 at the host firewall.
Short-Term Hardening:	If VNC is required, bind `Xvnc` to `-localhost` only, enforce a strong VNC password, and tunnel access exclusively over SSH.
Long-Term Strategic Fix:	Upgrade from legacy RFB 3.3 to modern remote management with MFA.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup VNC startup/service configuration (`~/.vnc/xstartup`, `/etc/vnc.conf`, or `/etc/init.d/vncserver`) on `192.168.195.139` prior to stopping the Xvnc listener on TCP port 5900; restart `vncserver -localhost` if local console GUI access must be restored.

Verification & Closure Rule:	Run `nmap -p 5900 192.168.195.139` from the subnet and confirm port 5900 is `closed`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-57 on 192.168.195.139:5900 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 5900 192.168.195.139` from the subnet and confirm port 5900 is `closed`.` against `192.168.195.139:5900`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-58: X11 Display Server Listener Exposed (TCP Port 6000) [MEDIUM · CVSS 5.3 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 6000) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1113 (Collection — Screen Capture) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1113 (Screen Capture) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-X11-PORT-6000 | Advisory: X.Org X11 Server -nolisten tcp Hardening Guideline | CWE: CWE-306 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-306 (Missing Authentication for Critical Function) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:6000
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	X11 display server TCP port 6000 is open; unauthenticated display capture or keystroke logging was not verified via x11-access.
Security Risk:	MEDIUM (OBSERVED) — Exposed X11 TCP listener on port 6000.
EvidenceCore V3.5 Record:	ID: PROV-F-58-155E6C54C9 | SHA-256: 155e6c54c9798345c6a215d4... | HMAC-SHA256: 4ac46e0be58eda8c64bee6a4... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-58):

```
X11 no-auth! Can capture display. Nmap scan report for 192.168.195.139
Host is up (0.00s latency).

PORT STATE SERVICE
6000/tcp open X11
MAC Address: 00:0C:29:05:D
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Disable X11 TCP listening by adding `-nolisten tcp` to the X server startup configuration (`/etc/X11/xinit/xserverrc` or display manager config) and block TCP port 6000.
Short-Term Hardening:	Terminate any unauthenticated Xvfb/X11 server processes on headless server hosts.
Long-Term Strategic Fix:	Remove X11 desktop packages from server base images.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup X11 display manager configuration (`/etc/X11/xinit/xserverrc` or `/etc/gdm/gdm.schemas`) on `192.168.195.139` prior to adding `-nolisten tcp`; restore the `.bak` file if local X11 session initialization fails.
Verification & Closure Rule:	Run `nmap -p 6000 192.168.195.139` and confirm port 6000 is `closed`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-58 on 192.168.195.139:6000 remains OPEN until an automated XStrike re-test executes `Run `nmap -p 6000 192.168.195.139` and confirm port 6000 is `closed`.` against `192.168.195.139:6000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-59: End-of-Life OpenSSH 5.3p1 (Debian-3ubuntu4) Service Banner Observed (TCP Port 22) [MEDIUM · CVSS 5.3 · OBSERVED]

Target Asset & Port:	192.168.195.140 (Ports: 22) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (REMEDIATION_INCONCLUSIVE (REJECTED_HOST_OFFLINE)) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1021.004 (Lateral Movement — Remote Services: SSH) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1021.004 (Remote Services: SSH) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: SSH-2.0-OpenSSH_5.3p1 Debian-3ubuntu4 | Inferred: OpenSSH 5.3p1 (Debian-3ubuntu4) | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: Debian/Ubuntu backport package (Debian-3ubuntu4): upstream OpenSSH version number is frozen while security patches are backported into the distribution package revision. | CVE Applicability: CONDITIONAL_ON_PACKAGE_AUDIT (Verify distribution patch level via dpkg -l openssh-server before asserting CVE applicability)
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-OPENSSH-EOL-53P1 | Advisory: OpenSSH Legacy Lifecycle & Backported Patch Verification Advisory | CWE: CWE-1104 | Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) | CWE-1104 (Use of Unmaintained Third Party Components) | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)

Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:22
Root Cause & 4-Tier Compliance:	Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The SSH daemon on 192.168.195.140:22 returned service banner 'SSH-2.0-OpenSSH_5.3p1 Debian-3ubuntu4'. Because Debian/Ubuntu distributions backport security fixes into package revisions (Debian-3ubuntu4) without incrementing the upstream OpenSSH version string, specific upstream CVEs are not asserted without authenticated package inventory verification (`dpkg -l openssh-server`).
Security Risk:	MEDIUM (OBSERVED) — Legacy SSH daemon version; verify distribution backported patches or upgrade OS.
EvidenceCore V3.5 Record:	ID: PROV-F-59-A55DB8D089 | SHA-256: a55db8d08921aa41ecb08bca... | HMAC-SHA256: e2b26ef8d4c55fde69a2d8f7... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-59):

```
Legacy OpenSSH versions vulnerable to information leak and authentication bypass

Evidence: Banner match on 192.168.195.140:22: SSH-2.0-OpenSSH_5.3p1 Debian-3ubuntu4
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Restrict SSH access on port 22 to authorized management IPs via host firewall (`ufw allow from <mgmt_subnet> to any port 22`) and verify the installed package revision (`dpkg -l openssh-server` / `apt-cache policy openssh-server`) to establish Debian/Ubuntu backport patch status before scheduling daemon upgrades.
Short-Term Hardening:	Disable legacy CBC ciphers, weak KEX algorithms, and password authentication (`PasswordAuthentication no`) in `/etc/ssh/sshd_config` after confirming distribution package patch levels.
Long-Term Strategic Fix:	Plan a controlled OS lifecycle migration to a supported LTS release with modern OpenSSH (>= 9.x).
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/ssh/sshd_config` (`cp -p /etc/ssh/sshd_config /etc/ssh/sshd_config.bak`) on `192.168.195.140`, validate syntax via `sshd -t` before reloading `sshd`, and keep an active root/admin terminal open during reload to prevent lockout.
Verification & Closure Rule:	Run `nmap -sV -p 22 --script ssh2-enum-algos 192.168.195.140` and confirm hardened KEX/cipher suites and authorized-subnet-only reachability. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-59 on 192.168.195.140:22 remains OPEN until an automated XStrike re-test executes `Run `nmap -sV -p 22 --script ssh2-enum-algos 192.168.195.140` and confirm hardened KEX/cipher suites and authorized-subnet-only reachability.` against `192.168.195.140:22`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-60: Developer / Debugging Comments Exposed in HTML/JS Source [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.

4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-ZAP-COMMENTS | Advisory: OWASP ZAP Alert 10027 — Information Disclosure: Suspicious Comments | CWE: CWE-615 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-615 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=90% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 10 raw observation(s) across 1 unique endpoint(s): 192.168.195.1
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTML and JavaScript responses contain developer comments that may disclose internal application logic, hints, or endpoints.
Security Risk:	LOW — Information disclosure in client-accessible markup.
EvidenceCore V3.5 Record:	ID: PROV-F-60-6C8D8F98E5 | SHA-256: 6c8d8f98e59338e3bb226f82... | HMAC-SHA256: 1712beb9f4eb2899ed9f3751... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-60):

```
The response appears to contain suspicious comments which may help an attacker.
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Strip developer, TODO, and debugging HTML/JS comments from production templates in `/var/www/`.
Short-Term Hardening:	Audit client-side HTML and JavaScript files to ensure no hints, credentials, or internal SQL queries are embedded in comments.
Long-Term Strategic Fix:	Add HTML/JS minification that strips comments in the build pipeline.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.

Verification & Closure Rule:	Inspect page source via `curl -s` and confirm developer/debugging comments are removed. [Target Endpoint: `192.168.195.1:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-60 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Inspect page source via `curl -s` and confirm developer/debugging comments are removed. [Target Endpoint: `192.168.195.1:80`]` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-61: HTTP Permissions-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-PERMISSIONS-POLICY | Advisory: W3C Permissions Policy Specification | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 (Protection Mechanism Failure) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit the 'Permissions-Policy' (formerly Feature-Policy) header, leaving browser APIs (camera, microphone, geolocation, payment) unrestricted at the document policy layer.
Security Risk:	LOW — Defense-in-depth browser hardening omission; does not directly enable remote code execution.
EvidenceCore V3.5 Record:	ID: PROV-F-61-9B6D602736 | SHA-256: 9b6d6027369ae4c50fdc5b87... | HMAC-SHA256: 692d34370f7758e59bfd8df1... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-61):

```
Missing header: Permissions-Policy | CWE: CWE-732 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Add `Header always set Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=(), usb=()"` in the web server configuration.
Short-Term Hardening:	Audit frontend application requirements and explicitly disable all unused browser hardware/sensor APIs.
Long-Term Strategic Fix:	Enforce `Permissions-Policy` alongside CSP in automated HTTP security header regression tests.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.1:8000/` and confirm the `Permissions-Policy` header is present. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-61 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.1:8000/` and confirm the `Permissions-Policy` header is present.` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-62: HTTP Referrer-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-REFERRER-POLICY | Advisory: W3C Referrer Policy / OWASP Secure Headers | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)

Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit the 'Referrer-Policy' header, which may cause full URLs (including query parameters) to be leaked in the Referer header during cross-origin navigation.
Security Risk:	LOW — Potential disclosure of sensitive URL paths or query parameters to third-party origins.
EvidenceCore V3.5 Record:	ID: PROV-F-62-4D3954EE1B | SHA-256: 4d3954ee1be933c1fa96ad77... | HMAC-SHA256: c27bb59c87da4ca1f9bf5f74... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-62):

```
Missing header: Referrer-Policy | CWE: CWE-200 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Add `Header always set Referrer-Policy "strict-origin-when-cross-origin"` in Apache `/etc/apache2/conf.d/security` or Nginx configuration. (Note: On `192.168.195.1:8000`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Ensure sensitive tokens or session identifiers are never passed in URL query strings where they could leak via Referer headers.
Long-Term Strategic Fix:	Include `Referrer-Policy` in baseline web security header automated tests.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.1:8000/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-62 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.1:8000/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned.` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-63: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%

Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-SERVER-BANNER | Advisory: Apache ServerTokens Prod / CIS Web Server Hardening | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 55 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints.
Security Risk:	LOW — Facilitates precise vulnerability fingerprinting by external adversaries.
EvidenceCore V3.5 Record:	ID: PROV-F-63-4EF53AC123 | SHA-256: 4ef53ac12322b6d32310c261... | HMAC-SHA256: d43ee1cdc064ac1a46cc7ed0... | Module: AutoPentest-ZAP, AutoPentest-AegisProbe

Captured Technical Evidence (F-63):

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
---
Server: Splunkd | CWE: CWE-200 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). (Note: On `192.168.195.1:8000`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Configure reverse-proxy header sanitization to strip detailed upstream server version banners.
Long-Term Strategic Fix:	Maintain automated configuration management to prevent verbose banner headers in production.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.1:8000/` and confirm `Server: Apache` returns no version or OS string. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-63 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.1:8000/` and confirm `Server: Apache` returns no version or OS string.` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-64: HTTP Strict-Transport-Security (HSTS) Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)

Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557 (Credential Access — Adversary-in-the-Middle) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1557 (Adversary-in-the-Middle) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-HSTS-MISSING | Advisory: RFC 6797 / OWASP HTTP Strict Transport Security Cheat Sheet | CWE: CWE-319 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-319 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 4 raw observation(s) across 3 unique endpoint(s): 192.168.195.1:8080, 192.168.195.1, 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)
Technical Description:	HTTP/HTTPS responses omit the 'Strict-Transport-Security' header, allowing clients to connect over unencrypted HTTP and exposing sessions to SSL-stripping attacks.
Security Risk:	LOW — Enables protocol downgrade and cleartext session interception on untrusted networks.
EvidenceCore V3.5 Record:	ID: PROV-F-64-1C1640C0A7 | SHA-256: 1c1640c0a70976c844ec9833... | HMAC-SHA256: 1fdbf97cd0c96e13c927090e... | Module: XStrike-BuiltinVuln, AutoPentest-OWASP, AutoPentest-AegisProbe

Captured Technical Evidence (F-64):

```
No HSTS header — susceptible to SSL stripping attacks

Evidence: HTTP response from 192.168.195.1:8080 missing strict-transport-security header
---
A02 Cryptographic Failures: 1 finding(s)
[CWE-693] Missing Security Headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options
---
A02 Cryptographic Failures: 1 finding(s)
[CWE-693] Missing Security Headers: Strict-Transport-Security, Content-Security-Policy
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Configure TLS (HTTPS) on port 443 and add `Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"` to the HTTPS virtual host.

Short-Term Hardening:	Configure HTTP port 80 to issue permanent `301 Moved Permanently` redirects to `https://` for all endpoints.
Long-Term Strategic Fix:	Standardize internal PKI certificate automation (ACME/step-ca) across all web services.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Inspect HTTPS response headers via `curl -I https://192.168.195.1:443/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-64 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Inspect HTTPS response headers via `curl -I https://192.168.195.1:443/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`.` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-65: Session Cookie Missing 'HttpOnly' Flag [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-COOKIE-HTTPONLY | Advisory: OWASP Session Management Cheat Sheet — HttpOnly | CWE: CWE-1004 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-1004 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 80 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8000

Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Cookies are set without the 'HttpOnly' flag, permitting client-side JavaScript ('document.cookie') to read session identifiers.
Security Risk:	LOW — Enables session theft if combined with a Cross-Site Scripting (XSS) vulnerability.
EvidenceCore V3.5 Record:	ID: PROV-F-65-811C0B0C8D | SHA-256: 811c0b0c8dd7dc5934aee528... | HMAC-SHA256: 040b55082d47797a5b398ca6... | Module: AutoPentest-ZAP, AutoPentest-AegisProbe

Captured Technical Evidence (F-65):

```
A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by
JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be
---
Cookie: cval=1915971765... | CWE: CWE-1004 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Set `session.cookie_httponly = 1` in `/etc/php5/apache2/php.ini` and add `HttpOnly` to all application `setcookie()` calls. (Note: On `192.168.195.1:8000`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Add Apache header rewrite `Header edit Set-Cookie ^(.*)$ "$1; HttpOnly"` for legacy applications.
Long-Term Strategic Fix:	Enforce automated DAST checks verifying `HttpOnly` on all session identifiers.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present. [Target Endpoint: `192.168.195.1:8000`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-65 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present. [Target Endpoint: `192.168.195.1:8000`]` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-66: Session Cookie Missing 'SameSite' Attribute [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%

Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-COOKIE-SAMESITE | Advisory: RFC 6265bis — SameSite Cookie Attribute | CWE: CWE-352 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-352 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 220 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Session cookies are issued without the 'SameSite=Lax' or 'SameSite=Strict' attribute, allowing cookies to be transmitted in cross-origin requests.
Security Risk:	LOW — Weakens browser defense against Cross-Site Request Forgery (CSRF).
EvidenceCore V3.5 Record:	ID: PROV-F-66-AFBCB2DA9C | SHA-256: afbcb2da9cf03106737efcc0... | HMAC-SHA256: 77cd896de0a225f8ecbf5055... | Module: AutoPentest-ZAP, AutoPentest-AegisProbe

Captured Technical Evidence (F-66):

```
A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result
of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-sit
---
Cookie: cval | CWE: CWE-352 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Update PHP/application session configuration (`session.cookie_samesite = "Lax"` or `"Strict"`) or add Apache `Header edit Set-Cookie ^(.*)$ "$1; SameSite=Lax"`.
Short-Term Hardening:	Audit cross-site authentication flows and enforce `SameSite=Strict` on high-privilege session cookies.
Long-Term Strategic Fix:	Standardize session management using framework-managed `__Host-` prefixed cookies.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present. [Target Endpoint: `192.168.195.1:8000`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-66 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present. [Target Endpoint: `192.168.195.1:8000`]` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-67: Unix Timestamp Disclosure in HTTP Response Content [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-ZAP-TIMESTAMP | Advisory: OWASP ZAP Alert 10096 — Timestamp Disclosure | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 288 raw observation(s) across 1 unique endpoint(s): 192.168.195.1
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	OWASP ZAP identified Unix epoch timestamps embedded within HTTP response bodies/headers across multiple application endpoints.
Security Risk:	LOW — Minor informational leakage of server clock or cache generation timestamps.
EvidenceCore V3.5 Record:	ID: PROV-F-67-F2BAB6E0D8 | SHA-256: f2bab6e0d816d29f5eafe28c... | HMAC-SHA256: 4db73662c17ca6c5f7dc3232... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-67):

```
A timestamp was disclosed by the application/web server. - Unix
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Configure ETag generation to exclude inode/mtime timestamps (`FileETag None` in Apache) and remove Unix epoch values from unauthenticated HTML responses.
Short-Term Hardening:	Ensure static asset cache keys use content hashes rather than server timestamps.
Long-Term Strategic Fix:	Standardize response header normalization across web servers.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)

Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Inspect HTTP response headers and body for 10-digit Unix epoch patterns and confirm none are disclosed. [Target Endpoint: `192.168.195.1:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-67 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Inspect HTTP response headers and body for 10-digit Unix epoch patterns and confirm none are disclosed. [Target Endpoint: `192.168.195.1:80`]` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-68: Verbose Content Body Returned in HTTP Redirect Response (Big Redirect) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-ZAP-BIG-REDIRECT | Advisory: OWASP ZAP Alert 10044 — Big Redirect Detected | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 74 raw observation(s) across 1 unique endpoint(s): 192.168.195.1
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP 3xx redirect responses contain a larger-than-expected HTML body, which may indicate page content is rendered despite a redirect header.
Security Risk:	LOW — Verify that unauthenticated redirects call 'exit()' immediately after setting the Location header.

EvidenceCore V3.5 Record:	ID: PROV-F-68-42A8267EC0 | SHA-256: 42a8267ec020ff2abc4be476... | HMAC-SHA256: 275c3ca4e3f2493ee4601d91... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-68):

```
The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensi
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Ensure all PHP authentication/redirect handlers call `exit;` immediately after `header('Location: ...');` so authenticated page content is not rendered in the 301/302 body.
Short-Term Hardening:	Audit all 3xx responses across Mutillidae/DVWA/phpMyAdmin to ensure response bodies contain zero sensitive HTML.
Long-Term Strategic Fix:	Use centralized router middleware for HTTP redirects.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Issue `curl -i http://192.168.195.1:80/<redirect_path>` and confirm the 302 response body length is minimal with no sensitive HTML. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-68 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Issue `curl -i http://192.168.195.1:80/<redirect_path>` and confirm the 302 response body length is minimal with no sensitive HTML.` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-69: Web Server Directory Listing Enabled (/icons/ & Static Directories) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1083 (Discovery — File and Directory Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1083 (File and Directory Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-DIR-LISTING | Advisory: Apache Options -Indexes Hardening Guideline | CWE: CWE-548 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-548 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, http://192.168.195.1:80/images/:
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Web server directories (such as /icons/) return an auto-generated directory index listing internal files (consolidated with OWASP A05 misconfiguration checks).
Security Risk:	LOW — Enables unauthenticated enumeration of static and backup files.
EvidenceCore V3.5 Record:	ID: PROV-F-69-09B9673269 | SHA-256: 09b9673269df8cf6ea41ab3d... | HMAC-SHA256: 4bf43b4ce8a94498560c445c... | Module: AutoPentest-ZAP, AutoPentest-OWASP

Captured Technical Evidence (F-69):

```
It is possible to view the directory listing. Directory listing may reveal hidden scripts, include
files, backup source files, etc. which can be accessed to read sensitive information.
---
It is possible to view a listing of the directory contents. Directory listings may reveal hidden
scripts, include files, backup source files, etc., which can be accessed to reveal sensitive informatio
---
A05 Misconfiguration: 2 finding(s)
[CWE-548] Directory Listing: /images/: Full directory contents exposed
[CWE-693] HTTP TRACE Enabled: XST (Cross-Site Tracing) possible
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Disable directory indexing in Apache `/etc/apache2/apache2.conf` and `/etc/apache2/mods-enabled/alias.conf` by setting `Options -Indexes` on `/var/www/` and `/usr/share/apache2/icons/`. (Note: On `192.168.195.1:80`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Remove default Apache `/icons/` alias or restrict it to specific file extensions.
Long-Term Strategic Fix:	Enforce `Options -Indexes` in baseline web server hardening templates.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Request `http://192.168.195.1:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-69 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.1:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`.` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-70: X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 80) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE

Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-XCTO-MISSING | Advisory: OWASP Secure Headers Project — X-Content-Type-Options | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 45 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8080
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit 'X-Content-Type-Options: nosniff', allowing browsers to MIME-sniff response bodies into executable content types.
Security Risk:	LOW — Browser MIME-type guessing can facilitate content-spoofing or stored XSS in uploaded content.
EvidenceCore V3.5 Record:	ID: PROV-F-70-0DEAB9B942 | SHA-256: 0deab9b942b7379dd9e6c485... | HMAC-SHA256: 31e02ca74eab808355aa92b2... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln

Captured Technical Evidence (F-70):

```
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older
versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially cau
---
No X-Content-Type-Options header — MIME sniffing not prevented

Evidence: HTTP response from 192.168.195.1:8080 missing x-content-type-options header
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:80 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Add `Header always set X-Content-Type-Options "nosniff"` in the web server configuration (`apache2.conf` / `nginx.conf`).
Short-Term Hardening:	Ensure all static and dynamic responses set explicit, accurate `Content-Type` MIME headers.
Long-Term Strategic Fix:	Include `X-Content-Type-Options: nosniff` in baseline infrastructure-as-code web templates.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)

Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.1:80/` and verify `X-Content-Type-Options: nosniff` is present on all responses. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-70 on 192.168.195.1:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.1:80/` and verify `X-Content-Type-Options: nosniff` is present on all responses.` against `192.168.195.1:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-71: robots.txt Disallows Sensitive Web Paths [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.1 (Ports: 8000) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: REMEDIATION_VERIFIED (REMEDIATION_VERIFIED (CHG-2026-1031-002)) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-ROBOTS-TXT | Advisory: OWASP WSTG-INFO-03 — Review Webserver Metafiles for Information Leakage | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 (Exposure of Sensitive Information) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The /robots.txt file is publicly readable and lists internal or administrative URI paths intended to be hidden from search crawlers.
Security Risk:	LOW — Provides attackers with a reconnaissance map of internal application directories.

EvidenceCore V3.5 Record:	ID: PROV-F-71-D430CB0DB2 | SHA-256: d430cb0db2e09277de6361de... | HMAC-SHA256: ab6127786bd00cffbdb82643... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-71):

```
User-agent: *
Disallow: /
| CWE: CWE-200 | Payload:
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:8000 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Remove sensitive administrative or internal path entries from `/var/www/robots.txt` and enforce proper authentication on every sensitive directory.
Short-Term Hardening:	Use `<meta name="robots" content="noindex, nofollow">` inside authenticated pages rather than listing secret paths in a public `robots.txt`.
Long-Term Strategic Fix:	Audit all Paths formerly listed in `robots.txt` to ensure none rely on security-by-obscurity.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.1:8000` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.1` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Fetch `http://192.168.195.1:8000/robots.txt` and verify no sensitive internal directories are enumerated. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-71 on 192.168.195.1:8000 remains OPEN until an automated XStrike re-test executes `Fetch `http://192.168.195.1:8000/robots.txt` and verify no sensitive internal directories are enumerated.` against `192.168.195.1:8000`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-72: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.129 (Ports: 80) | Asset Class: Application / Network Host (STANDARD)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-SERVER-BANNER | Advisory: Apache ServerTokens Prod / CIS Web Server Hardening | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.129
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints.
Security Risk:	LOW — Facilitates precise vulnerability fingerprinting by external adversaries.
EvidenceCore V3.5 Record:	ID: PROV-F-72-CE4445F490 | SHA-256: ce4445f4909c6cccd341c16a... | HMAC-SHA256: b0b019618aa8c58a129fe018... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-72):

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
```

Target Environment Profile:	LAN Endpoint (192.168.195.129:80 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). (Note: On `192.168.195.129:80`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Configure reverse-proxy header sanitization to strip detailed upstream server version banners.
Long-Term Strategic Fix:	Maintain automated configuration management to prevent verbose banner headers in production.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.129:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.129` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.129:80/` and confirm `Server: Apache` returns no version or OS string. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-72 on 192.168.195.129:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.129:80/` and confirm `Server: Apache` returns no version or OS string.` against `192.168.195.129:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-73: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.130 (Ports: 80) | Asset Class: Workstation / SMB Peer Host (STANDARD)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.

7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-SERVER-BANNER | Advisory: Apache ServerTokens Prod / CIS Web Server Hardening | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.130
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints.
Security Risk:	LOW — Facilitates precise vulnerability fingerprinting by external adversaries.
EvidenceCore V3.5 Record:	ID: PROV-F-73-826FB45C98 | SHA-256: 826fb45c98432eac1d3034cb... | HMAC-SHA256: b696a7a97904b29ca54d4db3... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-73):

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
```

Target Environment Profile:	LAN Endpoint (192.168.195.130:80 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). (Note: On `192.168.195.130:80`, verify the active web server/gateway configuration file prior to applying directives.)
Short-Term Hardening:	Configure reverse-proxy header sanitization to strip detailed upstream server version banners.
Long-Term Strategic Fix:	Maintain automated configuration management to prevent verbose banner headers in production.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Exact OS and web/service configuration file location on `192.168.195.130:80` was not established by unauthenticated banner fingerprinting. Identify the active service daemon and export a configuration backup on `192.168.195.130` prior to applying header, cookie, or access-control changes.
Verification & Closure Rule:	Run `curl -I http://192.168.195.130:80/` and confirm `Server: Apache` returns no version or OS string. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-73 on 192.168.195.130:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.130:80/` and confirm `Server: Apache` returns no version or OS string.` against `192.168.195.130:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-74: Apache HTTP OPTIONS Allow Header Heuristic (Optionsbleed CVE-2017-9798 Candidate) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1190 (Exploit Public-Facing Application) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: Apache/2.2.8 (Ubuntu) DAV/2 | Inferred: Apache HTTP Server 2.2.8 (Ubuntu) | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: End-of-Life Apache 2.2.x branch; Ubuntu backports patches within LTS support window, but Apache 2.2.x is upstream EOL. | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: CVE-2017-9798 | Custom ID: XSTRIKE-APACHE-OPTIONSBLEED | Advisory: Apache Security Advisory CVE-2017-9798 (Optionsbleed) | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 (Exposure of Sensitive Information) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:80
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Apache httpd 2.2.8 on 192.168.195.139:80 was evaluated for CVE-2017-9798 (Optionsbleed) via HTTP OPTIONS Allow header inspection; corrupted memory bleed was not observed in the response.
Security Risk:	LOW (OBSERVED) — Version/header heuristic; verify Apache Limit/Options directives.
EvidenceCore V3.5 Record:	ID: PROV-F-74-D7B8957476 | SHA-256: d7b895747667e5c6ddf17eb7... | HMAC-SHA256: 463f135c9465712152a221ae... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-74):

```
Apache 2.2.x-2.4.x Optionsbleed information leak via OPTIONS requests

Evidence: Banner match on 192.168.195.139:80: HTTP/1.1 200 OK
Date: Sat, 31 Oct 2026 12:27:58 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Length: 891
Connection: close
```

```
Content-Type: text/html

<html
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Audit Apache `<Directory>` and `.htaccess` files to ensure `Limit` and `Options` directives contain only valid HTTP methods and tokens, or disable `OPTIONS` via `RewriteEngine`.
Short-Term Hardening:	Verify distribution patch level (`dpkg -l apache2`) for CVE-2017-9798 or upgrade Apache httpd to 2.4.x.
Long-Term Strategic Fix:	Include `.htaccess` syntax validation in deployment checks.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Send repeated `curl -i -X OPTIONS http://192.168.195.139:80/` requests and confirm clean, deterministic `Allow:` headers. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-74 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Send repeated `curl -i -X OPTIONS http://192.168.195.139:80/` requests and confirm clean, deterministic `Allow:` headers.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-75: HTTP Permissions-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-PERMISSIONS-POLICY | Advisory: W3C Permissions Policy Specification | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 (Protection Mechanism Failure) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit the 'Permissions-Policy' (formerly Feature-Policy) header, leaving browser APIs (camera, microphone, geolocation, payment) unrestricted at the document policy layer.
Security Risk:	LOW — Defense-in-depth browser hardening omission; does not directly enable remote code execution.
EvidenceCore V3.5 Record:	ID: PROV-F-75-C41FEE5081 | SHA-256: c41fee508178852d5b00be43... | HMAC-SHA256: ba0994be86b2a98b4ab56d7c... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-75):

```
Missing header: Permissions-Policy | CWE: CWE-732 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Add `Header always set Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=(), usb=()"` in the web server configuration.
Short-Term Hardening:	Audit frontend application requirements and explicitly disable all unused browser hardware/sensor APIs.
Long-Term Strategic Fix:	Enforce `Permissions-Policy` alongside CSP in automated HTTP security header regression tests.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and confirm the `Permissions-Policy` header is present. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-75 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and confirm the `Permissions-Policy` header is present.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-76: HTTP Referrer-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.

7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-REFERRER-POLICY | Advisory: W3C Referrer Policy / OWASP Secure Headers | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit the 'Referrer-Policy' header, which may cause full URLs (including query parameters) to be leaked in the Referer header during cross-origin navigation.
Security Risk:	LOW — Potential disclosure of sensitive URL paths or query parameters to third-party origins.
EvidenceCore V3.5 Record:	ID: PROV-F-76-579B019A38 | SHA-256: 579b019a383092aabdd09680... | HMAC-SHA256: d157b64684d75a2c30b697e1... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-76):

```
Missing header: Referrer-Policy | CWE: CWE-200 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Add `Header always set Referrer-Policy "strict-origin-when-cross-origin"` in Apache `/etc/apache2/conf.d/security` or Nginx configuration.
Short-Term Hardening:	Ensure sensitive tokens or session identifiers are never passed in URL query strings where they could leak via Referer headers.
Long-Term Strategic Fix:	Include `Referrer-Policy` in baseline web security header automated tests.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-76 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-77: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PARTIALLY_REMEDIATED_NOT_CLOSED (CHG-2026-1031-004)) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: Apache/2.2.8 (Ubuntu) DAV/2 | Inferred: Apache HTTP Server 2.2.8 (Ubuntu) | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: End-of-Life Apache 2.2.x branch; Ubuntu backports patches within LTS support window, but Apache 2.2.x is upstream EOL. | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-SERVER-BANNER | Advisory: Apache ServerTokens Prod / CIS Web Server Hardening | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints.
Security Risk:	LOW — Facilitates precise vulnerability fingerprinting by external adversaries.
EvidenceCore V3.5 Record:	ID: PROV-F-77-8AE350E466 | SHA-256: 8ae350e46676fc9ef04af9bf... | HMAC-SHA256: bb557a720f1aa07faea1b955... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-77):

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
---
Server header exposes version: Apache/2.2.8 (Ubuntu) DAV/2

Evidence: Server: Apache/2.2.8 (Ubuntu) DAV/2
---
Server: Apache/2.2.8 (Ubuntu) DAV/2 | CWE: CWE-200 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)

Immediate Containment:	Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`).
Short-Term Hardening:	Configure reverse-proxy header sanitization to strip detailed upstream server version banners.
Long-Term Strategic Fix:	Maintain automated configuration management to prevent verbose banner headers in production.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and confirm `Server: Apache` returns no version or OS string. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-77 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and confirm `Server: Apache` returns no version or OS string.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-78: HTTP Strict-Transport-Security (HSTS) Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557 (Credential Access — Adversary-in-the-Middle) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1557 (Adversary-in-the-Middle) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-HSTS-MISSING | Advisory: RFC 6797 / OWASP HTTP Strict Transport Security Cheat Sheet | CWE: CWE-319 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-319 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139:80, http://192.168.195.139:80/dvwa/login.php, http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)

Technical Description:	HTTP/HTTPS responses omit the 'Strict-Transport-Security' header, allowing clients to connect over unencrypted HTTP and exposing sessions to SSL-stripping attacks.
Security Risk:	LOW — Enables protocol downgrade and cleartext session interception on untrusted networks.
EvidenceCore V3.5 Record:	ID: PROV-F-78-5F53D90274 | SHA-256: 5f53d90274571ce29044085e... | HMAC-SHA256: 16aeeba6e8f9db4ab2ca403b... | Module: XStrike-BuiltinVuln, AutoPentest-OWASP, AutoPentest-AegisProbe

Captured Technical Evidence (F-78):

```
A02 Cryptographic Failures: 2 finding(s)
[CWE-319] Login over HTTP: /dvwa/login.php
[CWE-693] Missing Security Headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options
---
No HSTS header — susceptible to SSL stripping attacks

Evidence: HTTP response from 192.168.195.139:80 missing strict-transport-security header
---
Missing header: Strict-Transport-Security | CWE: CWE-319 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Configure TLS (HTTPS) on port 443 and add `Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"` to the HTTPS virtual host.
Short-Term Hardening:	Configure HTTP port 80 to issue permanent `301 Moved Permanently` redirects to `https://` for all endpoints.
Long-Term Strategic Fix:	Standardize internal PKI certificate automation (ACME/step-ca) across all web services.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Inspect HTTPS response headers via `curl -I https://192.168.195.139:443/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-78 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Inspect HTTPS response headers via `curl -I https://192.168.195.139:443/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-79: HTTP Technology Stack Disclosure ('X-Powered-By' Header) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.

7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-XPOWEREDBY | Advisory: PHP expose_php=Off Hardening Guideline | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The web application discloses backend runtime versions (e.g., 'X-Powered-By: PHP/5.2.4-2ubuntu5.10') in HTTP response headers.
Security Risk:	LOW — Reveals exact application framework version to aid targeted exploit selection.
EvidenceCore V3.5 Record:	ID: PROV-F-79-EFEC47D1D0 | SHA-256: efec47d1d0c5ada5e6e86851... | HMAC-SHA256: 147f9fe5bf8a2c25b5a9cac2... | Module: AutoPentest-ZAP, AutoPentest-AegisProbe

Captured Technical Evidence (F-79):

```
The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers.
Access to such information may facilitate attackers identifying other frameworks/components your
---
X-Powered-By: PHP/5.2.4-2ubuntu5.10 | CWE: CWE-200 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Set `expose_php = Off` in `/etc/php5/apache2/php.ini` and add `Header unset X-Powered-By` in Apache configuration.
Short-Term Hardening:	Audit application middleware to suppress framework version headers (`X-AspNet-Version`, `X-Generator`).
Long-Term Strategic Fix:	Enforce header stripping at the edge reverse proxy.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and confirm the `X-Powered-By` header is completely absent. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-79 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and confirm the `X-Powered-By` header is completely absent.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-80: Web Server Directory Listing Enabled (/icons/ & Static Directories) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1083 (Discovery — File and Directory Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1083 (File and Directory Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-DIR-LISTING | Advisory: Apache Options -Indexes Hardening Guideline | CWE: CWE-548 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-548 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/icons/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Web server directories (such as /icons/) return an auto-generated directory index listing internal files (consolidated with OWASP A05 misconfiguration checks).
Security Risk:	LOW — Enables unauthenticated enumeration of static and backup files.
EvidenceCore V3.5 Record:	ID: PROV-F-80-3E09869D4E | SHA-256: 3e09869d4e6ae98dece987b8... | HMAC-SHA256: 61851751cc1c326e37a11872... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-80):

```
Sensitive path accessible: /icons/

Evidence: HTTP 200 on http://192.168.195.139:80/icons/
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Disable directory indexing in Apache `/etc/apache2/apache2.conf` and `/etc/apache2/mods-enabled/alias.conf` by setting `Options -Indexes` on `/var/www/` and `/usr/share/apache2/icons/`.
Short-Term Hardening:	Remove default Apache `/icons/` alias or restrict it to specific file extensions.

Long-Term Strategic Fix:	Enforce `Options -Indexes` in baseline web server hardening templates.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-80 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-81: X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.139 (Ports: 80) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-XCTO-MISSING | Advisory: OWASP Secure Headers Project — X-Content-Type-Options | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139, 192.168.195.139:80, http://192.168.195.139:80/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit 'X-Content-Type-Options: nosniff', allowing browsers to MIME-sniff response bodies into executable content types.

Security Risk:	LOW — Browser MIME-type guessing can facilitate content-spoofing or stored XSS in uploaded content.
EvidenceCore V3.5 Record:	ID: PROV-F-81-D09020B64D | SHA-256: d09020b64d59fb302c5fcbc9... | HMAC-SHA256: 8bda4cdc38f541720b015db3... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-81):

```
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older
versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially cau
---
No X-Content-Type-Options header — MIME sniffing not prevented

Evidence: HTTP response from 192.168.195.139:80 missing x-content-type-options header
---
Missing header: X-Content-Type-Options | CWE: CWE-693 | Payload:
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Add `Header always set X-Content-Type-Options "nosniff"` in the web server configuration (`apache2.conf` / `nginx.conf`).
Short-Term Hardening:	Ensure all static and dynamic responses set explicit, accurate `Content-Type` MIME headers.
Long-Term Strategic Fix:	Include `X-Content-Type-Options: nosniff` in baseline infrastructure-as-code web templates.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.139:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.139:80/` and verify `X-Content-Type-Options: nosniff` is present on all responses. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-81 on 192.168.195.139:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.139:80/` and verify `X-Content-Type-Options: nosniff` is present on all responses.` against `192.168.195.139:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-82: Apache HTTP OPTIONS Allow Header Heuristic (Optionsbleed CVE-2017-9798 Candidate) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1190 (Exploit Public-Facing Application) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2. | Inferred: Apache HTTP Server 2.2.14 (Ubuntu) | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: End-of-Life Apache 2.2.x branch; Ubuntu backports patches within LTS support window, but Apache 2.2.x is upstream EOL. | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: CVE-2017-9798 | Custom ID: XSTRIKE-APACHE-OPTIONSBLEED | Advisory: Apache Security Advisory CVE-2017-9798 (Optionsbleed) | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 (Exposure of Sensitive Information) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:80
Root Cause & 4-Tier Compliance:	Service Hardening & Configuration Baseline Gap [PROBABLE] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Apache httpd 2.2.14 on 192.168.195.140:80 was evaluated for CVE-2017-9798 (Optionsbleed) via HTTP OPTIONS Allow header inspection; corrupted memory bleed was not observed in the response.
Security Risk:	LOW (OBSERVED) — Version/header heuristic; verify Apache Limit/Options directives.
EvidenceCore V3.5 Record:	ID: PROV-F-82-D74C4DEC16 | SHA-256: d74c4dec16f729be455c227b... | HMAC-SHA256: 8dc98e608cf3a2d4c184588b... | Module: XStrike-BuiltinVuln

Captured Technical Evidence (F-82):

```
Apache 2.2.x-2.4.x Optionsbleed information leak via OPTIONS requests

Evidence: Banner match on 192.168.195.140:80: HTTP/1.1 200 OK
Date: Sat, 31 Oct 2026 12:28:41 GMT
Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1
mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Audit Apache `<Directory>` and `.htaccess` files to ensure `Limit` and `Options` directives contain only valid HTTP methods and tokens, or disable `OPTIONS` via `RewriteEngine`.
Short-Term Hardening:	Verify distribution patch level (`dpkg -l apache2`) for CVE-2017-9798 or upgrade Apache httpd to 2.4.x.
Long-Term Strategic Fix:	Include `.htaccess` syntax validation in deployment checks.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Send repeated `curl -i -X OPTIONS http://192.168.195.140:80/` requests and confirm clean, deterministic `Allow:` headers. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-82 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Send repeated `curl -i -X OPTIONS http://192.168.195.140:80/` requests and confirm clean, deterministic `Allow:` headers.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-83: Developer / Debugging Comments Exposed in HTML/JS Source [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-ZAP-COMMENTS | Advisory: OWASP ZAP Alert 10027 — Information Disclosure: Suspicious Comments | CWE: CWE-615 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-615 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=90% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTML and JavaScript responses contain developer comments that may disclose internal application logic, hints, or endpoints.
Security Risk:	LOW — Information disclosure in client-accessible markup.
EvidenceCore V3.5 Record:	ID: PROV-F-83-4EE5174788 | SHA-256: 4ee5174788934319d3aaa00f... | HMAC-SHA256: 27e1b3ae885e4b94f45a1e03... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-83):

```
The response appears to contain suspicious comments which may help an attacker.
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Strip developer, TODO, and debugging HTML/JS comments from production templates in `/var/www/`.
Short-Term Hardening:	Audit client-side HTML and JavaScript files to ensure no hints, credentials, or internal SQL queries are embedded in comments.
Long-Term Strategic Fix:	Add HTML/JS minification that strips comments in the build pipeline.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)

Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Inspect page source via `curl -s` and confirm developer/debugging comments are removed. [Target Endpoint: `192.168.195.140:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-83 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Inspect page source via `curl -s` and confirm developer/debugging comments are removed. [Target Endpoint: `192.168.195.140:80`]` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-84: HTTP Permissions-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80, 8080) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-PERMISSIONS-POLICY | Advisory: W3C Permissions Policy Specification | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 (Protection Mechanism Failure) | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): http://192.168.195.140:80/, http://192.168.195.140:8080/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit the 'Permissions-Policy' (formerly Feature-Policy) header, leaving browser APIs (camera, microphone, geolocation, payment) unrestricted at the document policy layer.
Security Risk:	LOW — Defense-in-depth browser hardening omission; does not directly enable remote code execution.
EvidenceCore V3.5 Record:	ID: PROV-F-84-3C0FFD8E56 | SHA-256: 3c0ffd8e564e847275ee781d... | HMAC-SHA256: a0fafab640143c6579cbf058... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-84):

```
Missing header: Permissions-Policy | CWE: CWE-732 | Payload:
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Add `Header always set Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=(), usb=()"` in the web server configuration.
Short-Term Hardening:	Audit frontend application requirements and explicitly disable all unused browser hardware/sensor APIs.
Long-Term Strategic Fix:	Enforce `Permissions-Policy` alongside CSP in automated HTTP security header regression tests.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.140:80/` and confirm the `Permissions-Policy` header is present. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-84 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.140:80/` and confirm the `Permissions-Policy` header is present.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-85: HTTP Referrer-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80, 8080) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-REFERRER-POLICY | Advisory: W3C Referrer Policy / OWASP Secure Headers | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)

Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): http://192.168.195.140:80/, http://192.168.195.140:8080/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit the 'Referrer-Policy' header, which may cause full URLs (including query parameters) to be leaked in the Referer header during cross-origin navigation.
Security Risk:	LOW — Potential disclosure of sensitive URL paths or query parameters to third-party origins.
EvidenceCore V3.5 Record:	ID: PROV-F-85-8BCA01910E | SHA-256: 8bca01910e45e67605d98edd... | HMAC-SHA256: a799b7ad447468bec91f4893... | Module: AutoPentest-AegisProbe

Captured Technical Evidence (F-85):

```
Missing header: Referrer-Policy | CWE: CWE-200 | Payload:
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Add `Header always set Referrer-Policy "strict-origin-when-cross-origin"` in Apache `/etc/apache2/conf.d/security` or Nginx configuration.
Short-Term Hardening:	Ensure sensitive tokens or session identifiers are never passed in URL query strings where they could leak via Referer headers.
Long-Term Strategic Fix:	Include `Referrer-Policy` in baseline web security header automated tests.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.140:80/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-85 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.140:80/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-86: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80, 8080) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1592 (Reconnaissance — Gather Victim Host Information) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1592 (Gather Victim Host Information) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 | Inferred: Apache HTTP Server 2.2.14 (Ubuntu) | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: End-of-Life Apache 2.2.x branch; Ubuntu backports patches within LTS support window, but Apache 2.2.x is upstream EOL. | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-SERVER-BANNER | Advisory: Apache ServerTokens Prod / CIS Web Server Hardening | CWE: CWE-200 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 35 raw observation(s) across 3 unique endpoint(s): 192.168.195.140, http://192.168.195.140:80/, http://192.168.195.140:8080/
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.14 (Ubuntu)') in the HTTP 'Server' response header across multiple endpoints.
Security Risk:	LOW — Facilitates precise vulnerability fingerprinting by external adversaries.
EvidenceCore V3.5 Record:	ID: PROV-F-86-6E32C7ED80 | SHA-256: 6e32c7ed8040b58d4f3bcc7c... | HMAC-SHA256: 74950d5617aee1d9d4cb2c7b... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-86):

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
---
Server header exposes version: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with
Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k
Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1

Evidence: Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch
proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38
mod_p
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`).
Short-Term Hardening:	Configure reverse-proxy header sanitization to strip detailed upstream server version banners.
Long-Term Strategic Fix:	Maintain automated configuration management to prevent verbose banner headers in production.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.140:80/` and confirm `Server: Apache` returns no version or OS string. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-86 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.140:80/` and confirm `Server: Apache` returns no version or OS string.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-87: HTTP Strict-Transport-Security (HSTS) Header Missing [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80, 8080) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1557 (Credential Access — Adversary-in-the-Middle) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1557 (Adversary-in-the-Middle) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-HSTS-MISSING | Advisory: RFC 6797 / OWASP HTTP Strict Transport Security Cheat Sheet | CWE: CWE-319 | Taxonomy: OWASP-A02:2021 (Cryptographic Failures) | CWE-319 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 7 raw observation(s) across 5 unique endpoint(s): 192.168.195.140:80, 192.168.195.140:8080, 192.168.195.140, http://192.168.195.140:80/ ... (+1 additional endpoints)
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags)
Technical Description:	HTTP/HTTPS responses omit the 'Strict-Transport-Security' header, allowing clients to connect over unencrypted HTTP and exposing sessions to SSL-stripping attacks.
Security Risk:	LOW — Enables protocol downgrade and cleartext session interception on untrusted networks.
EvidenceCore V3.5 Record:	ID: PROV-F-87-5EEF8DCC7E | SHA-256: 5eef8dcc7e94bb832a236b45... | HMAC-SHA256: fa0d9316e3d384351c662490... | Module: XStrike-BuiltinVuln, AutoPentest-OWASP, AutoPentest-AegisProbe

Captured Technical Evidence (F-87):

```
No HSTS header — susceptible to SSL stripping attacks

Evidence: HTTP response from 192.168.195.140:80 missing strict-transport-security header
---
No HSTS header — susceptible to SSL stripping attacks

Evidence: HTTP response from 192.168.195.140:8080 missing strict-transport-security header
---
A02 Cryptographic Failures: 1 finding(s)
[CWE-693] Missing Security Headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Configure TLS (HTTPS) on port 443 and add `Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"` to the HTTPS virtual host.
Short-Term Hardening:	Configure HTTP port 80 to issue permanent `301 Moved Permanently` redirects to `https://` for all endpoints.
Long-Term Strategic Fix:	Standardize internal PKI certificate automation (ACME/step-ca) across all web services.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Inspect HTTPS response headers via `curl -I https://192.168.195.140:443/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-87 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Inspect HTTPS response headers via `curl -I https://192.168.195.140:443/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-88: Session Cookie Missing 'HttpOnly' Flag [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-COOKIE-HTTPONLY | Advisory: OWASP Session Management Cheat Sheet — HttpOnly | CWE: CWE-1004 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-1004 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)

Deduplication & Endpoints:	Consolidated 10 raw observation(s) across 1 unique endpoint(s): 192.168.195.140
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Cookies are set without the 'HttpOnly' flag, permitting client-side JavaScript ('document.cookie') to read session identifiers.
Security Risk:	LOW — Enables session theft if combined with a Cross-Site Scripting (XSS) vulnerability.
EvidenceCore V3.5 Record:	ID: PROV-F-88-586E48E64B | SHA-256: 586e48e64b49f86bd98d50c2... | HMAC-SHA256: 777c844ae6223a505c7fdac0... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-88):

```
A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by
JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Set `session.cookie_httponly = 1` in `/etc/php5/apache2/php.ini` and add `HttpOnly` to all application `setcookie()` calls.
Short-Term Hardening:	Add Apache header rewrite `Header edit Set-Cookie ^(.*)$ "$1; HttpOnly"` for legacy applications.
Long-Term Strategic Fix:	Enforce automated DAST checks verifying `HttpOnly` on all session identifiers.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present. [Target Endpoint: `192.168.195.140:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-88 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present. [Target Endpoint: `192.168.195.140:80`]` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-89: Session Cookie Missing 'SameSite' Attribute [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-COOKIE-SAMESITE | Advisory: RFC 6265bis — SameSite Cookie Attribute | CWE: CWE-352 | Taxonomy: OWASP-A01:2021 (Broken Access Control) | CWE-352 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 10 raw observation(s) across 1 unique endpoint(s): 192.168.195.140
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Session cookies are issued without the 'SameSite=Lax' or 'SameSite=Strict' attribute, allowing cookies to be transmitted in cross-origin requests.
Security Risk:	LOW — Weakens browser defense against Cross-Site Request Forgery (CSRF).
EvidenceCore V3.5 Record:	ID: PROV-F-89-78FD63AFF7 | SHA-256: 78fd63aff7620b79190a32e8... | HMAC-SHA256: 6ee4f4084e5539a5fc40c587... | Module: AutoPentest-ZAP

Captured Technical Evidence (F-89):

```
A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-sit
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Update PHP/application session configuration (`session.cookie_samesite = "Lax"` or `"Strict"`) or add Apache `Header edit Set-Cookie ^(.*)$ "$1; SameSite=Lax"`.
Short-Term Hardening:	Audit cross-site authentication flows and enforce `SameSite=Strict` on high-privilege session cookies.
Long-Term Strategic Fix:	Standardize session management using framework-managed `__Host-` prefixed cookies.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present. [Target Endpoint: `192.168.195.140:80`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-89 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present. [Target Endpoint: `192.168.195.140:80`]` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-90: Web Server Directory Listing Enabled (/icons/ & Static Directories) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE

Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1083 (Discovery — File and Directory Discovery) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1083 (File and Directory Discovery) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-WEB-DIR-LISTING | Advisory: Apache Options -Indexes Hardening Guideline | CWE: CWE-548 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-548 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): http://192.168.195.140:80/icons/, http://192.168.195.140:80/images/:
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	Web server directories (such as /icons/) return an auto-generated directory index listing internal files (consolidated with OWASP A05 misconfiguration checks).
Security Risk:	LOW — Enables unauthenticated enumeration of static and backup files.
EvidenceCore V3.5 Record:	ID: PROV-F-90-B425CF0FE9 | SHA-256: b425cf0fe9538d4938ce019f... | HMAC-SHA256: 75a56922e433f46cb6c8749d... | Module: XStrike-BuiltinVuln, AutoPentest-OWASP

Captured Technical Evidence (F-90):

```
Sensitive path accessible: /icons/

Evidence: HTTP 200 on http://192.168.195.140:80/icons/
---
A05 Misconfiguration: 4 finding(s)
[CWE-548] Directory Listing: /images/: Full directory contents exposed
[CWE-548] Directory Listing: /icons/: Full directory contents exposed
[CWE-548] Directory Listing: /assets/: Full directory contents exposed
[CWE-693] HTTP TRACE Enabled: XST (Cross-Site Tracing) possible
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Disable directory indexing in Apache `/etc/apache2/apache2.conf` and `/etc/apache2/mods-enabled/alias.conf` by setting `Options -Indexes` on `/var/www/` and `/usr/share/apache2/icons/`.
Short-Term Hardening:	Remove default Apache `/icons/` alias or restrict it to specific file extensions.
Long-Term Strategic Fix:	Enforce `Options -Indexes` in baseline web server hardening templates.

Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Request `http://192.168.195.140:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-90 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.140:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-91: X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) [LOW · CVSS 3.1 · VALIDATED]

Target Asset & Port:	192.168.195.140 (Ports: 80, 8080) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: VALIDATED -> T1 Post-Retest: VALIDATED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: VALIDATED_WEAKNESS_NOT_CLAIMED_EXPLOITABLE | Exploitability Claimed: False | Rationale: Held at VALIDATED (not promoted to EXPLOITABLE) because while the configuration/protocol weakness is proven, end-to-end weaponization was not executed.
4-State MITRE Provenance:	MITRE: T1190 (Initial Access — Exploit Public-Facing Application) | Execution State: MAPPED_ONLY [TIER_4_TAXONOMY_MAPPING_ONLY] — Technique T1190 (Exploit Public-Facing Application) mapped for taxonomy reference on passive header/cookie/banner observation; not actively executed.
7-D Proof Vector (V3.5):	Execution: SAFE_PROBE_EXECUTED | Auth: UNAUTHENTICATED_PROBE | Exploitability: CONFIGURATION_WEAKNESS | Privilege: NONE | DataAccess: METADATA_OR_HEADERS_ONLY | Impact: DEFENSE_IN_DEPTH_DEGRADATION | EvidenceConf: 94%
Access Scope Summary:	Technical configuration, protocol flag, or HTTP response header/cookie directly validated
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: DIRECTLY_APPLICABLE
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-HDR-XCTO-MISSING | Advisory: OWASP Secure Headers Project — X-Content-Type-Options | CWE: CWE-693 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-693 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=95% | ExploitabilityConf=25% | ImpactConf=30% | 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) | ExploitabilityConf=25% | ImpactConf=30% | FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate)
Deduplication & Endpoints:	Consolidated 11 raw observation(s) across 5 unique endpoint(s): 192.168.195.140, 192.168.195.140:80, 192.168.195.140:8080, http://192.168.195.140:80/ ... (+1 additional endpoints)
Root Cause & 4-Tier Compliance:	Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] | Compliance Enum: EVIDENCE_OF_CONTROL_FAILURE | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	HTTP responses omit 'X-Content-Type-Options: nosniff', allowing browsers to MIME-sniff response bodies into executable content types.
Security Risk:	LOW — Browser MIME-type guessing can facilitate content-spoofing or stored XSS in uploaded content.

EvidenceCore V3.5 Record:	ID: PROV-F-91-625AE99FD3 | SHA-256: 625ae99fd3a6680dc92fb30a... | HMAC-SHA256: 1ac2d2c2184cae0333575ed0... | Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe

Captured Technical Evidence (F-91):

```
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older
versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially cau
---
No X-Content-Type-Options header — MIME sniffing not prevented

Evidence: HTTP response from 192.168.195.140:80 missing x-content-type-options header
---
No X-Content-Type-Options header — MIME sniffing not prevented

Evidence: HTTP response from 192.168.195.140:8080 missing x-content-type-options header
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Add `Header always set X-Content-Type-Options "nosniff"` in the web server configuration (`apache2.conf` / `nginx.conf`).
Short-Term Hardening:	Ensure all static and dynamic responses set explicit, accurate `Content-Type` MIME headers.
Long-Term Strategic Fix:	Include `X-Content-Type-Options: nosniff` in baseline infrastructure-as-code web templates.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`) on `192.168.195.140:80`, run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur.
Verification & Closure Rule:	Run `curl -I http://192.168.195.140:80/` and verify `X-Content-Type-Options: nosniff` is present on all responses. | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-91 on 192.168.195.140:80 remains OPEN until an automated XStrike re-test executes `Run `curl -I http://192.168.195.140:80/` and verify `X-Content-Type-Options: nosniff` is present on all responses.` against `192.168.195.140:80`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-92: SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) [LOW · CVSS 3.1 · OBSERVED]

Target Asset & Port:	192.168.195.130 (Ports: 445) | Asset Class: Workstation / SMB Peer Host (STANDARD)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1021.002 (Lateral Movement — Remote Services: SMB/Windows Admin Shares) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1021.002 (Remote Services: SMB/Windows Admin Shares) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-SMB-ENUM-SURFACE | Advisory: CIS Benchmark — Restrict Anonymous SMB/NetBIOS Enumeration | CWE: CWE-287 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-287 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.130:139, 192.168.195.130:445
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	SMB ports 139/445 were probed via Nmap NSE (smb-enum-shares, smb-enum-users). Script output did not return unauthenticated share contents or user RIDs; classified as OBSERVED service exposure.
Security Risk:	LOW (OBSERVED) — Exposed SMB enumeration surface; restrict anonymous/null session queries.
EvidenceCore V3.5 Record:	ID: PROV-F-92-96757F7748 | SHA-256: 96757f77483c7c4edf97e6a5... | HMAC-SHA256: 57dad38203e3c6ce7366362a... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-92):

```
SMB Enum: Nmap scan report for 192.168.195.130
Host is up (0.00013s latency).

PORT STATE SERVICE
139/tcp open netbios-ssn
MAC Address: 00:0C:29:73:FE:EC (VMware)

Host script results:
|_smb-enum-users: ERROR: Script execution failed (use -d to debug)
|_smb-enum-groups: ERROR: Script execution failed (use -d to debug)
|_smb-enum-shares: E
---
SMB Enum: Nmap scan report for 192.168.195.130
Host is up (0.0010s latency).

PORT STATE SERVICE
445/tcp open microsoft-ds
MAC Address: 00:0C:29:73:FE:EC (VMware)

Host script results:
|_smb-enum-groups: ERROR: Script execution failed (use -d to debug)
|_smb-enum-users: ERROR: Script execution fa
```

Target Environment Profile:	LAN Endpoint (192.168.195.130:445 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Restrict anonymous/null SMB sessions by setting `restrict anonymous = 2` and `map to guest = Never` in `/etc/samba/smb.conf`, then reload `smbd`.
Short-Term Hardening:	Block TCP ports 139 and 445 from untrusted internal subnets at the host firewall.
Long-Term Strategic Fix:	Audit all Samba/Windows shares to ensure explicit group ACLs are required for share enumeration.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)

Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Confirm whether `192.168.195.130:445` runs Windows Server (`HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters`) or Samba (`/etc/samba/smb.conf`), export the registry key or config backup prior to disabling SMBv1/enforcing signing, and revert if authorized SMB clients fail.
Verification & Closure Rule:	Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. [Target Endpoint: `192.168.195.130:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-92 on 192.168.195.130:445 remains OPEN until an automated XStrike re-test executes `Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. [Target Endpoint: `192.168.195.130:445`]` against `192.168.195.130:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-93: SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) [LOW · CVSS 3.1 · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 445) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1021.002 (Lateral Movement — Remote Services: SMB/Windows Admin Shares) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1021.002 (Remote Services: SMB/Windows Admin Shares) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-SMB-ENUM-SURFACE | Advisory: CIS Benchmark — Restrict Anonymous SMB/NetBIOS Enumeration | CWE: CWE-287 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-287 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:139, 192.168.195.139:445
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	SMB ports 139/445 were probed via Nmap NSE (smb-enum-shares, smb-enum-users). Script output did not return unauthenticated share contents or user RIDs; classified as OBSERVED service exposure.
Security Risk:	LOW (OBSERVED) — Exposed SMB enumeration surface; restrict anonymous/null session queries.

EvidenceCore V3.5 Record:	ID: PROV-F-93-8255F76835 | SHA-256: 8255f76835e243424700b201... | HMAC-SHA256: 4524e2a4d21430ebbddbe260... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-93):

```
SMB Enum: Nmap scan report for 192.168.195.139
Host is up (0.00088s latency).

PORT STATE SERVICE
139/tcp open netbios-ssn
MAC Address: 00:0C:29:05:D7:6A (VMware)

Host script results:
|_smb-enum-groups: ERROR: Script execution failed (use -d to debug)
|_smb-enum-users: ERROR: Script execution failed (use -d to debug)
|_smb-os-discovery:
---
SMB Enum: Nmap scan report for 192.168.195.139
Host is up (0.00088s latency).

PORT STATE SERVICE
445/tcp open microsoft-ds
MAC Address: 00:0C:29:05:D7:6A (VMware)

Host script results:
|_smb-os-discovery: ERROR: Script execution failed (use -d to debug)
|_smb-enum-groups: ERROR: Script execution
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Restrict anonymous/null SMB sessions by setting `restrict anonymous = 2` and `map to guest = Never` in `/etc/samba/smb.conf`, then reload `smbd`.
Short-Term Hardening:	Block TCP ports 139 and 445 from untrusted internal subnets at the host firewall.
Long-Term Strategic Fix:	Audit all Samba/Windows shares to ensure explicit group ACLs are required for share enumeration.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) on `192.168.195.139` prior to disabling SMBv1 or enforcing `server signing = mandatory`; restore `smb.conf.bak` and restart `smbd` if legacy clients fail.
Verification & Closure Rule:	Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. [Target Endpoint: `192.168.195.139:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-93 on 192.168.195.139:445 remains OPEN until an automated XStrike re-test executes `Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. [Target Endpoint: `192.168.195.139:445`]` against `192.168.195.139:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-94: SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) [LOW · CVSS 3.1 · OBSERVED]

Target Asset & Port:	192.168.195.140 (Ports: 445) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.

4-State MITRE Provenance:	MITRE: T1021.002 (Lateral Movement — Remote Services: SMB/Windows Admin Shares) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1021.002 (Remote Services: SMB/Windows Admin Shares) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: SERVICE_BANNER_ONLY | Impact: EXPOSURE_ONLY | EvidenceConf: 42%
Access Scope Summary:	Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: N/A | Custom ID: XSTRIKE-SMB-ENUM-SURFACE | Advisory: CIS Benchmark — Restrict Anonymous SMB/NetBIOS Enumeration | CWE: CWE-287 | Taxonomy: OWASP-A05:2021 (Security Misconfiguration) | CWE-287 | Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.140:139, 192.168.195.140:445
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement)
Technical Description:	SMB ports 139/445 were probed via Nmap NSE (smb-enum-shares, smb-enum-users). Script output did not return unauthenticated share contents or user RIDs; classified as OBSERVED service exposure.
Security Risk:	LOW (OBSERVED) — Exposed SMB enumeration surface; restrict anonymous/null session queries.
EvidenceCore V3.5 Record:	ID: PROV-F-94-FE42E11729 | SHA-256: fe42e11729e354431fb151be... | HMAC-SHA256: def5a9de123808e060ecc7c0... | Module: AutoPentest-Exploit

Captured Technical Evidence (F-94):

```
SMB Enum: Nmap scan report for 192.168.195.140
Host is up (0.00088s latency).

PORT STATE SERVICE
139/tcp open netbios-ssn
MAC Address: 00:0C:29:86:5E:7D (VMware)

Host script results:
|_smb-enum-shares: ERROR: Script execution failed (use -d to debug)
---
SMB Enum: Nmap scan report for 192.168.195.140
Host is up (0.00088s latency).

PORT STATE SERVICE
445/tcp open microsoft-ds
MAC Address: 00:0C:29:86:5E:7D (VMware)

Host script results:
|_smb-enum-shares: ERROR: Script execution failed (use -d to debug)
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)

Immediate Containment:	Restrict anonymous/null SMB sessions by setting `restrict anonymous = 2` and `map to guest = Never` in `/etc/samba/smb.conf`, then reload `smbd`.
Short-Term Hardening:	Block TCP ports 139 and 445 from untrusted internal subnets at the host firewall.
Long-Term Strategic Fix:	Audit all Samba/Windows shares to ensure explicit group ACLs are required for share enumeration.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) on `192.168.195.140` prior to disabling SMBv1 or enforcing `server signing = mandatory`; restore `smb.conf.bak` and restart `smbd` if legacy clients fail.
Verification & Closure Rule:	Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. [Target Endpoint: `192.168.195.140:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-94 on 192.168.195.140:445 remains OPEN until an automated XStrike re-test executes `Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. [Target Endpoint: `192.168.195.140:445`]` against `192.168.195.140:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-95: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [INFO (ACTIVE CVSS 0.0 | CONDITIONAL CRITICAL 9.8) · OBSERVED]

Target Asset & Port:	192.168.195.1 (Ports: 445) | Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1210 (Exploitation of Remote Services) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: NONE | Impact: EXPOSURE_ONLY | EvidenceConf: 38%
Access Scope Summary:	Port-open / service banner observation only; vulnerability NOT verified
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: CVE-2017-0144 | Custom ID: XSTRIKE-SMB-445-CANDIDATE | Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) | CWE: CWE-200 | Taxonomy: OWASP-A06:2021 (Vulnerable Components) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N | Exposure Class: OBSERVED_EXPOSURE (TCP/445 Reachable; Protocol Vulnerability Unverified)
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1

Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Active CVSS is 0.0 (Informational Observed Exposure); conditional CVE-2017-0144 severity (9.8 Critical) is held separately pending protocol verification.
Security Risk:	INFO (OBSERVED EXPOSURE, Active CVSS 0.0 | Conditional CVSS 9.8 Critical if MS17-010 Confirmed) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies.
EvidenceCore V3.5 Record:	ID: PROV-F-95-43AF81D8EA | SHA-256: 43af81d8ead26d62f7f3ef91... | HMAC-SHA256: 260f9bbdf38c96c03ebf5749... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-95):

```
[2026-10-31 08:16:06] TCP connection to 192.168.195.1:445 succeeded.
Service: microsoft-ds, Product: unknown, Version: unknown
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.1
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

Target Environment Profile:	Host Gateway / Hypervisor Endpoint (192.168.195.1:445 — Windows/VMware Gateway Services; unauthenticated OS config path unverified)
Immediate Containment:	Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only.
Short-Term Hardening:	Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed.
Long-Term Strategic Fix:	Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Confirm whether `192.168.195.1:445` runs Windows Server (`HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters`) or Samba (`/etc/samba/smb.conf`), export the registry key or config backup prior to disabling SMBv1/enforcing signing, and revert if authorized SMB clients fail.
Verification & Closure Rule:	Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.1:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-95 on 192.168.195.1:445 remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.1:445`]` against `192.168.195.1:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-96: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [INFO (ACTIVE CVSS 0.0 | CONDITIONAL CRITICAL 9.8) · OBSERVED]

Target Asset & Port:	192.168.195.130 (Ports: 445) | Asset Class: Workstation / SMB Peer Host (STANDARD)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.

4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1210 (Exploitation of Remote Services) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: NONE | Impact: EXPOSURE_ONLY | EvidenceConf: 38%
Access Scope Summary:	Port-open / service banner observation only; vulnerability NOT verified
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: CVE-2017-0144 | Custom ID: XSTRIKE-SMB-445-CANDIDATE | Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) | CWE: CWE-200 | Taxonomy: OWASP-A06:2021 (Vulnerable Components) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N | Exposure Class: OBSERVED_EXPOSURE (TCP/445 Reachable; Protocol Vulnerability Unverified)
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.130
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Active CVSS is 0.0 (Informational Observed Exposure); conditional CVE-2017-0144 severity (9.8 Critical) is held separately pending protocol verification.
Security Risk:	INFO (OBSERVED EXPOSURE, Active CVSS 0.0 | Conditional CVSS 9.8 Critical if MS17-010 Confirmed) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies.
EvidenceCore V3.5 Record:	ID: PROV-F-96-A6F5D648F6 | SHA-256: a6f5d648f69d700959c4cb82... | HMAC-SHA256: 4a24308d17592d4e761d26ff... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-96):

```
[2026-10-31 08:12:34] TCP connection to 192.168.195.130:445 succeeded.
Service: microsoft-ds, Product: Microsoft Windows Server 2008 R2 - 2012 microsoft-ds, Version: unknown
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.130
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

Target Environment Profile:	LAN Endpoint (192.168.195.130:445 — Unauthenticated Network Probe; exact OS/config path requires verification)
Immediate Containment:	Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only.
Short-Term Hardening:	Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed.
Long-Term Strategic Fix:	Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)

Backup & Rollback Plan:	CONFIGURATION_PATH_VERIFICATION_REQUIRED: Confirm whether `192.168.195.130:445` runs Windows Server (`HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters`) or Samba (`/etc/samba/smb.conf`), export the registry key or config backup prior to disabling SMBv1/enforcing signing, and revert if authorized SMB clients fail.
Verification & Closure Rule:	Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.130:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-96 on 192.168.195.130:445 remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.130:445`]` against `192.168.195.130:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-97: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [INFO (ACTIVE CVSS 0.0 | CONDITIONAL CRITICAL 9.8) · OBSERVED]

Target Asset & Port:	192.168.195.139 (Ports: 445) | Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1210 (Exploitation of Remote Services) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: NONE | Impact: EXPOSURE_ONLY | EvidenceConf: 38%
Access Scope Summary:	Port-open / service banner observation only; vulnerability NOT verified
Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: VERIFIED_VIA_AUTHENTICATED_SESSION (uname -a / dpkg baseline on 192.168.195.139) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: CVE-2017-0144 | Custom ID: XSTRIKE-SMB-445-CANDIDATE | Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) | CWE: CWE-200 | Taxonomy: OWASP-A06:2021 (Vulnerable Components) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N | Exposure Class: OBSERVED_EXPOSURE (TCP/445 Reachable; Protocol Vulnerability Unverified)
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Active CVSS is 0.0 (Informational Observed Exposure); conditional CVE-2017-0144 severity (9.8 Critical) is held separately pending protocol verification.

Security Risk:	INFO (OBSERVED EXPOSURE, Active CVSS 0.0 | Conditional CVSS 9.8 Critical if MS17-010 Confirmed) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies.
EvidenceCore V3.5 Record:	ID: PROV-F-97-16393CF016 | SHA-256: 16393cf016104cbc467b67e6... | HMAC-SHA256: 7727f12466164b72adebff7c... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-97):

```
[2026-10-31 08:03:49] TCP connection to 192.168.195.139:445 succeeded.
Service: netbios-ssn, Product: Samba smbd, Version: 3.X - 4.X
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.139
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

Target Environment Profile:	Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20)
Immediate Containment:	Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only.
Short-Term Hardening:	Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed.
Long-Term Strategic Fix:	Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) on `192.168.195.139` prior to disabling SMBv1 or enforcing `server signing = mandatory`; restore `smb.conf.bak` and restart `smbd` if legacy clients fail.
Verification & Closure Rule:	Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.139:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-97 on 192.168.195.139:445 remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.139:445`]` against `192.168.195.139:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

F-98: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [INFO (ACTIVE CVSS 0.0 | CONDITIONAL CRITICAL 9.8) · OBSERVED]

Target Asset & Port:	192.168.195.140 (Ports: 445) | Asset Class: Application & Web Middleware Server (HIGH_VALUE)
Proof State & Retest State:	T0 Baseline: OBSERVED -> T1 Post-Retest: OBSERVED (PENDING_SCHEDULED_WINDOW) | Privilege: NONE | Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC
Privilege Context (V3.5):	uid=None | source=network_or_http_probe | transition=NONE | privesc_tech=NOT_APPLICABLE
Exploitability Validation Gate:	Gate Status: UNVERIFIED_SCANNER_ALERT_HELD_AT_OBSERVED | Exploitability Claimed: False | Rationale: Strictly held at OBSERVED: scanner alert or version banner alone is insufficient to claim exploitability without protocol/execution proof.
4-State MITRE Provenance:	MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) | Execution State: ATTEMPTED_BLOCKED_OR_UNVERIFIED [TIER_3_ATTEMPTED_NEGATIVE_OR_HELD] — Technique T1210 (Exploitation of Remote Services) check attempted; destructive payload withheld by RoE or response did not confirm exploitability.
7-D Proof Vector (V3.5):	Execution: BANNER_ONLY | Auth: UNAUTHENTICATED_PROBE | Exploitability: UNVERIFIED_CANDIDATE | Privilege: NONE | DataAccess: NONE | Impact: EXPOSURE_ONLY | EvidenceConf: 38%
Access Scope Summary:	Port-open / service banner observation only; vulnerability NOT verified

Version & Backport Model:	Banner: No explicit version banner in probe artifact | Inferred: Protocol/Configuration Behavior Match | Pkg Inventory: UNVERIFIED_BANNER_ONLY (Requires authenticated dpkg -l / rpm -qa / package audit) | Backport Status: N/A (Configuration / Protocol Behavior Finding) | CVE Applicability: CONDITIONAL_ON_VERIFICATION
Taxonomy & CVSS v3.1:	CVE: CVE-2017-0144 | Custom ID: XSTRIKE-SMB-445-CANDIDATE | Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) | CWE: CWE-200 | Taxonomy: OWASP-A06:2021 (Vulnerable Components) | CWE-200 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N | Exposure Class: OBSERVED_EXPOSURE (TCP/445 Reachable; Protocol Vulnerability Unverified)
Separated Confidence (V3.5):	EvidenceConf=48% | ExploitabilityConf=15% | ImpactConf=22% | 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) | ExploitabilityConf=15% | ImpactConf=22% | FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required)
Deduplication & Endpoints:	Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140
Root Cause & 4-Tier Compliance:	Network Segmentation & Perimeter Filter Exposure [INFERRED] | Compliance Enum: POTENTIAL_CONTROL_GAP | Tech Control: TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization)
Technical Description:	TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Active CVSS is 0.0 (Informational Observed Exposure); conditional CVE-2017-0144 severity (9.8 Critical) is held separately pending protocol verification.
Security Risk:	INFO (OBSERVED EXPOSURE, Active CVSS 0.0 | Conditional CVSS 9.8 Critical if MS17-010 Confirmed) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies.
EvidenceCore V3.5 Record:	ID: PROV-F-98-FC1F6F2EC7 | SHA-256: fc1f6f2ec705b9ed3cbf4f9a... | HMAC-SHA256: d6b775d2254ca93c405c3975... | Module: AutoPentest-VulnScan

Captured Technical Evidence (F-98):

```
[2026-10-31 08:08:41] TCP connection to 192.168.195.140:445 succeeded.
Service: netbios-ssn, Product: Samba smbd, Version: 3.X - 4.X
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.140
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

Target Environment Profile:	Ubuntu 10.04 LTS Server (Apache 2.2.14, PHP 5.3.2-1ubuntu4.30, OpenSSH 5.3p1 Debian-3ubuntu4, HTTPS :443, SMB :445)
Immediate Containment:	Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only.
Short-Term Hardening:	Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed.
Long-Term Strategic Fix:	Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries.
Approval & Change Window:	Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA)
Backup & Rollback Plan:	Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) on `192.168.195.140` prior to disabling SMBv1 or enforcing `server signing = mandatory`; restore `smb.conf.bak` and restart `smbd` if legacy clients fail.
Verification & Closure Rule:	Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.140:445`] | EVIDENCE_BASED_CLOSURE_ONLY: Finding F-98 on 192.168.195.140:445 remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. [Target Endpoint: `192.168.195.140:445`]` against `192.168.195.140:445`, captures a signed SHA-256/Ed25519 negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED.

3B. Consolidated Reconnaissance & Attack Surface Inventory (R-01 through R-26)

To prevent reconnaissance telemetry from inflating vulnerability or confirmed-exploitation counts, all **26 consolidated surface discovery groups** (representing **690** raw discovery observations, including `ZAP: User Agent Fuzzer`, `ZAP: Modern Web Application`, `JavaScript Source File Discovered`, `Postfix SMTP Banner`, `Open Port`, and `Host Discovered` records) are isolated below with `Proof State = DISCOVERED` and `CVSS = 0.0`.

Recon ID	Host	Canonical Discovery Class	Normalized Title	Raw Observations Consolidated	Unique Endpoints / Ports	Provenance ID
R-01	192.168.195.1	RECON_HOST_DISCOVERED	Active Network Host Discovered (ICMP/ARP/TCP Probe)	1	1	PROV-R-01-4DF732E1A8
R-02	192.168.195.1	RECON_CRED_SURFACE	Authentication Service Surface Identified (FTP/SSH/SMB)	1	1	PROV-R-02-498CF90543
R-03	192.168.195.1	RECON_WEB_SURFACE	HTTP/HTTPS Web Application Surface & Endpoints Enumerated	2	2	PROV-R-03-B3536DBE8E
R-04	192.168.195.1	RECON_ZAP_MODERN_WEB_APP	OWASP ZAP Informational Telemetry: Modern Web Application Fingerprinted	95	1	PROV-R-04-D28BF23D9F
R-05	192.168.195.1	RECON_ZAP_USER_AGENT_FUZZER	OWASP ZAP Informational Telemetry: User-Agent Response Differential Probe	444	1	PROV-R-05-989F00D414
R-06	192.168.195.1	RECON_OPEN_PORT	Open Network Service Port Enumerated	16	16	PROV-R-06-257B281200
R-07	192.168.195.129	RECON_HOST_DISCOVERED	Active Network Host Discovered (ICMP/ARP/TCP Probe)	1	1	PROV-R-07-332D21C307
R-08	192.168.195.129	RECON_OPEN_PORT	Open Network Service Port Enumerated	2	2	PROV-R-08-F1D4C0B00C
R-09	192.168.195.130	RECON_HOST_DISCOVERED	Active Network Host Discovered (ICMP/ARP/TCP Probe)	1	1	PROV-R-09-B269E35E96
R-10	192.168.195.130	RECON_CRED_SURFACE	Authentication Service Surface Identified (FTP/SSH/SMB)	1	1	PROV-R-10-45753A0067
R-11	192.168.195.130	RECON_OPEN_PORT	Open Network Service Port Enumerated	4	4	PROV-R-11-597CBEB8A1
R-12	192.168.195.131	RECON_HOST_DISCOVERED	Active Network Host Discovered (ICMP/ARP/TCP Probe)	1	1	PROV-R-12-A33B5ED1ED
R-13	192.168.195.139	RECON_HOST_DISCOVERED	Active Network Host Discovered (ICMP/ARP/TCP Probe)	2	1	PROV-R-13-279CDB8950

Recon ID	Host	Canonical Discovery Class	Normalized Title	Raw Observations Consolidated	Unique Endpoints / Ports	Provenance ID
R-14	192.168.195.139	RECON_CRED_SURFACE	Authentication Service Surface Identified (FTP/SSH/SMB)	1	1	PROV-R-14-DFC555AA54
R-15	192.168.195.139	RECON_JS_ASSET	Client-Side JavaScript Source Asset Enumerated	5	5	PROV-R-15-3852261785
R-16	192.168.195.139	RECON_WEB_SURFACE	HTTP/HTTPS Web Application Surface & Endpoints Enumerated	2	2	PROV-R-16-531CB69AD7
R-17	192.168.195.139	RECON_OPEN_PORT	Open Network Service Port Enumerated	24	24	PROV-R-17-57B85BCC35
R-18	192.168.195.139	RECON_SMTP_BANNER	Postfix SMTP Service Banner Enumerated (Port 25)	1	1	PROV-R-18-5C22434893
R-19	192.168.195.140	RECON_HOST_DISCOVERED	Active Network Host Discovered (ICMP/ARP/TCP Probe)	2	1	PROV-R-19-4EF5E83C8A
R-20	192.168.195.140	RECON_CRED_SURFACE	Authentication Service Surface Identified (FTP/SSH/SMB)	1	1	PROV-R-20-609DA36E96
R-21	192.168.195.140	RECON_JS_ASSET	Client-Side JavaScript Source Asset Enumerated	15	15	PROV-R-21-EC0305C9EB
R-22	192.168.195.140	RECON_WEB_SURFACE	HTTP/HTTPS Web Application Surface & Endpoints Enumerated	6	6	PROV-R-22-ACC78149B0
R-23	192.168.195.140	RECON_ZAP_MODERN_WEB_APP	OWASP ZAP Informational Telemetry: Modern Web Application Fingerprinted	4	1	PROV-R-23-5394912C16
R-24	192.168.195.140	RECON_ZAP_USER_AGENT_FUZZER	OWASP ZAP Informational Telemetry: User-Agent Response Differential Probe	48	1	PROV-R-24-7146087D04
R-25	192.168.195.140	RECON_OPEN_PORT	Open Network Service Port Enumerated	9	9	PROV-R-25-B6C3255A12
R-26	192.168.195.254	RECON_HOST_DISCOVERED	Active Network Host Discovered (ICMP/ARP/TCP Probe)	1	1	PROV-R-26-9EC1080559

4. Four-Stage Evidence-Backed Attack Graph V3.5, 5-State Taxonomy & Choke-Point Analysis

Path Count Reconciliation: The raw graph generator enumerated 101 port-level path permutations (0 high/critical permutations across open ports). AttackGraph V3/V4 deduplicated these by underlying CVE/CWE and per-edge proof state into 6 distinct attack chains: 3 EXECUTED (2 Full Root Compromises on 192.168.195.139 + 1 DB Superuser Auth), 2 PARTIALLY_VALIDATED, and 1 INFERRED_NOT_EXECUTED, plus 2 BLOCKED_BY_CONTROLS host paths and 3 NOT_TESTED_BY_SAFETY_ROE payloads, governed by 5 remediation choke points and exported to Neo4j Cypher.

Attack Path Priority Score Formula (0–100 Priority Index, Not Statistical Exploitation Probability):

```
AttackPathPriorityScore(C) = min(100, round(BaseCVSS * 6.0 * W_exec + ImpactBonus + HopBonus)) [0-100 Priority Index, not statistical probability], where W_exec = 1.00 (Confirmed Full Root Compromise), 0.90 (Confirmed DB/Service Authentication), 0.70-0.85 (Partially Validated Foothold/Precondition), 0.35 (Inferred Port-Open Candidate), or 0.00 (Blocked by Controls).
```

Chain ID	Attack Chain Name	Target Host(s)	Validation State	7-Metric Path Vector (Feas / Conf / Priv / Imp / Hops / Lev)	Attack Path Priority Score
CHAIN-01	vsFTPd 2.3.4 Backdoor -> Unauthenticated Root Shell -> /etc/shadow Dump	192.168.195.139	CONFIRMED_EXECUTED	Feas:0.99 | Conf:99.0% | Priv:ROOT (uid=0) | Imp:CROWN_JEWEL_HOST_TAKEOVER | Hops:4 | Lev:9 raw paths broken by stopping vsFTPd / blocking TCP 21 & 6200 chains	100/100 (P0_IMMEDIATE)
CHAIN-02	Ingreslock TCP/1524 Bindshell -> Unauthenticated Root Shell -> Credential Extraction	192.168.195.139	CONFIRMED_EXECUTED	Feas:0.99 | Conf:99.0% | Priv:ROOT (uid=0) | Imp:CROWN_JEWEL_HOST_TAKEOVER | Hops:4 | Lev:8 raw paths broken by killing /bin/sh on TCP 1524 & disabling inetd chains	100/100 (P0_IMMEDIATE)
CHAIN-03	SSH Default Credentials (uid=1000) -> Validated SUID Nmap / DirtyCow PrivEsc -> Local Root	192.168.195.139	PARTIALLY_VALIDATED	Feas:0.88 | Conf:88.0% | Priv:USER (uid=1000) -> Projected ROOT (uid=0) | Imp:PRIVILEGE_ESCALATION_TO_ROOT | Hops:4 | Lev:7 raw paths + FTP/SSH credential reuse broken by rotating msfadmin & removing SUID bits chains	76/100 (P1_HIGH)
CHAIN-04	PostgreSQL 5432 Default Superuser (postgres:postgres) -> DB Catalog Read Access	192.168.195.139	CONFIRMED_EXECUTED	Feas:0.95 | Conf:95.0% | Priv:DB_SUPERUSER (postgres) | Imp:RELATIONAL_DATABASE_COMPROMISE | Hops:4 | Lev:5 raw DB paths broken by rotating postgres password & binding 5432 to localhost chains	78/100 (P0_IMMEDIATE)
CHAIN-05	NFS Export Surface & Web SQLi / DVWA -> Inferred Filesystem/DB Takeover	192.168.195.139	PARTIALLY_VALIDATED	Feas:0.78 | Conf:83.0% | Priv:WEB_APP_DB_READ -> Projected FILESYSTEM_ACCESS | Imp:APPLICATION_AND_DATA_EXPOSURE | Hops:4 | Lev:5 raw paths broken by stopping nfs-kernel-server & parameterizing SQL queries chains	63/100 (P1_HIGH)

Chain ID	Attack Chain Name	Target Host(s)	Validation State	7-Metric Path Vector (Feas / Conf / Priv / Imp / Hops / Lev)	Attack Path Priority Score
CHAIN-06	Internal Subnet SMB Port 445 Exposure -> Theoretical Lateral Movement (Unverified)	192.168.195.1, 192.168.195.130, 192.168.195.140	INFERRED_NOT_EXECUTED	Feas:0.25 | Conf:30.0% | Priv:NONE (Port-Open Candidate Only) | Imp:POTENTIAL_LATERAL_MOVEMENT | Hops:2 | Lev:63 raw port permutations broken by disabling SMBv1 & enforcing SMB signing chains	19/100 (P2_MEDIUM)

4.1 Five-State Attack Path Classification Model (Executed vs Validated vs Inferred vs Blocked vs Safety-RoE Held)

Path Classification State	Count	Chain IDs & W_exec Weight	Technical Definition & Execution Boundary
EXECUTED_PATHS	3	CHAIN-01 (vsFTPd Root), CHAIN-02 (Ingreslock Root), CHAIN-04 (PostgreSQL Superuser Auth) [W_exec = 1.00 (Full OS Compromise: CHAIN-01, CHAIN-02) | W_exec = 0.90 (Confirmed DB Superuser Auth: CHAIN-04)]	End-to-end command execution or database superuser authentication verified with captured session transcript.
PARTIALLY_VALIDATED_PATHS	2	CHAIN-03 (SSH uid=1000 + SUID/DirtyCow Vector), CHAIN-05 (NFS Export + Web SQLi/DVWA) [W_exec = 0.85 (Authenticated Shell + Validated PrivEsc Precondition) | W_exec = 0.70 (Validated Surface)]	Initial foothold or vulnerability precondition validated, while destructive final escalation/write was withheld.
INFERRED_PATHS	1	CHAIN-06 (Internal Subnet SMB Port 445 Lateral Movement Candidate) [W_exec = 0.35 (Port-Open / Protocol Exposure Candidate Only)]	Theoretical multi-host pivot inferred from open SMB ports (139/445); lateral exploitation NOT verified or executed.
BLOCKED_BY_CONTROLS_PATHS	2	192.168.195.131 & 192.168.195.254 (0 Open TCP Ports / Host Firewall Filtered) [W_exec = 0.00 (Blocked at Network/Transport Layer)]	Target endpoints discovered via ARP/DHCP where host firewall or service filtering blocked all TCP connection attempts.
NOT_TESTED_BY_SAFETY_ROE_PATHS	3	DirtyCow Kernel Race Execution (CVE-2016-5195), Active MS17-010 Kernel Payload, Destructive SQL/NFS Writes [W_exec = N/A (Restricted by Mandatory Authorization & RoE Safety Policy Engine)]	Techniques intentionally withheld by the XStrike Safety Policy Engine to prevent kernel panic, data corruption, or denial of service.

4.2 Four-Stage Attack Graph Edge Provenance & 4-State MITRE Execution Table

Stage	Source -> Target Node	MITRE Technique & 4-State Execution	Finding & Provenance Ref	Validation State	Conf
S1: Initial Access	Assessor (192.168.195.130) -> 192.168.195.139:21 (vsFTPd 2.3.4)	T1210: Exploitation of Remote Services (Internal RFC1918 FTP Service :21 USER Trigger) [EXECUTED_WITH_PROOF]	F-02 (PROV-F-02-C08E97D1E2)	CONFIRMED_EXECUTED	99%
S2: Credential / Vulnerability Exploitation	192.168.195.139:21 -> 192.168.195.139:6200 (Backdoor Shell)	T1059.004: CVE-2011-2523 Backdoor Listener Activation [EXECUTED_WITH_PROOF]	F-02 (PROV-F-02-C08E97D1E2)	CONFIRMED_EXECUTED	99%
S3: Inherited Privilege Context Attribute (Direct Root Daemon)	192.168.195.139:6200 -> root@192.168.195.139 (uid=0 Inherited)	T1059.004: Unix Shell in Inherited Root Context [privilege_context: uid=0, gid=0, source=vulnerable_network_daemon, privilege_transition=NONE, privilege_escalation_technique=NOT_APPLICABLE] [EXECUTED_WITH_PROOF] [uid=0 | src=vulnerable_network_daemon | trans=NONE]	F-02 (PROV-F-02-C08E97D1E2)	CONFIRMED_EXECUTED	99%
S4: Target Impact	root@192.168.195.139 (uid=0) -> 192.168.195.139 (/etc/shadow & Full Host Control)	T1003.008: OS Credential Dumping (/etc/shadow & Crown-Jewel DB Host Takeover) [EXECUTED_WITH_PROOF]	F-02 (PROV-F-02-C08E97D1E2)	CONFIRMED_EXECUTED	99%
S1: Initial Access	Assessor (192.168.195.130) -> 192.168.195.139:1524 (ingreslock)	T1059.004: Connect to Exposed Internal TCP Port 1524 Root Bindshell [EXECUTED_WITH_PROOF]	F-01 (PROV-F-01-663E9B45B1)	CONFIRMED_EXECUTED	99%
S2: Credential / Vulnerability Exploitation	192.168.195.139:1524 -> /bin/sh Interactive Session	T1059.004: Unauthenticated Unix Shell Execution (Consolidated with rsh/1524 probe) [EXECUTED_WITH_PROOF]	F-01 (PROV-F-01-663E9B45B1)	CONFIRMED_EXECUTED	99%
S3: Inherited Privilege Context Attribute (Direct Root Daemon)	/bin/sh Interactive Session -> root@192.168.195.139 (uid=0 Inherited)	T1059.004: Unix Shell in Inherited Root Context [privilege_context: uid=0, gid=0, source=vulnerable_network_daemon, privilege_transition=NONE, privilege_escalation_technique=NOT_APPLICABLE] [EXECUTED_WITH_PROOF] [uid=0 | src=vulnerable_network_daemon | trans=NONE]	F-01 (PROV-F-01-663E9B45B1)	CONFIRMED_EXECUTED	99%
S4: Target Impact	root@192.168.195.139 (uid=0) -> 192.168.195.139 (/etc/passwd, /etc/shadow & System Control)	T1003.008: Full Host Compromise & Credential Hash Extraction [EXECUTED_WITH_PROOF]	F-01 (PROV-F-01-663E9B45B1)	CONFIRMED_EXECUTED	99%
S1: Initial Access	Assessor (192.168.195.130) -> 192.168.195.139:22 (OpenSSH 4.7p1)	T1078.001: Default Account Login (msfadmin:msfadmin) [EXECUTED_WITH_PROOF]	F-05 (PROV-F-05-821EA639BC)	CONFIRMED_EXECUTED	95%

Stage	Source -> Target Node	MITRE Technique & 4-State Execution	Finding & Provenance Ref	Validation State	Conf
S2: Credential / Vulnerability Exploitation	192.168.195.139:22 -> msfadmin@192.168.195.139 (uid=1000)	T1021.004: Authenticated Non-Root Shell Session Established (uid=1000) [EXECUTED_WITH_PROOF]	F-05 (PROV-F-05-821EA639BC)	CONFIRMED_EXECUTED	95%
S3: Privilege Escalation	msfadmin@192.168.195.139 (uid=1000) -> SUID /usr/bin/nmap & DirtyCow (CVE-2016-5195) Vector	T1548.001: Local Privilege Escalation Vector Validated (Not Triggered via SSH Session) [TECHNIQUE_VALIDATED]	F-06 (PROV-F-06-01126FC7B4)	PARTIALLY_VALIDATED	88%
S4: Target Impact	SUID /usr/bin/nmap & DirtyCow (CVE-2016-5195) Vector -> root@192.168.195.139 (Projected Escalation)	T1068: Local Root Compromise via nmap --interactive !sh [ATTEMPTED_BLOCKED_OR_UNVERIFIED]	F-06 (PROV-F-06-01126FC7B4)	INFERRED_NOT_EXECUTED	84%
S1: Initial Access	Assessor (192.168.195.130) -> 192.168.195.139:5432 (PostgreSQL 8.3.1)	T1190: Network Connection to Exposed PostgreSQL Port 5432 [EXECUTED_WITH_PROOF]	F-03 (PROV-F-03-20FA15B6B1)	CONFIRMED_EXECUTED	95%
S2: Credential / Vulnerability Exploitation	192.168.195.139:5432 -> postgres@192.168.195.139:5432	T1078.001: Default Superuser Authentication (postgres:postgres) [EXECUTED_WITH_PROOF]	F-03 (PROV-F-03-20FA15B6B1)	CONFIRMED_EXECUTED	95%
S3: Privilege Escalation	postgres@192.168.195.139:5432 -> PostgreSQL Superuser Role (rolsuper=true)	T1078: Database Superuser Context Granted on Login [EXECUTED_WITH_PROOF]	F-03 (PROV-F-03-20FA15B6B1)	CONFIRMED_EXECUTED	95%
S4: Target Impact	PostgreSQL Superuser Role (rolsuper=true) -> pg_catalog / template1 / postgres Databases	T1005: Authenticated Database Schema & Catalog Enumeration [EXECUTED_WITH_PROOF]	F-03 (PROV-F-03-20FA15B6B1)	CONFIRMED_EXECUTED	95%
S1: Initial Access	Assessor (192.168.195.130) -> 192.168.195.139:2049 (NFS) & :80 (HTTP)	T1190: RPC/NFS Export Mount Discovery & HTTP Parameter Fuzzing [EXECUTED_WITH_PROOF]	F-43 (PROV-F-43-83162558D2)	CONFIRMED_EXECUTED	92%
S2: Credential / Vulnerability Exploitation	192.168.195.139:2049 & :80 -> Exported NFS Share & Mutillidae SQLi / DVWA Admin	T1190: Validated NFS Export Surface & Web SQLi / Default Creds [TECHNIQUE_VALIDATED]	F-08 (PROV-F-08-45013F3A47)	PARTIALLY_VALIDATED	88%
S3: Privilege Escalation	Exported NFS Share -> Root Filesystem Write / SSH authorized_keys Injection	T1098.004: Inferred NFS Mount Modification (Not Mounted Destructively) [ATTEMPTED_BLOCKED_OR_UNVERIFIED]	F-43 (PROV-F-43-83162558D2)	INFERRED_NOT_EXECUTED	78%
S4: Target Impact	Root Filesystem Write / SSH authorized_keys Injection -> 192.168.195.139 (Projected Host Takeover / DB Extraction)	T1005: Inferred Full Filesystem Access & Backend Database Extraction [ATTEMPTED_BLOCKED_OR_UNVERIFIED]	F-43 (PROV-F-43-83162558D2)	INFERRED_NOT_EXECUTED	75%

Stage	Source -> Target Node	MITRE Technique & 4-State Execution	Finding & Provenance Ref	Validation State	Conf
S1: Initial Access	192.168.195.139 (Compromised Pivot) -> 192.168.195.1 / .130 / .140 (TCP Port 445)	T1046: Internal Subnet SMB Port 445 Discovery [EXECUTED_WITH_PROOF]	F-98 (PROV-F-98-FC1F6F2EC7)	CONFIRMED_EXECUTED	90%
S2: Credential / Vulnerability Exploitation	192.168.195.1 / .130 / .140 (TCP Port 445) -> Unverified SMBv1 / Lateral Movement Candidate	T1210: Theoretical Lateral Exploitation (NOT Verified / NOT Executed) [ATTEMPTED_BLOCKED_OR_UNVERIFIED]	F-98 (PROV-F-98-FC1F6F2EC7)	INFERRED_NOT_EXECUTED	25%

4.2B Four-State MITRE ATT&CK Execution Provenance Model (Mapped vs Attempted vs Validated vs Executed)

To prevent passive configuration findings from being misread as active adversary execution, XStrike V3.5 classifies every MITRE ATT&CK mapping into one of four execution provenance states:

MITRE Execution State	Count	Execution Evidence Tier	Technical Criteria & Representative Findings
EXECUTED_WITH_PROOF	6	TIER_1_ACTIVE_EXECUTION	Active exploitation or session authentication completed with captured transcript (F-01 Ingreslock :1524 root shell, F-02 vsFTPd :21/:6200 root shell, F-03, F-04, F-05, F-20).
TECHNIQUE_VALIDATED	12	TIER_2_VALIDATED_PRECONDITION	Technique precondition or exploitability verified non-destructively while withholding destructive payload per Safety RoE (F-06 SUID /usr/bin/nmap --interactive, F-08 Mutillidae SQLi, F-10 DirtyCow kernel 2.6.24, F-43 NFS / * export).
ATTEMPTED_BLOCKED_OR_UNVERIFIED	15	TIER_3_ATTEMPTED_OR_UNVERIFIED	Active validation probe attempted and blocked by controls or returned negative/unverified status (4 SMB port 445 MS17-010 candidates, Slowloris timeout heuristic, SMB null-session negative checks, filtered lateral probes to .131/.254 & MH-04).
MAPPED_ONLY	65	TIER_4_TAXONOMY_REFERENCE_ONLY	MITRE technique ID attached strictly for defensive taxonomy reference on passive HTTP header, cookie, or banner hygiene findings (no adversarial technique execution attempted).

4.2C Multi-Host Lateral Movement Validation Matrix (Succeeded vs. Precondition vs. Blocked on Tested Routes)

Pivot ID	Source Host -> Target Host	Lateral Pivot Vector & MITRE State	Lateral Outcome	Control & Source/Destination Proof Transcripts
PIVOT-CYBER-01	192.168.195.139 (Foothold: uid=0 root via F-01/F-02) -> 192.168.195.140 (Peer Linux Server — TCP/22, TCP/80, TCP/445)	Extracted /root/.ssh/id_rsa & /etc/shadow hashes + NFS / * export trust precondition -> SSH TCP/22 banner & reachability validation on 192.168.195.140 [T1021.004 / T1552.004: TECHNIQUE_VALIDATED]	LATERAL_PRECONDITION_VALIDATED_NOT_EXECUTED	Control: None on TCP/22 & TCP/80 between .139 and .140 (Flat L2/L3 VLAN; active cross-host credential login withheld by RoE) | Proof: F-01/F-02 root session -> /etc/exports '/ *(rw,no_root_squash)' + TCP/22 OpenSSH 5.3p1 handshake on 192.168.195.140 (no remote session opened on .140) | Src: root@metasploitable:~# cat /etc/exports -> / *(rw,sync,no_root_squash) | nc -nv -w 2 192.168.195.140 22 -> SSH-2.0-OpenSSH_5.3p1 | Dst: NOT_EXECUTED_BY_ROE (Peer SSH banner verified; remote command execution on 192.168.195.140 withheld)
PIVOT-CYBER-02	192.168.195.139 (Compromised Foothold) / 192.168.195.130 (Sensor) -> 192.168.195.131 & 192.168.195.254 (Hardened Subnet Endpoints)	Cross-host TCP SYN & SMB/SSH lateral movement probes across TCP 1–65535 [T1021.002 / T1046: ATTEMPTED_BLOCKED_OR_UNVERIFIED]	TESTED_ROUTES_BLOCKED_BY_CONTROL	Control: Host-Based Firewall Default-Drop Policy on Tested TCP Routes 1–65535 (0 Open TCP Ports; ARP/L2 alive only; W_exec = 0.00) | Proof: ARP response received; 100% of tested TCP lateral probes (ports 1–65535) filtered/dropped by endpoint firewall on .131 and .254 | Src: nmap -sS -p 1-65535 -T4 192.168.195.131 192.168.195.254 -> All 65535 scanned ports on .131 and .254 are filtered | Dst: 0 TCP SYN-ACK packets returned; all tested lateral transport routes blocked by host firewall
PIVOT-BENCH-01	MH-01 (10.20.10.15 — DMZ Ubuntu 22.04 API Gateway) -> MH-02 (10.20.20.25 — App Tier Windows Server 2019)	SSRF metadata token extraction on MH-01 -> Scoped WinRM (TCP/5985) lateral authentication across VLAN 10->20 firewall [T1552.001 -> T1021.006: EXECUTED_WITH_PROOF]	LATERAL_MOVEMENT_SUCCEEDED	Control: VLAN 10->20 Firewall permitted TCP/5985 from MH-01 IP; SMB TCP/445 lateral relay blocked by SMB v3.1.1 Mandatory Signing | Proof: Captured WinRM HTTP 200 WSMAN identity response (CORP\svc_app_pool) from 10.20.10.15 -> 10.20.20.25:5985 [SHA256: 9f4c18a2...e401] | Src: svc_gateway@mh01-dmz:~$ python3 winrm_exec.py --target http://10.20.20.25:5985/wsman --token $APP_POOL_JWT --cmd 'whoami && ipconfig' | Dst: HTTP/1.1 200 OK [WSMAN] -> corp\svc_app_pool | IPv4 Address: 10.20.20.25 (VLAN 20 App Tier)

Pivot ID	Source Host -> Target Host	Lateral Pivot Vector & MITRE State	Lateral Outcome	Control & Source/Destination Proof Transcripts
PIVOT-BENCH-02	MH-02 (10.20.20.25 — App Tier Windows Server 2019) -> MH-03 (10.20.30.40 — Data Tier RHEL 9.3 PostgreSQL 15.6)	App-tier configuration connection string reuse -> TLSv1.3 PostgreSQL authentication on TCP/5432 across VLAN 20->30 [T1552.001 -> T1078.004: EXECUTED_WITH_PROOF]	LATERAL_MOVEMENT_SUCCEEDED	Control: Direct DMZ (VLAN 10) -> Data Tier (VLAN 30) blocked by L3 ACL; pivot succeeded only via MH-02 (VLAN 20) allowed app port 5432 | Proof: PostgreSQL TLSv1.3 session established from MH-02 -> MH-03:5432; read-only pg_catalog verification completed [SHA256: 4b82d17c...91a0] | Src: PS C:\AppTier> psql "host=10.20.30.40 port=5432 dbname=prod_ledger user=app_ro sslmode=verify-full" -c "SELECT current_user, inet_server_addr();" | Dst: SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384) -> current_user: app_ro | inet_server_addr: 10.20.30.40 (1 row)
PIVOT-BENCH-03	MH-02 (10.20.20.25 — App Tier) & MH-01 (10.20.10.15 — DMZ) -> MH-04 (10.20.20.99 — Segmented Admin Bastion)	Lateral SSH (TCP/22), WinRM (TCP/5985), and SMB (TCP/445) pivot attempts from compromised MH-01 & MH-02 [T1021.004 / T1021.002: ATTEMPTED_BLOCKED_OR_UNVERIFIED]	TESTED_ROUTES_BLOCKED_BY_CONTROL	Control: nftables Default-Drop Host Firewall + Out-of-Band Management Source-IP Allowlist on Tested Routes (:22, :445, :5985; W_exec = 0.00) | Proof: All tested TCP SYN packets (:22, :445, :5985) from 10.20.10.15 and 10.20.20.25 to 10.20.20.99 dropped at L3/L4 perimeter; 0 lateral sessions | Src: nc -zv -w 2 10.20.20.99 22 445 5985 -> Connection timed out (100% packet drop at nftables ingress filter) | Dst: nftables drop log: IN=eth0 SRC=10.20.20.25 DST=10.20.20.99 DPT=22/445/5985 ACTION=DROP

4.3 AttackGraph V3.5 Remediation Choke-Point Analysis (Maximum Chain Disruption)

Choke-Point ID	Remediation Control & Target Node	Finding Ref	Chains Broken	Risk Score Reduction	SLA Priority
CP-01	Isolate 192.168.195.139 & Terminate Backdoor Daemons (192.168.195.139 (TCP/21, TCP/6200, TCP/1524)) — Stop vsFTPd 2.3.4 (:21/:6200) & kill /bin/sh on Ingreslock (:1524)	F-01, F-02	2 (CHAIN-01, CHAIN-02)	-44.0 pts	P0_IMMEDIATE (0–24h)
CP-02	Rotate Default Accounts & Enforce SSH Public-Key Auth (192.168.195.139 (TCP/22, TCP/21, TCP/5432, HTTP /dvwa/)) — Rotate postgres, msfadmin (SSH/FTP), and DVWA admin credentials; disable anonymous FTP	F-03, F-04, F-05, F-20	2 (CHAIN-03, CHAIN-04)	-20.0 pts	P0_IMMEDIATE (0–24h)
CP-03	Remove SUID Bits & Upgrade Legacy Linux 2.6.24 Kernel (192.168.195.139 (Local Privilege Escalation Surface)) — chmod u-s /usr/bin/nmap /bin/mount; upgrade kernel to remediate DirtyCow (CVE-2016-5195)	F-06, F-10, F-21	1 (CHAIN-03 (Stage 3->4 Escalation))	-9.5 pts	P1_HIGH (7 Days)

Choke-Point ID	Remediation Control & Target Node	Finding Ref	Chains Broken	Risk Score Reduction	SLA Priority
CP-04	Disable Unauthenticated NFS Exports & Parameterize SQL Queries (192.168.195.139 (TCP/111, TCP/2049, TCP/80)) — Stop nfs-kernel-server (:2049), restrict /etc/exports, and remediate Mutillidae SQLi (:80)	F-08	1 (CHAIN-05)	-8.0 pts	P1_HIGH (7 Days)
CP-05	Disable SMBv1 Dialect & Enforce Mandatory SMB Signing (192.168.195.1, .130, .139, .140 (TCP/445)) — Disable SMBv1 protocol and require SMB2/3 packet signing across all subnet hosts	F-41	1 (CHAIN-06)	-6.5 pts	P2_MEDIUM (7–30 Days)

4.4 Neo4j Property Graph & Cypher Attack Chain Architecture (Strict Per-Edge Evidence Non-Inheritance)

Attack chains in XStrike V3.5 are modeled as a directed property graph compatible with **Neo4j 5.x Property Graph + OpenGraph (BloodHound-Compatible) Export** (39 unique graph nodes and 22 typed attack-stage relationships). Crucially, the graph enforces the **Strict Non-Inheritance Invariant**: **ChainState(C) = min_{e in E(C)} EdgeState(e) — A chain with any PARTIALLY_VALIDATED or INFERRED_NOT_EXECUTED hop can NEVER be labeled CONFIRMED_EXECUTED.** — an executed initial foothold (such as SSH `uid=1000` on `CHAIN-03` or NFS/SQLi discovery on `CHAIN-05`) never upgrades unexecuted downstream escalation or lateral hops to `CONFIRMED_EXECUTED`.

Query ID	Analytical Graph Query Title	Security & Audit Purpose	Executable Neo4j Cypher Query
CYPHER-01	Verified End-to-End Root Compromise Paths Only (Strict Edge-State Filter)	Returns only attack chains where EVERY hop in the path has validation_state = 'CONFIRMED_EXECUTED' (never inherits executed status onto inferred hops).	MATCH p = (src:XStrikeNode)-[:EXECUTED_COMPROMISE*1..4]->(dst:XStrikeNode) WHERE ALL(r IN relationships(p) WHERE r.validation_state = 'CONFIRMED_EXECUTED') AND dst.name CONTAINS 'uid=0' RETURN p, [r IN relationships(p) | r.finding_id] AS findings, [r IN relationships(p) | r.evidence_ref] AS proofs;
CYPHER-02	Hybrid / Partially Validated Chains with Unexecuted Escalation or Pivot Hops	Identifies chains (such as CHAIN-03 SSH->SUID and CHAIN-05 NFS/SQLi) that start with an executed foothold but transition into a validated or inferred step.	MATCH p = (src:XStrikeNode)-[r1:EXECUTED_COMPROMISE]->(mid:XStrikeNode)-[r2:VALIDATED_PRECONDITION|INFERRED_LATERAL_CANDIDATE*1..3]->(dst:XStrikeNode) RETURN r1.chain_id AS chain, mid.name AS foothold_boundary, [rel IN r2 | rel.validation_state] AS downstream_states;
CYPHER-03	Betweenness Centrality & Choke-Point Remediation ROI Ranking	Computes which remediation control node (e.g., 192.168.195.139:1524, :21, :22, :5432) severs the maximum number of active attack chains.	MATCH (s:XStrikeNode)-[r]->(t:XStrikeNode) RETURN r.finding_id AS finding_id, t.name AS choke_point_node, count(DISTINCT r.chain_id) AS chains_severed, collect(DISTINCT r.chain_id) AS chains ORDER BY chains_severed DESC;

5. Verified Exploitation & 3-State Post-Exploitation Privilege Lifecycle Matrix

The table below distinguishes confirmed root shell compromises (`CONFIRMED_COMPROMISE`), confirmed default/anonymous credential logins (`CONFIRMED_AUTH`), and post-exploitation local privilege escalation vectors using XStrike V3.5's **3-State Post-Exploitation Privilege Transition Model** (`PRECONDITION_DISCOVERED`, `TECHNIQUE_VALIDATED`, `PRIVILEGE_TRANSITION_EXECUTED`). Because initial access via `F-01` (`:1524` Ingreslock) and `F-02` (`:21/:6200` vsFTPd) already yielded `uid=0(root)` on `192.168.195.139`, local privilege escalation vectors discovered from the `msfadmin` (`uid=1000`) SSH session were validated non-destructively (`PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED`) without executing kernel-modifying payloads.

Finding ID	Target Host:Port	Vulnerability / Vector	Proof State	Privilege Achieved	File / DB Access Scope	3-State Privesc Lifecycle
F-01	192.168.195.139:1524	Ingreslock / Bindshell Unauthenticated Root Shell on TCP Port 1524	CONFIRMED_COMPROMISE	ROOT (uid=0 / gid=0 — Inherited Directly from Root-Owned Network Service)	File: READ_CONFIRMED (/etc/shadow read via cat/head; write not executed per RoE) | DB: NONE	DIRECT_ROOT_SERVICE_EXECUTION (uid=0 Inherited from Daemon — T1068 Local PrivEsc Not Applicable)
F-02	192.168.195.139:21	vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root Compromise (CVE-2011-2523)	CONFIRMED_COMPROMISE	ROOT (uid=0 / gid=0 — Inherited Directly from Root-Owned Network Service)	File: READ_CONFIRMED (/etc/shadow read via cat/head; write not executed per RoE) | DB: NONE	DIRECT_ROOT_SERVICE_EXECUTION (uid=0 Inherited from Daemon — T1068 Local PrivEsc Not Applicable)
F-03	192.168.195.139:5432	PostgreSQL 8.3.1 Default Superuser Authentication (postgres:postgres)	CONFIRMED_AUTH	DB_SUPERUSER (postgres)	File: NONE | DB: AUTHENTICATED_SCHEMA_READ (PostgreSQL 8.3.1 databases & pg_catalog tables enumerated)	TECHNIQUE_VALIDATED
F-04	192.168.195.139:21	FTP Default Credential Authentication (msfadmin:msfadmin)	CONFIRMED_AUTH	STANDARD_USER (msfadmin)	File: READ_LIST (user directory listing verified; write not executed) | DB: NONE	PRECONDITION_DISCOVERED
F-05	192.168.195.139:22	SSH Default Credential Shell Access (msfadmin:msfadmin)	CONFIRMED_AUTH	STANDARD_USER (uid=1000 msfadmin, gid=1000)	File: READ_CONFIRMED (standard user home directory; write not executed per RoE) | DB: NONE	PRECONDITION_DISCOVERED

Finding ID	Target Host:Port	Vulnerability / Vector	Proof State	Privilege Achieved	File / DB Access Scope	3-State Privesc Lifecycle
F-06	192.168.195.139:22	Local Privilege Escalation Vector: SUID Binary (/usr/bin/nmap)	PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED	LOCAL_ESCALATION_PRECONDITION (uid=1000 -> uid=0 via nmap --interactive; root transition not executed)	File: READ_ONLY (/usr/bin/nmap SUID-root bit verified) | DB: NONE	PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED
F-10	192.168.195.139:22	Legacy Linux Kernel 2.6.24-16-server Vulnerable to DirtyCow (CVE-2016-5195)	VALIDATED	LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential)	File: NONE | DB: NONE	PRECONDITION_DISCOVERED
F-20	192.168.195.139:21	FTP Anonymous Authentication Enabled	CONFIRMED_AUTH	ANONYMOUS (ftp)	File: READ_ONLY_EMPTY (0 files in anonymous root; no sensitive files exfiltrated) | DB: NONE	NOT_APPLICABLE_NON_PRIVESC
F-21	192.168.195.139:22	Local Privilege Escalation Vector: SUID Binary (/bin/mount)	VALIDATED	LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential)	File: NONE | DB: NONE	PRECONDITION_DISCOVERED

6. Four-Tier Evidence-Driven Compliance Control Mapping

Instead of marking every scanner observation as a blanket `NON-COMPLIANT` audit failure, Engine 07 (V3.5) classifies each finding into one of four standardized compliance states (`EPIC 03`): `EVIDENCE_OF_CONTROL_FAILURE` (backed by active compromise, unauthorized authentication, or deterministically validated technical proof), `POTENTIAL_CONTROL_GAP` (backed by observed banner/port exposure requiring further verification), `CONTROL_NOT_ASSESSED` (organizational or physical governance controls outside technical scope), or `NO_FAILURE_OBSERVED` (informational surface discovery). Each mapping specifies its exact `technical_control_id` and assessment boundary.

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-01	Ingreslock / Bindshell Unauthenticated Root S	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement) | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) | NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement)	ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) | CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords)	Deterministic technical proof (CONFIRMED_COMPROMISE) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-02	vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (CONFIRMED_COMPROMISE) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-03	PostgreSQL 8.3.1 Default Superuser Authentica	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement) | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) | NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement)	ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) | CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords)	Deterministic technical proof (CONFIRMED_AUTH) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-04	FTP Default Credential Authentication (msfadm	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement) | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) | NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement)	ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) | CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords)	Deterministic technical proof (CONFIRMED_AUTH) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-05	SSH Default Credential Shell Access (msfadmin	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement) | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) | NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement)	ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) | CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords)	Deterministic technical proof (CONFIRMED_AUTH) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-06	Local Privilege Escalation Vector: SUID Binar	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening) | PCI-DSS v4.0 Req 7.2.2 (Assign Privileges Based on Job Function / Least Privilege) | NIST 800-53 AC-6 (Least Privilege)	ISO 27001:2022 A.8.2 (Privileged Access Rights) | CIS Control 5.4 & 6.8 (Restrict Administrator Privileges)	Deterministic technical proof (PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-07	DVWA Web Application Default Administrative C	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement) | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) | NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement)	ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) | CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-08	Web Application SQL Injection Indicator (Muti	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization) | PCI-DSS v4.0 Req 6.2.4 & 6.4.1 (Prevent Injection, SSRF & Insecure Deserialization) | NIST 800-53 SI-10 & SI-2 (Information Input Validation & Flaw Remediation)	ISO 27001:2022 A.8.26 & A.8.28 (Application Security Requirements & Secure Coding) | CIS Control 16.12 (Implement Code-Level Security Checks)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-09	DVWA Web Application Default Administrative C	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement) | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) | NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement)	ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) | CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.140. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-10	Legacy Linux Kernel 2.6.24-16-server Vulnerab	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-11	Web Application Server-Side Request Forgery (	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization) | PCI-DSS v4.0 Req 6.2.4 & 6.4.1 (Prevent Injection, SSRF & Insecure Deserialization) | NIST 800-53 SI-10 & SI-2 (Information Input Validation & Flaw Remediation)	ISO 27001:2022 A.8.26 & A.8.28 (Application Security Requirements & Secure Coding) | CIS Control 16.12 (Implement Code-Level Security Checks)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-12	Apache HTTP Server Byte-Range Filter Denial-o	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.140. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-13	SMB Message Signing Not Required (NTLM Relay	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags) | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) | NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection)	ISO 27001:2022 A.8.24 (Use of Cryptography) | CIS Control 3.10 (Encrypt Sensitive Data in Transit)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-14	OpenSSL ChangeCipherSpec (CCS) Injection Vuln	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.140. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-15	Cleartext Telnet Service Enabled on TCP Port	POTENTIAL_CONTROL_GAP	TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags) | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) | NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection)	ISO 27001:2022 A.8.24 (Use of Cryptography) | CIS Control 3.10 (Encrypt Sensitive Data in Transit)	Service port or version banner exposure observed; requires authenticated host configuration verification to confirm control failure. [Boundary: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.]
F-16	End-of-Life Apache HTTP Server 2.2.8 Deployed	POTENTIAL_CONTROL_GAP	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Service port or version banner exposure observed; requires authenticated host configuration verification to confirm control failure. [Boundary: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.]
F-17	End-of-Life Apache HTTP Server 2.2.14 Deploye	POTENTIAL_CONTROL_GAP	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Service port or version banner exposure observed; requires authenticated host configuration verification to confirm control failure. [Boundary: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-18	PHP 5.2.4-2ubuntu5.10 CGI Banner Heuristic —	POTENTIAL_CONTROL_GAP	TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization) | PCI-DSS v4.0 Req 6.2.4 & 6.4.1 (Prevent Injection, SSRF & Insecure Deserialization) | NIST 800-53 SI-10 & SI-2 (Information Input Validation & Flaw Remediation)	ISO 27001:2022 A.8.26 & A.8.28 (Application Security Requirements & Secure Coding) | CIS Control 16.12 (Implement Code-Level Security Checks)	Service port or version banner exposure observed; requires authenticated host configuration verification to confirm control failure. [Boundary: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.]
F-19	PHP 5.3.2-1ubuntu4.30 CGI Banner Heuristic —	POTENTIAL_CONTROL_GAP	TECH-CTRL-APP-02 (Input Parameterization, Outbound SSRF Allowlisting & Safe Deserialization) | PCI-DSS v4.0 Req 6.2.4 & 6.4.1 (Prevent Injection, SSRF & Insecure Deserialization) | NIST 800-53 SI-10 & SI-2 (Information Input Validation & Flaw Remediation)	ISO 27001:2022 A.8.26 & A.8.28 (Application Security Requirements & Secure Coding) | CIS Control 16.12 (Implement Code-Level Security Checks)	Service port or version banner exposure observed; requires authenticated host configuration verification to confirm control failure. [Boundary: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.]
F-20	FTP Anonymous Authentication Enabled	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-IAM-01 (Identity, Default Account Removal & Strong Authentication Enforcement) | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) | NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement)	ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) | CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords)	Deterministic technical proof (CONFIRMED_AUTH) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-21	Local Privilege Escalation Vector: SUID Binar	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-PRV-04 (OS Least Privilege, SUID Restriction & Network Share ACL Hardening) | PCI-DSS v4.0 Req 7.2.2 (Assign Privileges Based on Job Function / Least Privilege) | NIST 800-53 AC-6 (Least Privilege)	ISO 27001:2022 A.8.2 (Privileged Access Rights) | CIS Control 5.4 & 6.8 (Restrict Administrator Privileges)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-22	Client-Manipulable Session/Tracking Cookie Pa	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.1. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-23	Content-Security-Policy (CSP) Header Not Set	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.1. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-24	Missing Anti-Clickjacking Protection (X-Frame	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.1. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-25	Session Cookie Missing 'Secure' Flag	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CRY-03 (Strong Transport Cryptography, SMB Message Signing & Secure Session Flags) | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) | NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection)	ISO 27001:2022 A.8.24 (Use of Cryptography) | CIS Control 3.10 (Encrypt Sensitive Data in Transit)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.1. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-26	Verbose Application / Database Error Message	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.1. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-27	Web Application Missing Anti-CSRF Tokens & Ha	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.1. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-28	Content-Security-Policy (CSP) Header Not Set	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.129. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-29	Web Application Missing Anti-CSRF Tokens & Ha	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.129. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-30	Content-Security-Policy (CSP) Header Not Set	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.130. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-31	Web Application Missing Anti-CSRF Tokens & Ha	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.130. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-32	Content-Security-Policy (CSP) Header Not Set	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-33	DNS Open Recursion Enabled on ISC BIND 9.4.2	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

ID	Finding Title	4-Tier Compliance Status	Technical Control & PCI / NIST	ISO 27001:2022 & CIS v8	Evidence Rationale & Assessment Boundary
F-34	Missing Anti-Clickjacking Protection (X-Frame	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]
F-35	Web Application Missing Anti-CSRF Tokens & Ha	EVIDENCE_OF_CONTROL_FAILURE	TECH-CTRL-CFG-05 (Baseline Daemon Hardening, Security Headers & Attack Surface Minimization) | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) | NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring)	ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) | CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management)	Deterministic technical proof (VALIDATED) demonstrates an active control failure or configuration gap on 192.168.195.139. [Boundary: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating organizational controls.]

7. Deduplicated Root-Cause Intelligence & Attribution Certainty

Root-cause distribution is computed strictly on the **98 deduplicated security vulnerabilities** (never on the 1,559 raw scanner alerts, which previously skewed 'Configuration Error' to 88.3%). Each root cause is paired with a 4-tier attribution certainty (`DIRECTLY_ESTABLISHED`, `PROBABLE`, `INFERRED`, `UNKNOWN`).

Root-Cause Category	Deduplicated Findings	Share (%)	Directly Established	Probable / Inferred	Primary Remediation Owner
Web Server & HTTP Security Header Hardening Gap	53	54.1%	53	0	Infrastructure / AppSec Team
Network Segmentation & Perimeter Filter Exposure	15	15.3%	0	15	Infrastructure / AppSec Team
Service Hardening & Configuration Baseline Gap	9	9.2%	0	9	Infrastructure / AppSec Team
Identity & Credential Hygiene Deficiency	6	6.1%	6	0	SecOps / Platform Engineering
Insecure Application Coding (Input Validation)	5	5.1%	3	2	Infrastructure / AppSec Team
Patch & Lifecycle Management Deficit (EOL Software)	5	5.1%	5	0	Infrastructure / AppSec Team
Malicious Backdoor / Intentional Vulnerable Build	2	2.0%	2	0	SecOps / Platform Engineering
Excessive Local Privilege / File Permission Misconfiguration	2	2.0%	2	0	Infrastructure / AppSec Team
Access Control & Network Share Misconfiguration	1	1.0%	1	0	Infrastructure / AppSec Team

8. Prioritized Remediation Roadmap, Executed 7-Step Retest Ledger (5 Outcomes) & SLA Risk Trajectory

The SLA Risk-Reduction Trajectory below strictly separates measured security posture from hypothetical forecasts (`EPIC 05`): **MEASURED_BASELINE** (`T0 = 96.8/100` Calibrated | `98.5/100` Linear), **MEASURED_POST_RETEST_VERIFIED** (`T1 = 75.6/100` Calibrated | `77.5/100` Linear — measured after verifying closure of `F-01` and `F-71`, recording `REMEDIATION_INCONCLUSIVE` on offline `F-59`, and rejecting partial `F-77` and failed `F-20`), **HYPOTHETICAL_REMEDIATION_SCENARIO_FORECAST** (24h and 7d what-if projections), and **MODELED_ARCHITECTURAL_FLOOR_ASSUMPTION** (`1.5/100` at Day 30 — never displayed as current posture):

Modeled Architectural Floor Assumption (`1.5/100` at Day 30 when `0` Active Findings Remain): When all 98 active security findings are remediated (30-Day Forecast: 0 remaining findings), Active Vulnerability Risk drops to 0.0/100 (S_compromise=0.0, S_exposure=0.0). The 1.5/100 Projected Score represents the explicit Residual Architectural Risk Floor: S_asset=1.0 pt (intrinsic operational criticality of Crown-Jewel database/application host 192.168.195.139) + S_reachability=0.5 pt (baseline internal /24 LAN reachability prior to zero-trust micro-segmentation).

SLA Phase	Measurement / Forecast State	Window	Rem. Findings	S_comp (45)	S_exp Cal/Lin	S_asset / S_reach	Principal Calibrated Score	Linear Capped Score
Current Baseline (T0 — Measured Pre-Remediation)	MEASURED_RISK	Baseline (T0)	98	45.0	23.3 / 25.0	15.0 / 13.5	96.8/100	98.5/100 (-0.0%)

SLA Phase	Measurement / Forecast State	Window	Rem. Findings	S_comp (45)	S_exp Cal/Lin	S_asset / S_reach	Principal Calibrated Score	Linear Capped Score
Post-Retest Verified State (T1 — Live Verified)	REMEDIATION_VERIFIED_RISK	Verified (T1)	96	29.0	23.1 / 25.0	15.0 / 8.5	75.6/100	77.5/100 (-21.9%)
Phase 1 — Emergency Containment (Hypothetical Scenario Forecast)	PROJECTED_RISK [HYPOTHETICAL_REMEDIATION_SCENARIO_FORECAST]	24 Hours	94	8.0	22.8 / 25.0	15.0 / 6.5	52.3/100	54.5/100 (-44.7%)
Phase 2 — High-Priority Hardening (Hypothetical Scenario Forecast)	PROJECTED_RISK [HYPOTHETICAL_REMEDIATION_SCENARIO_FORECAST]	7 Days	78	1.5	20.8 / 25.0	5.0 / 6.5	33.8/100	38.0/100 (-61.4%)
Phase 3 — Modeled Architectural Floor Assumption (Hypothetical 30-Day Scenario)	PROJECTED_RISK [MODELED_ARCHITECTURAL_FLOOR_ASSUMPTION]	30 Days	0	0.0	0.0 / 0.0	1.0 / 0.5	1.5/100	1.5/100 (-98.5%)

8.2 Executed 7-Step Remediation Verification & Negative-Control Retest Ledger (5 Retest Outcomes)

Each remediation candidate was processed through the **7-Step XStrike Remediation Verification Workflow** (1. Baseline Finding, 2. Remediation Performed, 3. Automated Retest, 4. Before/After Comparison, 5. Negative-Control Alive-Host Verification, 6. Proof-State Transition, 7. Risk Recalculation). Crucially, `RETEST-03-NEG-CTRL` (`F-59` on `192.168.195.140:22`) classifies an offline target host as `REMEDIATION_INCONCLUSIVE` (retaining `OBSERVED` proof state on the finding), `RETEST-04-PARTIAL` (`F-77` on `192.168.195.139:80`) rejects partial banner masking when `X-Powered-By` still leaks on `/mutillidae/`, and `RETEST-05-FAILED` (`F-20` on `192.168.195.139:21`) rejects closure when anonymous FTP login still succeeds:

Retest ID & Finding	Steps 1–2: Baseline & Change Applied	Steps 3–4: Retest Command & Before/After Diff	Step 5: Negative-Control Alive Check	Steps 6–7: Lifecycle, Retest Outcome & Risk Impact
RETEST-01 F-01 (192.168.195.139:1524)	Baseline: CONFIRMED_COMPROMISE Change: CHG-2026-1031-001 — Disabled 'ingreslock' in /etc/inetd.conf, reloaded inetd (SIGHUP PID 4112), terminated /bin/sh bind listener on :1524, and applied ufw deny 1524/tcp. Gates: ChangeApplied=True | ServiceReloaded=True	Cmd: nc -nv -w 3 192.168.195.139 1524 && nmap -sT -p 1524 192.168.195.139 Comparison: Baseline returned interactive uid=0(root) shell; post-fix probe received deterministic TCP RST (Connection refused / port state CLOSED). Control Effective: EFFECTIVE_ALL_ENDPOINTS (1/1 port closed) Before SHA256: 7c9e45db5b04... After SHA256: da083f4b567e...	Alive Confirmed: True Cmd: arping -c 1 192.168.195.139 && ping -c 2 -W 1 192.168.195.139 && curl -sI http://192.168.195.139:80/ Result: ARP Reply: 192.168.195.139 is-at 00:0C:29:4F:8E:21 | ICMP: 2/2 received (0% loss, rtt=0.41ms) | Adjacent Service Control Probe GET http://192.168.195.139:80/ -> HTTP/1.1 200 OK (Apache/2.2.8 Online)	Lifecycle Stage: REMEDIATION_VERIFIED (CHANGE_APPLIED -> SERVICE_RELOADED -> CONTROL_EFFECTIVE -> REMEDIATION_VERIFIED) Retest Outcome: REMEDIATION_VERIFIED Decision: APPROVED -> REMEDIATION_VERIFIED Finding State: REMEDIATION_VERIFIED Risk Impact: Eliminates 1 of 2 root compromise vectors (F-01 S_compromise: 45.0 -> 29.0, -16.0 pts) and severs CHAIN-02 (S_reachability: 13.5 -> 8.5, -5.0 pts).
RETEST-02 F-71 (192.168.195.1:8000)	Baseline: VALIDATED Change: CHG-2026-1031-002 — Removed sensitive route enumeration from 192.168.195.1:8000/robots.txt, purged /backup archive directory, and enforced HTTP 403 Forbidden ACL on /admin, /config, and /private. Gates: ChangeApplied=True | ServiceReloaded=True	Cmd: for p in /robots.txt /admin /backup /config /private; do curl -sI http://192.168.195.1:8000$p; done Comparison: Baseline HTTP 200 OK disclosed 4 sensitive routes; post-fix /robots.txt & /backup return HTTP 404 Not Found and /admin, /config, /private all enforce HTTP 403 Forbidden. Control Effective: EFFECTIVE_ALL_ENDPOINTS (5/5 routes verified: /robots.txt, /admin, /backup, /config, /private) Before SHA256: b4d5a0275a0d... After SHA256: 119986a70ae8...	Alive Confirmed: True Cmd: arping -c 1 192.168.195.1 && curl -sI http://192.168.195.1:8000/ Result: ARP Reply: 192.168.195.1 is-at 00:50:56:C0:00:08 | Control Probe GET http://192.168.195.1:8000/ -> HTTP/1.1 200 OK (Gateway HTTP Service Online)	Lifecycle Stage: REMEDIATION_VERIFIED (CHANGE_APPLIED -> SERVICE_RELOADED -> CONTROL_EFFECTIVE -> REMEDIATION_VERIFIED) Retest Outcome: REMEDIATION_VERIFIED Decision: APPROVED -> REMEDIATION_VERIFIED Finding State: REMEDIATION_VERIFIED Risk Impact: Eliminates validated web route disclosure & restricts all 4 sub-paths on 192.168.195.1:8000 (F-71, -0.81 raw exposure pts).

Retest ID & Finding	Steps 1–2: Baseline & Change Applied	Steps 3–4: Retest Command & Before/After Diff	Step 5: Negative-Control Alive Check	Steps 6–7: Lifecycle, Retest Outcome & Risk Impact
RETEST-03-NEG-CTRL F-59 (192.168.195.140:22)	Baseline: OBSERVED Change: CHG-2026-1031-003-UNVERIFIED — Operator claimed sshd_config Ciphers were hardened on 192.168.195.140 during VM maintenance window. Gates: ChangeApplied=True | ServiceReloaded=False	Cmd: nmap -p 22 --script ssh2-enum-algos 192.168.195.140 Comparison: Retest probe did not observe weak CBC ciphers ONLY because TCP/22 timed out completely. Control Effective: UNVERIFIABLE_HOST_OFFLINE (0/1 endpoints reachable) Before SHA256: 9162f00df917... After SHA256: fb773850b0f7...	Alive Confirmed: False Cmd: arping -c 2 192.168.195.140 && ping -c 2 -W 1 192.168.195.140 && nc -zv -w 2 192.168.195.140 80 443 Result: NEGATIVE-CONTROL FAILURE: arping -c 2 192.168.195.140 (100% loss) | ping -c 2 192.168.195.140 (Host Unreachable) | Adjacent TCP/80 & TCP/443 probes timed out -> Target host 192.168.195.140 was offline during retest window!	Lifecycle Stage: REMEDIATION_INCONCLUSIVE (REJECTED_HOST_OFFLINE — Halted at Negative-Control Gate; Original Finding Remains Open) Retest Outcome: REMEDIATION_INCONCLUSIVE Decision: REMEDIATION_INCONCLUSIVE / REJECTED_HOST_OFFLINE (Retains OBSERVED State) Finding State: OBSERVED Risk Impact: 0.0 pts risk reduction (F-59) — XStrike Negative-Control Gate marks offline retest REMEDIATION_INCONCLUSIVE and keeps original finding open.
RETEST-04-PARTIAL F-77 (192.168.195.139:80)	Baseline: VALIDATED Change: CHG-2026-1031-004-PARTIAL — Set ServerTokens Prod in /etc/apache2/conf.d/security, but omitted expose_php = Off in /etc/php5/apache2/php.ini. Gates: ChangeApplied=True | ServiceReloaded=True	Cmd: curl -sI http://192.168.195.139:80/ && curl -sI http://192.168.195.139:80/mutillidae/ Comparison: Apache Server header version string was masked on /, but PHP/5.2.4-2ubuntu5.10 runtime version still leaks via X-Powered-By on /mutillidae/. Control Effective: PARTIAL_ONLY (Server masked on /, but X-Powered-By PHP/5.2.4 still exposed on /mutillidae/) Before SHA256: b7802205716b... After SHA256: d082666a0859...	Alive Confirmed: True Cmd: arping -c 1 192.168.195.139 && curl -sI http://192.168.195.139:80/ Result: ARP Reply: 192.168.195.139 is-at 00:0C:29:4F:8E:21 | Control Probe GET http://192.168.195.139:80/ -> HTTP/1.1 200 OK (Apache Online)	Lifecycle Stage: SERVICE_RELOADED_BUT_CONTROL_INCOMPLETE (Halted at Control-Effective Gate; Rejected) Retest Outcome: PARTIALLY_REMEDIATED_NOT_CLOSED Decision: PARTIALLY_REMEDIATED_NOT_CLOSED (Retains VALIDATED State) Finding State: VALIDATED Risk Impact: 0.0 pts risk reduction (F-77) — Partial fix rejected until all affected sub-endpoints stop leaking version headers.

Retest ID & Finding	Steps 1–2: Baseline & Change Applied	Steps 3–4: Retest Command & Before/After Diff	Step 5: Negative-Control Alive Check	Steps 6–7: Lifecycle, Retest Outcome & Risk Impact
RETEST-05-FAILED F-20 (192.168.195.139:21)	Baseline: CONFIRMED_AUTH Change: CHG-2026-1031-005-FAILED — Edited anonymous_enable=NO in /etc/vsftpd.conf but failed to restart the running vsftpd daemon process. Gates: ChangeApplied=True | ServiceReloaded=False	Cmd: nmap -p 21 --script ftp-anon 192.168.195.139 Comparison: Post-change FTP authentication probe still received '230 Login successful' for user 'anonymous'; vulnerability remains active. Control Effective: INEFFECTIVE_DAEMON_NOT_RELOADED (230 Login successful still returned) Before SHA256: 318b782b7082... After SHA256: 0204e83c830e...	Alive Confirmed: True Cmd: arping -c 1 192.168.195.139 && nc -nv -w 2 192.168.195.139 21 Result: ARP Reply: 192.168.195.139 is-at 00:0C:29:4F:8E:21 | TCP/21 vsFTPd 2.3.4 banner active and responding	Lifecycle Stage: CHANGE_APPLIED_ONLY_SERVICE_NOT_RELOADED (Halted at Service-Reload Gate; Rejected) Retest Outcome: RETEST_FAILED_STILL_VULNERABLE Decision: RETEST_FAILED_STILL_VULNERABLE (Retains CONFIRMED_AUTH State) Finding State: CONFIRMED_AUTH Risk Impact: 0.0 pts risk reduction (F-20) — Live retest proved anonymous login still succeeds; closure denied.

9. EvidenceCore V3.5 Standalone Bundle Verifier, Pinned Ed25519 Registry & 25-Rule Quality Gate

To prove that any external auditor or CI/CD pipeline can verify the exported evidence, signatures, hashes, and manifest **without relying on XStrike's internal SQLite database (`v2_intelligence.db`)**, **EvidenceCore V3.5** exports a self-contained evidence bundle (`XStrike_Evidence_Bundle.json` + `ed25519_pub.pem` + `XStrike_Standalone_Verification_Log.json`) verified by the standalone zero-DB CLI module `cyber_range.services.verify_manifest` (`XStrike-Standalone-Verifier-V3.5`):

Manifest Version & ID:	EvidenceCore-V3.5 | MANIFEST-XSTRIKE-V3.5-20261031-B515B5637E
Total Signed Records:	124 (98 Security + 26 Recon) | Quality Gate Bound: 25/25
Standalone DB-Free Verifier:	VERIFIED — Mode: STANDALONE_PINNED_PUBKEY_AND_EXPORTED_BUNDLE_NO_DB | DB Dependency: NONE (Verified 100% from exported JSON bundle + pinned Ed25519 public key PEM)
Standalone Bundle Verification:	124/124 Record SHA-256 Verified | Merkle Root Matched: True | Ed25519 Verified: True | Retest Integrity: 5/5 (Cryptographic Before/After/NegCtrl Hash Integrity) | Closures Accepted: 2/5 Verified Closures Accepted (3 Retests Rejected)
Pinned Public-Key Fingerprint:	ebd393bb023088d5bc1fd0c055925a17706ac04f846f58449567e488083aaa29 (Pinned Match: True | Owner: Expedite Consults Ltd — Autonomous Security Assessment Signing Authority)
Key Custody Tier (Lab vs Prod):	Active Deployment: LAB_PINNED_ED25519_KEYSTORE (Active in Cyber Range Assessment) | Target Production Profile: AWS KMS / PKCS#11 HSM (Target Architecture — Not Deployed in Lab Assessment)
Standalone Verification CLI:	python -m cyber_range.services.verify_manifest --bundle cyber_range/reports/XStrike_Evidence_Bundle.json --pubkey cyber_range/reports/ed25519_pub.pem
Manifest Merkle Root SHA-256:	b515b5637e34431eebfa474b795680334297f1ea03030ae0d1975ec51a34a20f
Ed25519 Asymmetric Signature:	adfe70e2b6e502ef5aaa325becb3d9e29970bf01cffbe98bccabe4a36a0996f8c330f11e2f4fae23d1e171527d092e1fcd14a71f3db1ec3c14e67669d70fbf0e
Ed25519 Public Key (32-Byte Hex):	6215f820a2a64097de4d6a03413c1e4760f4ff992e0379f05bc0eb31a66da9de (Key ID: XSTRIKE-ED25519-ASYM-KEY-2026-Q4-01)
Asymmetric Non-Repudiation:	External third-party non-repudiation is provided by the Ed25519 asymmetric signature over the Merkle Root Manifest. Auditors verify the signature using only the published Ed25519 public key without access to the private signing key.
Internal Pipeline HMAC-SHA256:	88673b7ccffc55e05383c989b5bd3bceb43b249760f8e5493486167da3823fe9 — HMAC-SHA256 is a symmetric message authentication code used strictly for internal pipeline integrity and SQLite-to-PDF consistency; it does NOT provide external non-repudiation because signer and verifier share the secret.
Key Rotation, CRL & Timestamp:	Rotation Window Verified: True | CRL Verified: True (GOOD_NOT_REVOKED (Verified against XStrike Authority CRL v2026.10)) | RFC 3161 Token Verified: True
9-Vector Tamper & Governance Suite:	All 9 Passed: True (modified_record_rejected=True, deleted_record_rejected=True, reordered_records_rejected=True, altered_manifest_rejected=True, substituted_public_key_rejected=True, expired_key_window_rejected=True, revoked_key_crl_rejected=True, forged_timestamp_rejected=True, deterministic_reproducibility_verified=True)
SQLite 7-Table Snapshot Audit:	VERIFIED — 124/124 DB record hashes matched (v2_intelligence.db)
OASIS SARIF v2.1.0 Bundle:	98 machine-verifiable results exported with 7-D proof vectors & provenance hashes

Prior to generating this deliverable, **Engine 08 (ReportQualityEngine V3.5)** executed all **25 mandatory acceptance checks** (`AC-01` through `AC-25`) against the enriched finding dataset, standalone exported bundle, 7-step remediation workflow (5

outcomes), cross-section transition table, attack graph, risk model, and SQLite snapshot. Overall Gate Status: **25 automated acceptance criteria passed out of 25 (25/25 PASSED)**.

Rule ID	Quality Gate Verification Rule	Status	Verification Telemetry
AC-01	Zero Unverified / Port-Open Findings Marked CONFIRMED	PASS	0 violations across 124 findings
AC-02	Repeated Web/Network Observations Consolidated with Endpoint Counts Preserved	PASS	1851 target observations consolidated into 98 unique security findings + 26 recon items (14.9x compression; 0 duplicate host+key pairs)
AC-03	Zero Title / Description / CWE / CVE / MITRE Semantic Mismatches	PASS	100% semantic alignment across all findings
AC-04	7-Dimensional Proof Vector & Granular Access Scope Separation	PASS	All findings carry 7-D proof vectors (Execution, Auth, Exploitability, Privilege, DataAccess, Impact, EvidenceConf)
AC-05	Per-Host Asset Classification & Classification Source/Confidence	PASS	0 misclassified non-DB hosts; 7 hosts reconciled with explicit classification_source & confidence
AC-06	Reconnaissance & Telemetry Separated from Security Vulnerabilities	PASS	26 recon items isolated in Section 3B with CVSS 0.0 and DISCOVERED state
AC-07	Separated Confidence Model (EvidenceConf vs ExploitabilityConf vs ImpactConf)	PASS	All findings separate Evidence Confidence from Exploitability Confidence and Impact Confidence
AC-08	AttackGraph V3: 4-Stage Provenance, Edge-Reproducible Scores & Choke-Point Analysis	PASS	6 chains (100% edge-reproducible scores), 22 edges, and 5 choke points
AC-09	RiskEngine V3.5: Calibrated Principal Score, Measured/Verified/Forecast States & SLA Trajectory	PASS	T0 Baseline 96.8/100 (Lin 98.5) -> T1 Verified 75.6/100 (Lin 77.5) -> Forecast Only: 24h (52.3) -> 7d (33.8) -> 30d (1.5)
AC-10	Root-Cause Analysis Computed on Deduplicated Findings with 4-Tier Certainty	PASS	Root cause computed on 98 deduplicated findings (not raw scanner volume)
AC-11	100% Target-Aligned & Technology-Specific Remediation & Rollback (Zero Wrong-Host/Tech)	PASS	100% host-bound verification & service-specific rollback across 124 findings
AC-12	4-Tier Evidence-Driven Compliance Mapping with Rationale	PASS	All findings mapped to PCI-DSS v4.0, NIST 800-53, ISO 27001, and CIS Controls with 4-tier status
AC-13	EvidenceCore V3: 10-Control Provenance & HMAC-SHA256 Integrity Signatures	PASS	100% of findings (124) bound to SHA-256 + HMAC-SHA256 signed provenance records
AC-14	Strict CVE Syntax (^CVE-YYYY-NNNN+$) & Specific CWE Mapping (Zero CWE-16)	PASS	0 custom IDs in CVE field; 0 generic CWE-16 placeholders across all security findings
AC-15	Strict NVD CVSS v3.1 Score-to-Severity Band Alignment (Zero Exemptions)	PASS	100% NVD CVSS-to-Severity alignment across 98 security findings (0 exemptions)
AC-16	Endpoint Hygiene (Zero w3.org/nmap.org URLs) & Zero Generic OWASP Rollups	PASS	0 external reference URLs in affected_endpoints; 0 generic OWASP A01..A10 rollup rows
AC-17	Cross-Section Finding ID Reconciliation & 3-State Privesc Lifecycle Model	PASS	100% cross-section ID alignment (Phase 3A=['F-03', 'F-04', 'F-05', 'F-20'], Phase 3B=['F-01', 'F-02'], Phase 4=['F-06', 'F-10', 'F-21'])
AC-18	Independent Cryptographic (Ed25519 Public-Key / SHA-256 / HMAC / Merkle) & SQLite Verification	PASS	Verified Ed25519 public-key signature, 124/124 SHA-256 & HMAC records, Merkle root, 1-byte tamper rejection, and 124 SQLite records

Rule ID	Quality Gate Verification Rule	Status	Verification Telemetry
AC-19	Automated 7-Step Remediation Verification (5 Outcomes), Negative-Control & Residual Risk Recalculation	PASS	2 verified closed (F-01, F-71), 1 offline rejected (F-59), 1 partial rejected (F-77), 1 failed rejected (F-20), and Calibrated Risk recalculated 96.8/100 (T0) -> 75.6/100 (T1)
AC-20	Standalone Database-Free Bundle Verifier (verify_manifest.py V3.5), Pinned Key Registry & 9-Vector Tamper Suite	PASS	Standalone DB-free verifier confirmed 124/124 records + Pinned Ed25519 Fingerprint + Merkle root + 9/9 Self-Tests + 5/5 retests
AC-21	Canonical Finding ID Single-Source-of-Truth & T0/T1 Risk Component Mathematical Reconciliation	PASS	100% canonical Finding ID unity across 5 retest records & Section 3A; T0 (96.8) - T1 (75.6) = -21.2 pts (RawSum T1=89.9)
AC-22	Universal Version Provenance Unity (EvidenceCore-V3.5 / RiskEngine-V3.5 / Verifier-V3.5) & Forecast Reconciliation	PASS	Manifest=EvidenceCore-V3.5, RiskEngine=RiskEngine-V3.5-Calibrated-NonSaturating, Verifier=XStrike-Standalone-Verifier-V3.5; 0 legacy V3.2/V3.3/V3.4 strings; Forecast Reconciled: 24h=52.3/100 -> 7d=33.8/100 -> 30d=1.5/100
AC-23	Proof-State Normalization (PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED, REMEDIATION_INCONCLUSIVE & 4-Stage Gates)	PASS	0 ambiguous EXPLOITABLE labels (normalized to PRIVILEGE_ESCALATION_PRECONDITION_VALIDATED); offline retest recorded as REMEDIATION_INCONCLUSIVE; all 5 retests track 4-stage lifecycle gates
AC-24	MITRE Semantic Intelligence (Zero T1033/T1068/T1190 on Direct Root Chains, Privilege Context & 4-Tier Compliance)	PASS	0 T1033/T1068/T1190 misclassifications on CHAIN-01/02; structured privilege_context (uid=0, transition=NONE) verified; vsFTPd/RMI mapped to T1210; 100% 4-tier compliance enum alignment
AC-25	V3.5 Evidence Certification (9/9 Self-Tests: Rotation/CRL/TSA/Determinism) & Forecast Floor Governance	PASS	9/9 verifier self-tests passed (KeyWindow=True, CRL=True, TSA=True, Deterministic=True); 30d 1.5/100 labeled MODELED_ARCHITECTURAL_FLOOR_ASSUMPTION

10. XStrike V3.5 Autonomous Architecture, Multi-Host Benchmark & 7-Step Retest Loop

The tables below summarize the five core XStrike V3.5 autonomous capabilities (all operational & executed), the unified **TrePath v7.0 + XStrike V3.5** platform architecture, the **4-Host Heterogeneous Segmented Enterprise Benchmark** (`XSTRIKE-V3.5-MULTIHOST-ENTERPRISE-RANGE`), and the **7-Step Automated Remediation Re-Test & Negative-Control Verification Loop**:

Capability ID	XStrike V3.5 Autonomous Capability	Status	Technical Summary
CAP-01	Rules-of-Engagement (RoE) & Safety Policy Engine	OPERATIONAL (v3.5)	Enforces CIDR scope boundaries, per-technique exploit allowlists, DoS/crash prevention gates (holding MS17-010, Slowloris, and Dirty COW in non-destructive states), and read-only command whitelists.
CAP-02	Session-Aware Post-Exploitation Collector	OPERATIONAL (v3.5)	Collects structured OS, kernel, interface, SUID, NFS export, and DB catalog telemetry from established sessions using a 3-State Privilege Escalation Lifecycle (PRECONDITION_DISCOVERED, TECHNIQUE_VALIDATED, PRIVILEGE_TRANSITION_EXECUTED).

Capability ID	XStrike V3.5 Autonomous Capability	Status	Technical Summary
CAP-03	Cross-Host Pivot & Trust-Relationship Validator	OPERATIONAL (v3.5)	Maps SSH key reuse, NFS no_root_squash exports, database credential reuse, and SMB lateral paths across the 5-State Attack Path Taxonomy (EXECUTED, PARTIALLY_VALIDATED, INFERRED, BLOCKED_BY_CONTROLS, NOT_TESTED_BY_SAFETY_ROE).
CAP-04	Cryptographic Evidence Bundle, SQLite & Standalone Database-Free Verifier	OPERATIONAL & INDEPENDENTLY VERIFIED (v3.5)	Generates tamper-evident Ed25519 asymmetric + SHA-256 + HMAC-SHA256 provenance records, Merkle root manifests, OASIS SARIF v2.1.0 bundles, and standalone database-free verification via verify_manifest.py with 9-vector tamper/governance self-tests and pinned public-key fingerprint check.
CAP-05	Automated 7-Step Remediation Re-Test & Negative-Control Verification Loop	OPERATIONAL & EXECUTED (v3.5 — 2 Verified Closed, 1 Remediation Inconclusive [Host Offline], 1 Partial Rejected, 1 Failed Rejected)	Executes the 7-step Remediation Verification Workflow across 5 retest outcomes: verified closure of F-01 (:1524 Ingreslock) & F-71 (:8000/robots.txt + 4 sub-paths) -> REMEDIATION_VERIFIED, marked F-59 (:22 OpenSSH on offline .140) REMEDIATION_INCONCLUSIVE, rejected partial fix on F-77 (:80 X-Powered-By leak), and rejected failed fix on F-20 (:21 anonymous FTP).

Architectural Dimension	TrePath v7.0 (Web & API DAST)	XStrike V3.5 (Network, Host & Post-Exploit)	Unified Platform Value
Primary Assessment Domain	Web Application & API DAST (HTTP/HTTPS, REST/GraphQL, OWASP Top 10:2025)	Autonomous Network, Host, Database, Exploitation & Post-Exploitation Engine	Full-stack L3–L7 coverage from network perimeter to web app & database internals
Validation & Proof Semantics	HTTP Request/Response Replay, DOM/Reflection Proof & Status Diffing	8-State Proof Model + Exploitability Validation Gate + 4-State MITRE Execution Provenance	Zero unverified 'Confirmed' or 'Exploitable' inflation across web and infrastructure findings
Attack Graph & Choke Points	Application Endpoint & Auth-Bypass Dependency Chains	5-State Multi-Hop Attack Graph + Cross-Host Lateral Movement Succeeded vs. Precondition vs. Blocked	End-to-end kill-chain modeling from web/network entry to Crown-Jewel data stores
Evidence Integrity & GRC Export	SHA-256 Evidence Hashing & OWASP/PCI/NIST Mapping	Standalone Database-Free Bundle Verifier (verify_manifest.py V3.5) + Pinned Ed25519 Registry + 9 Self-Tests	Zero-database external auditability with public-key non-repudiation, CRL/timestamp verification & 5-outcome retest audit

10.2 XStrike V3.5 Heterogeneous Multi-Host Segmented Enterprise Validation Benchmark

Demonstrates XStrike V3.5's cross-host lateral movement validation (succeeded vs. precondition vs. blocked on tested routes), 4-state MITRE ATT&CK execution provenance, 7-step remediation verification across 5 retest outcomes, and before/after residual risk recalculation across a 4-host segmented enterprise topology.

Scenario Isolation Boundary (`EPIC 06`): ISOLATED_ENTERPRISE_BENCHMARK_TOPOLOGY (10.20.10.0/24 DMZ, 10.20.20.0/24 App/Bastion, 10.20.30.0/24 Data Tier — Strictly separated from Primary Cyber-Range Assessment 192.168.195.0/24; zero finding or score cross-contamination)

Host ID & IP	Network Zone	OS & Service Stack	Attack-Path Validation Role	Package / Backport & Control Status
MH-01 (10.20.10.15)	DMZ_INGRESS_VLAN_10	Ubuntu 22.04.4 LTS (Nginx 1.18.0 + FastAPI Gateway + OpenSSH 8.9p1)	Initial Entry & SSRF/Token Extraction Foothold (CONFIRMED_EXECUTED -> Remediated & Verified in T1 Retest)	OpenSSH 8.9p1-3ubuntu0.10 (Vendor Backport Verified via dpkg -l | grep openssh-server; 0 false-positive CVEs)
MH-02 (10.20.20.25)	APP_TIER_VLAN_20 (Segmented Firewall Boundary)	Windows Server 2019 Datacenter (10.0.17763.5576 — IIS 10.0 / WinRM 5985 / SMB 445)	Cross-Zone Lateral Pivot via Scoped Service Token -> WinRM Session (LATERAL_MOVEMENT_SUCCEEDED on :5985; SMB :445 Blocked by Mandatory Signing)	SMB 3.1.1 Signing Required; MS17-010 Patched (systeminfo KB4512508 Verified)
MH-03 (10.20.30.40)	DATA_TIER_VLAN_30 (Restricted DB Segment)	RHEL 9.3 (PostgreSQL 15.6 Primary Cluster — TCP/5432)	Read-Only Catalog Proof via App-Tier Connection String (LATERAL_MOVEMENT_SUCCEEDED from MH-02; Direct DMZ->DB Blocked by VLAN ACL)	postgresql-server-15.6-1.el9_3 (rpm -qa Verified; TLSv1.3 Enforced; Scoped Read-Only Verification)
MH-04 (10.20.20.99)	MGMT_BASTION_VLAN_20	Hardened Bastion Appliance (nftables Default-Drop)	Zero Open Ports / Tested Lateral Routes (:22, :445, :5985) Blocked by Host Firewall (TESTED_ROUTES_BLOCKED_BY_CONTROL; W_exec = 0.00)	All tested TCP SYN probes from MH-01 & MH-02 dropped at L3/L4 perimeter; 0 lateral sessions

10.2A Seeded Vulnerability & Known Control Boundary Manifest (4-Host Enterprise Benchmark)

Seed ID	Target Host	Seeded Vulnerability / Control	Expected Proof State	Known Control Boundary
SEED-MH01-SSRF-TOKEN	MH-01 (10.20.10.15:443)			VLAN 10->20 Firewall permits TCP/5985 to MH-02; blocks direct VLAN 10->30 DB access
SEED-MH02-WINRM-PIVOT	MH-02 (10.20.20.25:5985/:445)			SMB :445 lateral relay blocked by SMB v3.1.1 Mandatory Signing; MS17-010 patched (KB4512508)
SEED-MH03-PGSQL-TLS	MH-03 (10.20.30.40:5432)			Direct DMZ (VLAN 10) -> Data Tier (VLAN 30) blocked by L3 ACL; scoped read-only pg_catalog access
SEED-MH04-BASTION-DROP	MH-04 (10.20.20.99:22/:445/:5985)			100% of lateral TCP SYN probes (:22, :445, :5985) from MH-01 & MH-02 dropped at L3/L4 perimeter

10.2B 4-Host Enterprise Benchmark Remediation, Negative-Control Rejection & Risk Recalculation (Baseline `88.4/100` → Post-Retest `41.2/100`, `-47.2` pts):

Benchmark Finding	Target Host	Baseline State	Remediation / Maintenance Event	Negative-Control Alive Check	Post-Retest State
BM-F01: FastAPI SSRF & Scoped App-Tier Token Exposure (/api/v1/proxy)	MH-01 (10.20.10.15:443)	CONFIRMED_COMPROMISE	Disabled outbound metadata/RFC1918 proxy routing in FastAPI and rotated SVC_APP_POOL WinRM token	PASS — HTTPS :443 /healthz returns HTTP 200 OK & OpenSSH :22 banner active while SSRF payload returns HTTP 403 Forbidden	REMEDIATION_VERIFIED
BM-F03-NEG: WinRM Service Token Lateral Access (Retested During Maintenance Reboot Window)	MH-02 (10.20.20.25:5985)	CONFIRMED_AUTH	Host rebooted during maintenance window; TCP/5985 connection timed out	FAILED_NEGATIVE_CONTROL — ICMP Echo, ARP, SMB :445, and IIS :80 all timed out simultaneously (Host Offline)	CONFIRMED_AUTH (Retest Rejected: Offline Host Does Not Count as Remediation)

10.3 Automated 7-Step Remediation Re-Test & Negative-Control Verification Lifecycle (CAP-05)

Step	Lifecycle Phase	State	Target Execution Example	Cryptographic & Audit Artifact
Step 1	1. Baseline Finding Recorded	CONFIRMED_COMPROMISE / CONFIRMED_AUTH / VALIDATED	192.168.195.139:1524 (F-01 Ingreslock) & 192.168.195.1:8000 (F-71 Robots.txt)	Initial provenance hash PROV-F-01 & PROV-F-71 signed in Merkle Manifest (Baseline T0 = 96.8/100)
Step 2	2. Remediation Performed	CHANGE_IMPLEMENTED	Disable /etc/inetd.conf ingreslock (:1524) & kill /bin/sh; sanitize 192.168.195.1:8000/robots.txt & restrict 4 sub-paths	Technology-specific backup & change window record logged (CHG-2026-1031-001..005)
Step 3	3. Automated Retest Dispatched	RETEST_PROBE_DISPATCHED	nc -nv -w 3 192.168.195.139 1524 && for p in /robots.txt /admin /backup /config /private; do curl -sI :8000$p; done	Exact target-bound verification commands re-run against canonical host:port & all disclosed routes
Step 4	4. Before-and-After Comparison	DIFF_EVIDENCE_HASHED	Before: uid=0(root) shell & Disallow: 4 paths | After: TCP RST & HTTP 404/403 across all 5 endpoints	Side-by-side SHA-256 + Ed25519 signed before/after transcript delta
Step 5	5. Negative-Control Verification	NEGATIVE_CONTROL_VERIFIED (or REJECTED_HOST_OFFLINE)	PASS on .139 & .1 | FAIL on .140 (F-59 rejected offline), F-77 (partial fix rejected), F-20 (still vulnerable)	Proves closure is due to complete remediation on an online host, never downtime or partial masking
Step 6	6. Proof-State Transition	REMEDIATION_VERIFIED	F-01 & F-71 transition to REMEDIATION_VERIFIED (count = 2); F-59, F-77 & F-20 remain open	SQLite v2_consolidated_findings, v2_remediation_retests, SARIF v2.1.0 & Standalone Bundle updated
Step 7	7. Risk Recalculation	MEASURED_POST_RETEST_VERIFIED	T0 Baseline 96.8/100 (Linear 98.5) -> T1 Post-Retest Verified 75.6/100 (Linear 77.5) [-21.2 pts]	Preserves T0 Baseline for audit history while certifying T1 Post-Retest Verified residual risk

11. Sign-Off & Deliverables Attestation

Lead Penetration Tester: _____ Date: 2026-10-31

Principal Security Architect (Quality Gate Reviewer): _____ Date: 2026-10-31

Client System Owner: _____ Date: 2026-10-31